

NO.	토픽	중요도	중도픽	키워드 특징 및 설명	타연관 토픽
1	기본	상	보안 특징	(정의) 정보의 기밀성(Confidentiality), 무결성(Integrity), 가용성(Availability). 추가적으로 진정성(authenticity), 책임성(accountability), 부인방지(non-repudiation), 그리고 신뢰성(reliability)과 관계가 있을 수 있다." (ISO/IEC 27000:2009) CIA, 사용자 인증 요소(User Authentication Factor)	120회 기출
2		상	암호화(Encryption)	[목적] 인증(Authentication), 기밀성(Confidentiality), 무결성(Integrity), 부인방지(NonReputation) [원리] 대체, 블록, 치환, 확장, 혼돈, 확산, 압축 [방식] 대체법(Substitution), 치환법(Transposition), 대수법(Algebraic글자->숫자), 빈도수분석법, 비즈네르 암호화, 스테가노그래피 [유형] 대칭키(비밀키)-스트림(LFSR,SEL,RC4), 블록(DES,IDEA,SEED,RC5,AES) 공개키-이산대수기반, 소인수분해기반, 타원곡선방식(ECC), 전자서명방식	*암호학적 강도 높이기 위해 혼돈(Confusion)과 확산(Diffusion) 이용 이소타전
3		출제예상	암호화 원리	대체, 블록, 치환, 확장, 혼돈, 확산, 압축 혼대지수(혼돈, 대치, 치환, S-BOX), 확전순P(확산, 전치, 순열, P-BOX)	
4		중	스트림 암호화(stream cipher)	대칭 키 암호의 구조 유사난수를 1비트 생성하고, 암호화하는 값과 XOR 처리함. bit 단위, RC4(전송 계층 보안(TLS)이나 WEP 등의 여러 프로토콜에 사용) 무선통신 환경에서 사용함.	주기/비주기 동기/비동기 동기식(키 스트림 외부공급) 비동기식(키 이전 암호문비트 합수로 결정)
5		상	블록 암호화	[운영모드] ECB(Electronic CodeBook,사용금지), CBC(Cipher Block Chaining,권장), PCBC(Propagating Cipher Block Chaining) CFB(Cipher Feedback,미권장), OFB(Output Feedback), CTR(Counter,권장) [증명방법] 차분공격(Differential Cryptanalysis,입력값에 따른 출력 값 변화), 선형공격(Linear Cryptanalysis) [암호구조] Feistel(좌우분리,XOR,Round), SPN(S-Box,P-Box,혼돈,확산) [유형] DES, SEED, AES, RC5, ARIA	스왑, XOR, 쉬프트, 패딩
6		중	비밀키 암호화/비대칭 키 암호화	공개키 암호화 대칭 암호화와 비대칭(공개키) 암호화	
7		하	Feistel(피스텔)	[정의] 평문을 두 블록으로 나누어 XOR (Exclusive-OR)와 Swap 기법을 이용하는 라운드를 R번 반복으로 암호문을 만드는 블록 암호화 기술 [구성요소] Plain Text (평문), Round Key (라운드 키), Round Function (라운드 함수), Cipher Text (암호문) [특성] 장점(암호화와 복호화 과정이 동일하기 때문에 암호복호화 과정에서 역함수가 필요 없음) 단점(스왑(Swap)단계 때문에 연산량이 많이 소요, 라운드 함수를 안전하게 설계해야 하는 단점) 적용 및 사례(DES, SEED) 안전성 증명(선택평문공격인 차분공격(Differential Cryptanalysis)과 알려진 평문공격인 선형공격(Linear Cryptanalysis)등이 있음)	
8		상	암호학적 해시 함수	[정의] 역상저항, 제2역상저항, 충돌에 대해 안정성을 갖고, 임의 길이 입력값에 대해 최대 길이에 제한을 갖는 암호화 알고리즘 [종류] MAC(비밀키, CBC-MAC,MAA), MDC(빠름,전용 해쉬,MD5, HAS-1, Has-160) [특징] 압축성, 효율성, 단방향성, 충돌회피성 [활용] 디지털포렌식, 전자서명 레안보우 테이블(Raubbow Table)	SHA-2
9		하	타원곡선 (Elliptic Curve Cryptography)	[필요성] RSA의 속도와 기밀성 문제 해결, IC카드,PDA 등 HW적 구현, 적은 메모리의 암호/복호화 알고리즘 필요 [특징] 타원곡선의 굴곡을 값의 방정식에서 비대칭키 생성 이산대수 사용 하나의 키에 대해 해를 구할 수 없게 만들 구현용이, 일방향성 안정성 우수, 타원형 곡선, 공식 암기	아이소제닉 기반 확장
10		하	DES (Data Encryption standard)	[정의] 56bit 키를 이용, 64bit 평문 블록을 64bit의 암호문 블록으로 만드는 블록 암호 방식의 미국표준 [원리] 대칭키, Key생성 부분과 데이터 암호화 부분으로 나뉘며, 치환과 XOR에 의한 전치, 48bit 문자열을 32bit로 바꾸는 8개의 논리회로인 S-box사용 [문제점] 최근 컴퓨터의 연산 성능 향상으로 key길이가 56비트로 짧아 Key search machine에의한 Brute Force Attack 가능 [해결방안] - Blowfish, RC5, IDEA 등 보완 알고리즘 - 보안성을 강화한 2-DES, 3-DES 사용을 권고	
11		하	RSA (Rivest Shamir Adleman)	[정의] 소인수분해 기반 공개키-개인키를 생성하는 암호화 알고리즘 [소수] $n = p * q$ [암호화] $c = me \pmod{\varphi(n)}$ [복호화] $m = cd \pmod{\varphi(n)}$	
12		출제예상	Diffie-Hellman 키 교환	[정의] 암호화 키를 교환하는 하나의 방법으로 두 사람이 암호화되지 않은 통신망을 통해 공통의 비밀키를 공유하도록 하는 암호화 알고리즘 [특징] 공개키 사용, 이산대수 어려움, 비밀키 사용 [구성요소] key(비밀키-A와 B가 공유하는 키, 공개키-외부 공개키, 개인키-개인 소유하며 외부에 노출되지 않는 키) 기호(p -소수 1024bit 이상, g -연산에 사용되는 베이스, S -비밀키) [알고리즘 절차] 0. 사전 준비 : 사전에 엘리스와 밥은 g, p 값을 공유한다. 여기서는 $g=7$, $p=23$ 라고 가정 1. R1 생성 : 엘리스는 $x=3$ 을 선택하고 $R1=7^3 \pmod{23} = 21$ 을 계산한다. 2. R1 송신 : 엘리스는 21 을 밥에게 보낸다. 3. R2 생성 : 밥은 $y=6$ 을 선택하고 $R2=7^6 \pmod{23} = 4$ 를 계산한다 4. R2 송신 : 밥은 4 를 엘리스에게 보낸다. 5. 엘리스 K 계산 : 엘리스는 대칭 키 $K=R2^3 \pmod{23} = 18$ 을 계산한다. 6. 밥 K 계산 : 밥은 대칭 키 $K=R1^6 \pmod{23} = 18$ 을 계산한다.	이산대수 문제, 공개키, 중간자 공격
13		중	SEED	[정의] KISA와 국내 기술진에 의해 개발되어, ISO/IEC 및 IETF 표준으로 제정된 128비트 대칭키 블록화 알고리즘 [특징] 안전성/신뢰성(128bit), 효율성/사용성(하드웨어 구현용이,JPsec,전자우편), 경제성(로열티감소), 국제표준(IETF/ISO/IEC국제표준제정) [개념도] 128평문-16블록화-16라운드-블럭조합-암호문생성 [설계기준] 암호/복호 방식-대칭키, 구조-Fiestel, 데이터처리단위-8,16,32bit, 입/출력문 단위128bit, 암호/복호화 key-128bit, 라운드-16회, 내부함수-SPN,비선형함수 LUT, 안전성-자분해독법,선형해독법에 대해 안전, 효율성-3DES 대비 속도 빠름	국내암호기술, 128비트 블록암호, Feistel
14		하	AES(Advanced Encryption Standard)	[정의] DES를 대체하는 미국의 연방 표준 암호화 알고리즘으로 암호화 복호화 과정에서 동일한 키를 사용하는 대칭키 기반 암호화 알고리즘 [SPN] S-Box와 P-Box이용해 병렬성을 갖추어 암호화,복호화 알고리즘 고속화시키는 블록 암호 알고리즘 [주요함수] subByte()-confusion,S-BOX, shiftRows()-permutation,P-BOX, mixColumns()-섞음, addRoundKey()-설계암호화(XOR),key는 key expansion에 의해 제공 [비교] Feistel vs. SPN 역함수: 암호화 과정 필요없음 - 암호화 과정 필요 분할: 분할 필요/연산량 소요 - 분할없이 한번에 처리/비교적 덜 복잡 안전성: 라운드함수 안전 설계 중요 - Feistel 비해 효율적 설계 대표암호: DES,LOKI, Blowfish, RC5 - AES,SAFER,IDEA,SHARK	XOR, S-Box, P-Box, SPN

15	암호화	상	양자암호기술	양자암호통신(Quantum Cryptography Communication) 양자키분배 (QKD, Quantum Key Distribution) Quantum Channel 양자 중첩, 얽힘 등 양자물리학 특성을 정보통신기술에 적용하여 정보통신 인프라 보호 및 초고속 대용량 연산이 가능하고, 초정밀 계측을 실현할 수 있는 차세대 정보통신기술 [기술요소] 편위채퍼B - 편광, 위상, 양자채널, 퍼블릭채널, BB84프로토콜(키교환알고리즘) [구현기술] 양광단단프 양자광원, 단일광자 검출기, 난수 발생기, 양자 암호 프로토콜	양자정보통신기술 안에 양자암호 기술이 있음
16		중	큐비트(Qubit)	[정의] - 일반 컴퓨터는 정보를 0과 1의 비트단위로 처리하고 저장하는 반면, 정보를 0과 1의 상태를 동시에 갖는 양자 컴퓨터의 기본 연산 단위(퀀텀 비트(Quantum Bit)의 줄임말) [특징] 0과 1의 상태 동시, 중첩, 얽힘	비트
17		상	BB84	[정의] 0비트와 1비트의 상태를 나타내는 편광을 이용해 심자필터와 대각필터를 통해 측정해 안전하게 키를 교환하는 방법 [특징] 기저와 편광필터로 양자키 교환, 도청 시도에 대한 감지	
18		출제예상	양자내성암호화 (Post-Quantum Cryptography, PQC)	다변수기반(Multivariate-based), 코드기반(Code-based), 격자기반(Lattice-based), 아이소제니기반(isogeny-based), 해시 기반(Hash-based)	
19		출제예상	하이브리드 양자암호 통신	양자암호통신의 보완, 하이브리드 양자암호통신 가. 하이브리드 양자암호통신의 개념 - 양자 키 분배(QKD, Quantum Key Distribution) 기술과 양자내성 암호(PQC, Post-Quantum Cryptography) 기술을 동시에 결합하여 보안을 강화하는 통신 방법	
20		중	LEA	[정의] 2012년 국가보안기술연구소에서 개발한 높은 안전성과 우수한 효율성 제공하는 128bit 블록 암호 알고리즘 (특징) 속도(AES대비 1.5~2.7배), 경량코드(AES의 1/8, 적은 메모리), 높은 효율성(저전력, 임베디드적합 면적 AES의 1/3), 안정성(알려진 암호공격방어), 작은플랫폼적합(LoT, 32bit OS 최적화), 암호호환성(XOR, OR, ROLn/RORn 사용), 키 스케줄 함수(32bit), 구조(ARX기반, GFN) ARX(Addition, Rotation, XOR), GFN(Generalized Feistel Network) [구성요소] 키스케줄러-비밀키생성, 라운드 함수-반복암호화연산, 비밀키-128/192/256비트 [규격] (블록길이, 비밀키길이, 라운드수)(LEA-128-16-16-24)(LEA-192-16-24-28)(LEA-256-16-32-32) [표준화] TTAK.KO-12.0223/TTAK.KO-12.0246	ISO 29192-2
21		중	블록체인기술	데이터 거래 시 기존의 중앙 집중형 서버 관리 방식이 아닌, 거래에 참여하는 모두(노드)가 데이터를 묶음(블록)으로 분산-저장하는 방식 특징 : Block 모임, 이중지불방지, 3자 공증없음, P2P, 블록헤더, Transaction1, 2,...N저장 [보안위협] 공퍼프(공통, Public, Private) 키스취소분산 합의개사비 내권 키도난분실, 스마트 컨트랙트 취약점, 취약한 키 생성, 소프트웨어취약점, 분산서비스거부공격, 상호운용성 미제공, , 합의 가로채기, 비정상거래 탐지불가, 개인정보 침해, 가용성 저하, 사이드 체인 내 비정상 거래 발생(오라클), 내부 담합, 권한 오남용 [대응방안] 공돌기 (공통, 플랫폼, 기술) 키거참소 (키관리, 거래 검증 및 합의, 참여자 권한관리, 블록체인 SW 보안) 개유신가스 (개인정보 보호, 유효성 검증, 신뢰성 확보, 가용성 확보스캠거래 차단, 스캠거래 차단) 참사점영 (참여자 검증, 사이드체인 활용, 접근제어, 영커링 검증) 멀다HT - 멀티인증 : 개인키+OTP, 개인키+생체인증, 개인키+SMS - 다중서명 : n개의 개인키 중 m개의 서명 이중 - HSM : Hardware Security Module - TPM : Trusted Computing Group	이더리움(Ethereum)
22		출제예상	전자 서명(Digital Signature)/디지털 서명	서명자가 해당 전자문서에 서명하였음을 나타내기 위해 전자문서에 첨부되거나 논리적으로 결합된 전자적 형태의 정보(송신 개인은 송공에 있다) 1) 송신측 개인키(Private key)로 해시값 암호화 전송 2) 송신측 공개키(Public key)로 해시값 복호화 3) 별도로 보낸 메시지의 해시값과 비교하여 일치하면 서명 정당 (참고) 전자서명 ----(기밀성 강화) ----- 전자 봉투	위조불가, 인증, 부인방지, 변경불가, 재사용불가, HASH, MD생성, 개인키, 공개키, PKI, SSL, 임베디드 Secure Boot
23		출제예상	이중 서명	[정의] 판매자는 구매 정보만을, 금융기관은 결제 정보만 알 수 있도록 각각의 공개키로 암호화하는 두단계 서명 지급결제 보안 + 사용자 프라이버시 보안 구매 정보/결제 정보를 송신자 개인키로 전자서명 -> 송신자 공개키로 암호화하여 전자봉투도 함께 전송 [기술요소] 해시함수(MD2, MD4, MD5, SHA), 공개키 암호화(RSA, ECC), 비밀키 암호화(DES, 3DES, SEED, AES, IDEA), 전자서명, 전자봉투 [수행절차] 이중서명 생성 -> 전자봉투 생성 -> 구매정보 확인(판매자) -> 결제정보 확인(PG사)	SET(Secure Electronic Transaction)
24		하	메시지 인증(Message Authentication)	[정의] 데이터가 변조(수정, 삭제, 삽입 등)되었는지를 검증할 수 있도록 데이터에 덧붙이는 코드 [기법] 메시지 인증 코드(MAC), 공개키암호화, 해시함수	
25		중	HMAC (Hash-based Message Authentication Code)	[정의] 송신자와 수신자만 공유하고 있는 Key와 Message를 혼합하여 Hash값을 만드는 방식 (HMAC = Hash(Hash(message + key) + key)) [특징] - 메시지 무결성, 기밀성 보장 - 알고리즘: MD5, SHA-1 - 분류: HMAC-MD5, HMAC-SHA1 [생성절차] - 키에 대한 패딩 - 패딩한키와 1 pad의 XOR 수행 - 메시지와 결합 - 해시값 계산 - 패딩한 키와 0 pad의 XOR 수행 - 해시값과 결합 - 해시값 계산 (주의) HMAC은 해시 암호 키를 송신자와 수신자가 미리 나눠가지고 이를 사용한다는 것	
26		출제예상	엘가멜(ElGamal)	[정의] 암호화와 전자서명을 위해 개발한 암호화 기법으로 유한체(finite field)에서의 이산대수 문제에 바탕을 둔 암호 알고리즘 [특징] 암호문 길이가 RSA 대비 2배 증가, 평문 2배	
27		중	형태보존암호화 (Format-Preserving Encryption)/순서보존 암호화(Order-Preserving Encryption)	[형태보존암호화] 특정한 형태의 평문 값을 동일한 형태의 암호 값으로 변환, 시스템 변경 최소화 및 암호문 기반 통계분석 활용성 향상 지원, NIST 표준 암호화 알고리즘(FF1, FF3) [순서보존암호화] 암호화 과정에서 평문의 순서정보를 암호문에 동일하게 보존, 데이터 검색 및 연산의 질의처리 활용성 향상 지원 암호화 알고리즘	

28		중	동형 암호 (Homomorphic Encryption)	[정의] 암호화와 전자서명을 위해 개발한 암호화 기법으로 유한체(finite field)에서의 이산대수 문제에 바탕을 둔 암호 알고리즘 [특징] 암호문 길이가 RSA 대비 2배 증가, 평문 2배 [원리] 부분동형암호, 부트스트래핑, 스쿼싱 부존원 부소 RBC 부분적 동형암호, 준 동형암호, 완전 동형암호, 부트스트래핑, 스쿼싱, RAD78, BGN05, Gen09, CRT-Based	
29		하	종단간 암호화(E2EE)	통신하는 단말 사이에만 암호화, 복호화가 이루어지고 중간 서버나 통신 경로에서는 데이터를 해독할 수 없는 암호화 방식 PGP, OTR, 대칭키, 비대칭키, 키분배, 단말보안	
30		중	Sniffing	[정의] 컴퓨터 네트워크 상에서 자신이 아닌 다른 상대방들의 패킷 교환을 엿듣는 도청 행위 (소극적 공격) [sniffing 유형] switch jamming, arp redirect(ICMP redirect, ICMP router.adv [sniffing 방지] sentinel [대응기법] 암호화	promiscuous
31		중	부 채널 공격 (Side-Channel Attacks)	[정의] 디바이스에 구현된 암호 알고리즘이 동작할 때 발생하는 부채널 정보를 측정하여 암호 알고리즘 및 키 값 등을 분석하는 공격기법 [유형] 1)계산과정의 제어(수동적 공격, 능동적 공격) 2)모듈접근 방법(침입,준침입,비침입) 3)표본자료 분석방법(단순부채널 공격법(SSCA), 차분부채널 공격법(DSCA)) (공격법) 시차공격,오류공격,전력분석공격(SPA,DPA),EM공격,오류메시지공격 [대응방안] 일방대용(출력값의 상관관계제거, 명령어변경, 알고리즘수정) 공격대응기법(무작위성기법, 블라인딩기법, 마스킹기법)	그레이 박스 공격
32		중	IP Spoofing	[정의]IP Protocol의 인증 취약점을 악용하여 공격자가 자신의 IP Address를 공격하고자 하는 네트워크의 호스트 IP Address로 바꾸어 IP 기반의 인증을 무력화 시키는 공격 [방지대책] 패킷 필터링, TCP Wrapper SSH, 지속적 관리, Trusted 관계, Mac주소지정, 모니터링, 관리적보안	
33		상	ARP 스푸핑 공격	MAC 주소를 속이는 것. 로컬에서 통신하고 있는 서버와 클라이언트의 IP 주소에 대한 2계층 MAC 주소를 공격자의 MAC 주소로 속임으로써, 클라이언트에서 서버로 가는 패킷이나, 서버에서 클라이언트로 가는 패킷이 공격자에게 향하게 속임 타이머링크계증, 물리적 주소(MAC Address = 하드웨어 인터페이스 주소) 변환, 탐지기법, 대응방법 - ARP, RARP ARP 테이블이 변경되지 않도록 arp -s [IP 주소] [MAC 주소] 명령으로 MAC 주소값을 고정	Data Link Layer
34		중	RARP	역순 주소 결정 프로토콜(Reverse Address Resolution Protocol, RARP)은 IP호스트가 자신의 물리 네트워크 주소(MAC)는 알지만 IP주소를 모르는 경우, 사용하는 프로토콜(브로드캐스팅함)	
35		중	ARP poisoning	[정의] MAC Table을 위조하는 공격기법	
36		상	ARP Redirect	[정의]네트워크상의 다른 모든 호스트들이 공격자 호스트를 라우터로 믿게끔 하여 네트워크상의 모든 트래픽을 공격자의 호스트를 경유하게 하여 훔쳐보는(Sniffing) 공격 기법.	
37		중	DNS Spoofing	위악한 DNS 서버에 조작된 Query를 전송하여 DNS 서버가 저장하고 있는 주소 Cache 정보를 임의로 변조하는 공격	
38		상	TCP SYN Flooding	TCP 프로토콜의 3 Way Handshake를 악용, Buffer Overflow	
39		중	포맷 스트링 공격 (Format String Attack)	[정의] printf()와 같은 C함수 서 숫자, 문자등을 출력시 포맷스트링의 취약점을 이용, 특정 메모리 위치 값 변경 및 시스템 권한 획득할 수 있는 공격기법	시스템 공격기법:BOF공격, 포맷스트링공격
40		중	Smurfing(스머핑)	[정의] 여러 호스트가 특정 대상자에게 다량의 ICMP Echo Request 를 보내게 하여 서비스거부(DoS)를 유발시키는 보안 공격 [특징] 광범위한 효과, 가장 무서운 DoS 중 하나, IP/ICMP 특징 악용 [표적] 직접적인 브로드캐스트, 공격자/중목네트워크/표적 이용 ICMP ECHO전송-수신한 중목 네트워크 내 모든 시스템은 공격 서버에 응답	ICMP Echo
41		중	Buffer Overflow 공격	[정의] 연속된 메모리 공간을 사용하는 프로그램의 할당 메모리범위를 넘어선 위치의 자료를 읽기/쓰기시 발생현상 이용, 프로그램 오동작 유발 또는 악성코드 실행 통한 공격자가 프로그램 통제권한 획득 공격기법	strcpy(), gets(), 스택, 힙 오버플로우 공격 이용
42		상	DoS, Ddos, Model DoS	[Dos 정의] 정상적인 서비스를 하는 자원을 무리하게 요청해서 원활한 서비스가 제공될 수 없도록 하는 공격 ----- [DDos 정의] 다수의 시스템에 분산/ 설치된 Agent(악성 프로그램)를 통해 동시에 서비스 거부 공격을 하는 방법 ; 무의미한 서비스요청 반복으로 특정시스템 가용자원 소모로 가용성 저하시키는 해킹 기법 ---- DDos[공격 유형] 대역폭 소진 공격(TCP Traffic Flooding,UDP Flooding, ICMP Flooding, IP Flooding) 어플리케이션(서비스)마바공격(HTTP Traffic Flooding,HTTP Head/Option Spoofing Flooding,HashDoS,HulkDoS) [유형2] 침입기법(non-Spoofing, Spoofing), 커넥션기법(HTTP,TCP connection), Application기법, 스머프 smurf DDos 공격: ICMP ECHO 패킷조작 공격	사이버대피소
43		하	PDos 공격	[정의] 사전에 기기의 펌웨어에 악성코드 삽입, 유통시킨후 공격을 가해 DoS 및 과부하 피해를 입힌후에 제품 자체를 파괴시키는 공격 [절차] 펌웨어삽입 -> 기기파괴 -> 2차피해 PDos(Permanent DoS), 각종 전자기기들의 펌웨어(Firmware)에 악성코드를 삽입, 제품 파괴 및 공격 - 펌웨어 정상 업그레이드, 무료다운로드 유도	제품 자체 파괴 백신치료 어려움, 루트찾기 어려움 정보유출 가능
44		하	RUDY	웹 서버와 다수의 커넥션을 맺은 후 각 커넥션 별로 데이터를 매우 느리게 전송함으로써 웹 서버의 커넥션 자원을 고갈시키는 DDos 공격 기법(RUDY는 R-U-Dead-Yet의 줄임 말) [대응방안]리리세 Request timeout 설정, Read timeout 설정, 세션 임계치 제한	slowloris
45		상	APT	[정의] 타겟팅이 분명한 정밀화, 지능형 타겟 지속공격 - 특수한 목적을 가진 하나의 표적에 대해 다양한 기술을 이용해 지속적으로 정보를 수집하고 취약점을 파악 후 피해 유발 공격 기법 "하나의 표적" 타겟팅이 분명한 정밀화, 지능형 타겟 지속공격 [특징] 영우지지 명확한 타겟, 우회공격, 지능화, 지속적 [유형]백트라피 백도어, 논리폭탄, 트로이목마, 바이러스, 웜, >>. 좀비PC [공격방식] 스피어피싱, PLC, 익스플로잇, 내부자위협, 사회공학공격기법 [공격절차] 침탐수유 "단계, 공격기법, 설명 침입(관사제수 - 관찰,사회공학,제로데이,수동공격) 탐색(다운로드,다중백터,은밀한 활동,연구 분석) 수집(은근 은닉,관한상승-brute force) 유출(재중 제어,중단) [대응방법] 엔D계망대운안 End Point 보안, DLP, 보안체계수립, 망 분리, 침해사고대응센터, 시큐리티대응센터 분리 운영, 암호화 (Context Awareness 활용/관제) Security 대응->Security Intelligence로 진화	레티컬 무브먼트

46	출제예상	드라이브 바이 다운로드(DBD) (Drive by download)	[정의] 네트워크를 통한 취약한 서비스를 공격하는 방식에서 벗어나 웹 페이지에 악성 스크립트를 설치하고 사용자가 악의적인 웹사이트에 접속하는 순간 사용자 동의 없이 실행되어 악성코드에 감염시켜 시스템을 사회 공학적 공격 기법 ----- [대응 방안] 서버 측면 - SQL Injection, XSS 공격 등 웹페이지에 코드 삽입을 사전 또는 사후에 탐지 - Secure Coding 적용 - 샌드박스 활용 악성코드 사전탐지 - 지속적인 보안상황 모니터링을 통한 보안정책 업데이트 - API 취약점 솔루션 도입 통합 API 취약점 제거 클라이언트 측면 - Client Honey Pot 이용, 악성 웹사이트로 의심되는 웹사이트 분석 (악성 웹사이트 조기 탐지) 1) Low-interaction Client Honey Pot : 의심 페이지를 다운로드 하여 정적 분석 2) High-interaction Client Honey Pot : 의심 웹페이지를 직접 방문하여 발생하는 시스템 변화를 모니터링 - SW 최신유지 - 웹필터링 SW설치 - 파이어폭스 브라우저 NoScript 설치 - 자바 비활성화 - 블레이드(Blade) - 새로운 윈도우 면역시스템 - 관리자 권한 접속 금지 형상관리 활용 측면 - 매일 정적 및 동적 페이지 검사 수행	정적/동적 해킹 분석기법
47	출제예상	Exploit	[정의] 소프트웨어, 하드웨어 등의 버그 혹은 제조, 프로그래밍 과정에서 발생한 취약한 부분을 이용하여 공격자가 의도한 동작이나 명령을 실행하도록 만든 소프트웨어를 지칭하거나, 그러한 공격행위	zero-day 공격
48	상	랜섬웨어 (Ransomware)	[정의] ransom(몸값)과 ware(제품)의 합성어, 컴퓨터에 저장된 파일들을 암호화하여 사용자가 읽을 수 없는 문자들로 바꿔버린 후, 암호화를 풀어주는(복호화) 대가로 금전(몸값)을 요구하는 악성프로그램 [특징] 사회공학 기법, 금품요구, 암호화, 몸값, 금전 [랜섬웨어 저지 방안] 사전예방 -> 실시간 대응 -> 사후 복구 [대응방법] 중신데 증상확인(증상 확인, 피해 최소화 긴급조치) > 신고(증거 수집, 신고 및 증거제출) > 데이터 복구(백업, PC초기화, 복구) [백업방법] 정구백관 정책수립(백업 조직 구성, 대상별 정책 수립, 방식 결정, 점검 및 훈련) > 시스템 구축(장비 선정, 대상 선정, 백업 구성 방식 선택) > 백업절차(요청 > 요청서 검토 > 요청 확인 > 작업 > 백업 수행) > 백업보안관리(취약 진단 요청 및 대상선정 > 진단 계획 > 이행 > 취약점 조치 > 점검)	
49	중	표적형 랜섬웨어 (Ransomware)	[정의] 특정기업이나 기관의 취약점을 분석하여 이를 대상으로 정보유출과 파일 암호화를 동시에 실행하며 금전적 협박을 가하는 표적공격과 랜섬웨어가 결합된 보안 위협 [특징] 지이특정암금 지속공격, 이중 위협, 특정 표적, 정보 유출, 암호화, 금전 요구 [2단락 나. 표적형 랜섬웨어 유형] 류소섬에를랜 (NV의피포) 1)시스템 직접 침투-Manual Infection - 류크 : 스피어피싱 이용 권한 획득 후 NW 암호화 - 소디노키비 : 오라클 헬로직 서버나 시큐어 VPN 허점 악용 - 생섬 : 미국 의료시설 대상 2) 데이터 유출 미끼로 한 협박유형 - 예그레고르 : 피싱메일 - 를름 : 한국유통기업 타깃 POS 시스템 악성코드 감염 3) DDoS 위협 유형 : 랜 - 랜섬 디도스 : 특정 기업에 DDoS 공격	
50	출제예상	Ransome Web	웹 서버에 저장된 DB를 암호화하고 해당 정보를 인질로 삼아 돈을 요구하는 기법	2020.4 합숙
51	출제예상	RaaS(Ransomware as a Service)	서비스로 진화된 랜섬웨어, 다크웹 [정의] 다크웹과 같은 익명 네트워크를 이용하여 비유한 지급하면 랜섬웨어 공격을 할 수 있게끔 서비스 형태로 제공되는 랜섬웨어	2020.4 합숙
52	출제예상	Cryptojacking	가상화폐 채굴 신종 해킹	2020.4 합숙
53	하	워너크라이 (WannaCry) - 랜섬웨어	워너크라이 개념 - 2017년 5월 12일 마이크로소프트 윈도우의 파일공유에 사용하는 SMB 원격코드의 취약점을 악용한 랜섬웨어	
54	출제예상	스피어피싱(Spear Phishing)	[정의] 직장 동료나 친구, 가족을 사칭한 이메일 사기로, 특정 대상의 ID/PW 해킹하여 정보 획득하는 해킹 기법 [대응방안] 보안패치,보안프로그램설치,비밀번호경신,보안교육,전문인력양성	명확한 타겟 APT
55	출제예상	워터링 홀 공격 (Watering-Hole Attack)	미리 공격대상이 방문할 사이트에 미리 감염. 피해자의 컴퓨터 암호코드 설치하는 기법 물웅덩이(Watering Hole) + 사자 매복 형상 빗뚨 1) 주요 프로그램의 최신 버전 유지, 제로데이 공격에 대한 안티-익스플로잇(Anti-Exploit) 기술이 적용된 2) 보안 제품의 최신 업데이트 적용 3) 위협 상황에 대한 가시성 확보: 네트워크 포렌식	
56	하	Slow Read DDoS Attack	윈도우 사이즈를 0 또는 작은 데이터를 만들어, 웹서버의 3-way hadshaking 시에 서버는 계속 여기에 응답 메시지를 보내야 함. 읽고 응답은 늦게(slow)하면 서버는 Connection pool 고갈 유발 (참고)윈도우 사이즈 최대 크기: 65,535Bytes(65KB)	
57	출제예상	Slowloris (Dos)	HTTP 데이터를 장시간 유지하여, 웹서버의 리소스를 모두 소진하는 공격 웹 서버와 다수의 커넥션을 맺은 후 각 커넥션 별로 완료되지 않은 비정상 HTTP 헤더를 전송함으로써 웹 서버의 커넥션 자원을 고갈시키는 DDoS 공격 기법 서버는 타임 아웃에 도달하게 됨 (대응) http timeout 값을 조정, 혹은 일정 시간 내로 유입이 안되면, 종료함. 웹방화벽 처리함. (참고)슬로로리스: 느로로리스를 말함	
58	출제예상	은닉채널(Covert Channel) / DNS Covert Channel	기본 채널에 생성하는 통신 채널로서, 은닉 메시지 등 채널에 속여서, 혹은 삽입해서 전달하는 채널 기법 예) 스테가노그라피 예) 신호 대 잡음비를 축소해서 메시지 전달	DNS Covert Channel 기술문제 참조

59	하	사회공학(Social Engineering)	[정의] 기술적 방법이 아닌 사람들간의 기본적인 신뢰를 기반으로 비밀정보를 획득하거나 정상적인 보안 절차를 깨뜨리는 침입수단 [특징] 높은 ROI(단기간 내 해킹), 범죄행위(악의적 목적), 취약한 사람공약 [공격절차] (1) 정보수집-보안취약점 파악-휴대용 저장장치, USB 메모리 (2) 관계형성-메일 배포, 스미싱, 인적관계 이용, 악성코드 삽입 (3) 공격-의심없는 악성코드 실행, 컴퓨터 백도어 설치 실행 (4) 실행-백도어 이용 정보 탈취, 사내 NW망 취약점 반복적 확인 [대응방안] (관리적) 정보보호 거버넌스(조직내부통제), 개인정보교육(보안교육,평가) (물리적) 침입물리적 차단(보안시설, 바이오인증), 물리기기 차단(허가된 물리기기, 허용된 기기) (기술적) 패턴대응(RSK도출), 보안기술강화(최신 AI,바이오인증,MFA)	
60	하	래터럴 무브먼트 (Lateral Movement)	래터럴 무브먼트(Lateral movement, 내부망 이동; 옆으로의) - 사이버범죄자들이 공격 가능한 잠재대상 중에서 특정 기관을 선택하고 수동으로 직접 해킹한 후, 래터럴 무브먼트 (Lateral movement, 내부망 이동)로 탐지를 피하면서 목적지에 도달하는 방식으로, 자동화된 능동형 공격을 수행할 수 있는 효율적인 방법	APT
61	중	Shellcode	[개념] 공격 대상 시스템의 명령어 셸(Command Shell-ectbash)을 실행시킨다는 의미로 파생되었으며, 주로 소프트웨어 취약점을 통한 공격(Exploitation)이후 실행 될 작은 규모의 프로그램(Payload) [종류] 대상에 따른 분류(Local Shellcode, Remote Shellcode) 원격 공격 방식(Reverse Shellcode, Bind Shellcode, Download & Execute Shellcode)	OS
62	중	레이스 컨디션(Race Condition) 공격	[개념] 공유 자원에 여러 개의 프로세스가 동시에 접근하기 위한 경쟁 상태에서 생성된 임시 파일을 통해 관리자 권한을 탈취하는 공격 기법 [대응방안] 프로그램 실행 전(임시파일 생성 자체, umask를 취하 022로 유지) 프로그램 실행 중(임시파일에 링크 존재 여부 검사, 임시파일 생성 시 랜덤이름사용)	
63	출제예상	Credential Stuffing (크리덴셜 스텍핑)	이미 확보된 로그인정보를 이용해 다른 사이트나 계정에 Brute Force 하는 공격	
64	중	Malvertising(멀버타 이징)	[정의] 온라인 광고를 통해 악성코드(Malware)를 유포시키는 공격 행위 [공격절차] 위장광고 의뢰 -> 위장광고 게시 -> 애드웨어 배포 -> 위장광고 접속 -> 악성코드 감염 [대응방안] 온라인광고업체(온라인 광고 신규 계약 점검, 광고 서버 기술적 점검, 광고 서버 관리적 점검) 이용자(최신보안 업데이트, 파일다운로드 주의, 온라인 광고 차단, 온라인 악성 광고 신고)	
65	중	비즈니스 스캠 (Business SCAM)	[정의] 인터넷 무역이 Seller 와 buyer 간의 비대면 거래를 통해 이뤄지는 형태를 이용하여, 양측의 이메일을 해킹하여 거래처로 위장해 비즈니스 거래대금을 가로채는 이메일 피싱형태의 사이버범죄 수법 [공격기법] 감염 후 내부 정보 유출, 비슷한 이메일 만들기, 거래 진행 중개하기, 거래 체결 시 통장 번호 바꿔 치기 [대응방안] 정보보호 거버넌스(조직내부통제), 개인정보교육(보안교육,평가), 이메일 필터링, 미확인 수신자 메일 열람금지	
66	중	딥링크(Deepink)	웹링크가 사용자를 특정 웹사이트로 이동시키듯이, 딥링크는 사용자를 특정 앱으로 이동시켜서 원하는 화면을 보여주거나, 사용자 액션을 유도하는 링크 기법	
67	하	Worm	자기복제성, 숙주 프로그램없이 독자 실행, 시스템간 전파 사용자 물래 이메일 전송, 정상 파일에 공격 코드 삽입	
68	상	스턱스넷(Stuxnet)	1) MS 제품으로 스텍스넷이 침투 2) 지멘스 제품 찾기 3) 타겟을 공격하기 위해 업데이트 받음 4) 취약점을 찾고. 5) 타겟시스템의 OS로 침투 6) SCADA 파괴	SCADA
69	중	Virus	숙주 프로그램, 실행 가능 파일에 감염, 복제/변형/전이 시스템 파괴, 비정상 동작 유발, 데이터 삭제 및 성능 저하 초래 [진화] 1세대(원시형)-2세대(암호화)-3세대(은폐형,암축)-4세대(다형성,랜덤)	암축, 암호화
70	중	Zombie (PC)	바이러스에 감염됐지만 스스로 인지하지 못한 채 스캔을 보내는 등 원격조종당하는 PC	원격조절, 해커 보호 및 대행
71	하	트로이 목마(Trojan horse)	[정의] 겉으로 보기에는 전혀 해를 끼치지 않을 것처럼 보이지만 실제로는 바이러스 등의 위험 인자를 포함하고 있는 프로그램 자기 복제 능력이 없다는 것이 바이러스와의 차이점	자기복제불가
72	중	스파이웨어	[정의] 사용자의 동의없이 특정 사이트에 접속하게 만들거나 정보를 유출하는 악성코드 [목적] 웹 브라우저의 변화, 주기적으로 특정 사이트 접속, 웹 페이지에 홍보 등의 악성 목적을 하는 배너 출력, 사용자 정보 유출 [감염경로] Active X, 특정 웹사이트 접속 전자 메일, 악성 프로그램 통해 감염 [종류] WinSpy, 브라우저 강탈 스파이웨어, 스파이봇 등 [대응] 사용자 관리 권한 제한, 안티스파이웨어, 윈도우 보안업데이트 최신 믿을수 없는 activeX 설치금지, P2P 불법복사 금지	
73	하	악성 봇	[정의] 감염된 컴퓨터에서 일반 프로세스처럼 존재하지만 스스로 움직이지 않고 공격자가 원격 제어 가능하게 만드는 악성코드 DNS 싱크홀 (악성 봇에 따른 DDoS 공격 대응)	원격제어, DNS 싱크홀
74	하	루트킷	[정의] 전통적 UNIX 시스템에서 관리자 계정 뜻하는 root와 소프트웨어 컴포넌트 뜻하는 kit의 합성어로서, 컴퓨터의 관리자 권한을 유지하고 자신의 존재를 운영체제 또는 다른 프로그램으로부터 숨기는 악성코드 [특징] 대부분의 루트킷은 일반 프로그램이 동작하는 계층보다 더 하위 계층, 즉 커널이라는 운영체제 핵심 부분에 숨어서 동작하여 탐지,분석이 어려움. 루트킷의 위험성: 시스템의 완전한 제어권 소유, 프로그램과 파일 추가 및 변경 가능, 프로세스 감시, 네트워크 소용량 송수신, 백도어 접근 가능 [키워드] Root, 프로그램, 백도어, 메모리기반, 사용자 모드, 커널모드 은닉, 관리자 권한	
75	중	Mirai 봇넷(미라이)	IoT 디바이스를 마라이 봇넷으로 감염시킨 후, 좀비로 활용하는 DDoS 공격 C&C 서버 해킹, 원리: IoT의 디폴트 계정을 통해, 기기 통제권 획득, 다량의 트래픽 발생, 웹서비스 다운 키워드: 봇, IoT, 디폴트 암호 취약점 이용, DDoS 공격용 취약점: 수백만 IoT가 존재, 악용 용이, 보안프로그램 지원미흡을 악용.	비지박스(BusyBox)는 하나의 실행 파일 안에 스트림 다윈의 일부 유닉스 도구들을 제공하는 소프트웨어.
76	중	Phishing	금융기관 등을 사칭하여 불특정 다수에게 이메일 등 발송해 가짜 사이트로 접속을 유도하여 개인의 금융기관 카드정보나 계좌정보 등을 빼내는 사기 기법	e-mail, 가짜 사이트, 액티브 피싱(Active Phishing)
77	악성프로그램 (Malware, 악성코드)	해	[정의] 합법적으로 소유하고 있는 도메인을 탈취하거나, 도메인네임시스템 (DNS) 이름을 속여 사용자들이 진짜 사이트로 오인하도록 유도, 개인정보를 훔치는 기법 [특징] 개인정보 노출 유도, 진위 여부 확인 불가, 사전 공격 [공격단계] (1)위조 사이트 설치, (2) DNS 해킹, 데이터 위조 (3) DNS 조희 (4) 피해자가 가짜 사이트 접근하여 ID/PW/계좌번호 등 노출 [공격유형] DNS 주소변조 클라이언트 호스트 파일 변경, 클라이언트 DNS서버 설정 주소 변경, 등록된 도메인의 정보 변경 [대응방안] 기술적(도메인 기능 잠금, DNS 시스템 보안강화, SSL 확인, DNS RR 전자서명) 관리적(검증방안 고려, 웹 인증서 진위 여부 확인 방안 모색, OTP 사용, 신뢰사이트 등록제)	DNS 변조
78	하	Smishing	스미싱, 문자메시지(SMS)+피싱(phishing) = 문자메시지 이용 휴대폰 해킹, 접속유도, 악성코드감염	
79	출제예상	큐싱(Qshing)	QR코드와 피싱(fishing)의 합성어로, 사용자를 속이기 위해 한 단계 진화된 금융사기 수법	IT 기술사회 자료 참고
80	중	스팸(Spam) 메일, 스팸 (휴대폰)문자 메시지	정보통신망법과 전기통신사업법 개정, 발신번호 변경방지	

81		중	크라이웨어 (Crimeware)	사이버공격에 사용되는 악성코드 및 소프트웨어를 지칭 스텔스 기술, Stuxnet, Zeus, 봇넷, 스파이아이(SpyEye) 기술	
82		중	Web Shell	[정의] 파일 업로드 취약점 등 이용하여 공격자가 원격에서 대상 웹 서버에 명령 내려 수행할 수 있도록 작성된 웹 스크립트(asp, jsp, php, cgi) 파일 - 웹 서버에 명령을 실행하여 관리자 권한을 획득해 행하는 공격 방법 관리자 권한을 획득, 파일업로드 취약점이용, 다양한 공격 가능	파일업로드, 랜섬웨어, 호스팅, 웹 유출, 개인유출, 기업유출 기법
83			출제예상 파일리스 악성코드 (Fileless Malware)	E-Mail의 첨부파일, 인터넷 상에서 쉽게 다운 받을 수 있는 PDF, JPEG 등에 삽입되어 배포 - 공격 타겟이 되는 단말의 하드 드라이브에 설치되지 않고, 메모리 상에서만 존재하는 악성코드 단계) 스링파메다워 1단계 사용자가 악성 웹사이트로 가는 링크가 포함된 스멤 메시지를 받음 2단계 사용자 링크 클릭 3단계 악성 웹사이트는 사용자의 컴퓨터에 보안 취약점이 있는 파일 을 로딩 4단계 해당 파일은 윈도우 파워셸 도구를 여는데 파워셸은 명령어 라인을 통해 지시 사항을 실행할 수 있으며 메모리에서 작동 5단계 파워셸은 해커의 실행과 제어 C&C) 서버로부터 스크립트를 다운로드 받아 실행 6단계 파워셸 스크립트는 사용자의 데이터 위치를 알아내 해커에게 전송 [공격기법] 리메스W Reflective DLL Injection, Memory Exploits, Script-Based Techniques, WMI Persistence III. 파일리스 악성코드의 대응방안 1) 최신패치&업데이트, 2) 매크로 기능 해제 3)행위 기반 방어	IT 기술사회 자료 참고
84			출제예상 인포스틸러 (InfoStealer)	[정의] - 정보 탈취형 악성코드로서 웹 브라우저나 이메일 클라이언트 같은 프로그램에 저장되어 있는 사용자 계정 정보나 가상화폐 지갑 주소, 파일과 같은 사용자의 정보들을 탈취하는 것이 목적인 악성코드: 정보와 도둑이 합성어 [키워드] 비다르(VIDAR), 악성코드, 이메일, 문서	
85		중	타이포스쿼팅 (Typosquatting)	자주 사용하는 사이트의 URL을 교묘하게 바꿔 가져 사이트로 유도 하거나, 파일 이름을 속인 악성 소프트웨어 패키지를 내려 받도록 유도하는 사회공학적 공격 기법	오픈소스 패키지, 컨테이너 레지스트리, 재사용 패키지 위험, FQID
86		중	기타 용어	논리 폭탄(logic bomb) : 특정한 조건의 발생이나 특정한 데이터의 입력을 기록제로 컴퓨터에 부정한 행위를 실행시키는 것. 트랩 도어 (Trap Door) : 컴퓨터 범죄 수법의 하나로 시스템 설계자나 유지보수자가 고의적으로 컴퓨터 보안에 구멍을 남겨놓은 것	
87	악성코드 분석 방법	상	정적 분석(Static code Analysis)	디스어셈블러(Dis-assembler)나 디컴파일러 (Decompiler)를 이용한 역공학(Reverse Engineering)을 통해 악성코드 바이너리 파일을 실제로 실행시키지 않고 분석하는 방법 [주요기법] 소코리 소스 코드 검증, 코드 리뷰, 리버스 엔지니어링 (역공학-정적분석, 3R) [관련도구] 코폴고 스크루 CodeSonar , PolySpace , Coverity , Spaarrow , Klockwork , PurifyPlus	
88		상	동적 분석(Dynamic)	악성코드를 실제로 실행시켰을 때 수행되는 내용을 분석하는 방법 [주요기법] 디스모리 디버깅 , 스트레스 테스트, 모의 해킹, 리버스 엔지니어링 [모의해킹 도구] 버메와(밤에와) AppScan, 버프 스위트, 메타스플로잇 , 와이어 샤크	
89		중	자동화 분석 (그 외 초기 분석도 있음)	자동으로 분석하는 방법, 분석 도구 이용/Fully-automated analysis 초기 분석	
90	악성코드 탐지기법	상	시그니처 탐지기법	오미공패, Misuse 모델, 지식기반, 시그니처 기반 모두 같은 용어임 CFG(Control Flow Graph) 시그니처를 기반으로 한 탐지 기술은 코드섹션의 실행 흐름과 구조를 표현하는 그래프인 CFG를 시그니처로 이용한 기법 [기법] 스트링 시그니처, 명령어 빈도수, CFG 시그니처, 바이트 시퀀스	
91		상	휴리스틱 탐지기법	휴리스틱(Heuristic) 탐지기법 프로파일 유사도를 가지고 악성코드를 탐지 악성코드가 가지고 있는 특징을 프로파일링. 일반적으로 샌드박스과 같은 환경에서 악성코드를 실행시켜 보면서 수집된 다양한 정보를 바탕으로 비교 [기법] 악성코드 프로파일, 네거티브 휴리스틱, 유전 알고리즘	
92		상	행위기반 탐지기법	Anomaly 모델, 통계기반, 행위기반, 통계기반 모델 (Behavior Detection) 실행 파일의 실행을 통해 이전까지 알려지지 않은 악성 코드를 탐지하는 방법 무결성 검사(Integrity Check) 방법은 컴퓨터 시스템이 데이터, 실행 파일들과 시스템 자체에 대한 어떠한 변화가 없이 유지되는지 확인하는 방법 [기법] 통계, 행위 차단 방법, 무결성 검사	
93		상	샌드박스 (Sandbox)	외부로부터 들어온 프로그램이 보호된 영역에서 동작해 시스템에 부정하게 조작되는 것을 막는 보안 형태	
94	보안취약점	중	CVE	Common Vulnerabilities and Exposures의 약자 일반적인 취약점 및 노출로, CVE 시스템은 보안 취약점, 위험노출과 같은 공개적으로 잘 알려진 정보에 대한 참조 및 방법 제공	
95		하	CWE (Common Weakness Enumeration)	[정의] 미국 MITRE 기관에서 일반적으로 소프트웨어에서 공통적으로 발생하는 잠재적인 취약점을 체계적으로 분류하고 표준화한 체계 [CWE 699] 소프트웨어 개발에서 자주 사용되거나 발생하는 개념의 취약점 [CWE 1000] 취약점 연구를 용이하게 하기 위한 분류(연구자, 개발자 활용) [CWE 700] 7PK(Seven Pernicious Kingdoms) [CWE 900] CWE/SANS Top25 [CWE 928] OWASP Top10	
96		상	SQL Injection	web application에서 입력받은 파라미터 변조 후 삽입하여 비정상적 DB접근 시도 및 쿼리 재구성하여 원하는 정보 얻는 해킹 방법 [특징] DB에 악성코드 대량 삽입, 자동스크립트	The Open Web Application Security Project, AIBX(아이비지)SSM(삼)CUU(규) Blind SQL Injection(101회) 6월 모의고사 2교시 3번 문제 확인하고 풀이

97	OWASP Top 10(2021)	상	XSS	[Reflective XSS] 클라이언트에서 제공한 데이터가 서버의 응답 페이지에 바로 포함되어 돌려지는 것을 악용하는 공격 방식 URL의 CGI 인자에 악성 스크립트 코드 삽입 http://www.a.co.kr/a.asp?id=1;<script> 악성코드 </script> [Stored XSS] 웹 서버를 매개로 웹 서버에 저장된 스크립트가 피해자의 시스템에서 실행되도록 하는 공격 방식 <img src= ~~~ 태그나, <iframe width=0 height=0 ~~~ 등으로 스크립트를 교묘하게 숨김 [대응방안] 개발자(쿠키정보 추출, 특수문자 이용, HTML 태그, 스크립트 공격) 사용자(링크노출, 브라우저 취약점) [Dom XSS] 공격자는 DOM 기반 XSS 취약점이 있는 브라우저를 대상으로 조작된 URL을 이메일 통해 발송 URL 클릭 시 공격피해-> HTML 페이지를 구문 분석 할때마다 공격 스크립트가 DOM 생성의 일부로 실행되면서 공격	
98		중	CSRF	[정의] 사이트에서 제공하는 기능을 신뢰된 사용자의 권한으로 요청하도록 하는 공격 - 공격자가 사용자의 Cookie 값이나 Session정보를 의도한 사이트로 보내거나 특정한 동작을 유발하는 스크립트를 글 에 삽입하여 사용자가 게시글 등을 클릭할 경우 공격자가 원하는 동작이 실행되는 방식 - 공격자가 악성코드로 피해자의 Session Cookie 값을 이용하여 웹-브라우저로 하여금 Cross Web-site의 취약한 웹 어 플리케이션에 변조된 HTTP 요청을 보내어 공격자가 원하는 동작이 실행되도록 하는 공격 기법 [피해유형] - 정보 노출 : 쿠키 또는 세션 정보 노출 - 동일 작업 반복 : 게시글 클릭 시 공격자가 원하는 동작 수행 [대응책] - 모든 입력 값을 상세히 검증하는 것으로 헤더, 쿠키, 질의 문, 폼 필드, 숨겨진 필드 등과 같은 모든 파라미터들을 엄 격한 규칙에 의해서 검증 - 공격대상 서버에 대한 사용자 인증 정보는 해당 세션만 유효한 일회성 사용의 세션 인증 - HTML을 사용할 경우 태그 내에 html, & 등이 포함되지 않도록 작성하고 검증은 반드시 서버에서 수행	사용자의 권한으로 공격자가 원 하는, 서버에서 실행
99		중	Session Management	클라이언트와 웹서버 간 네트워크 연결이 지속 유지되고 있는 상태, 악용, 시간 설정	
100		중	OWASP Top 10	[정의] 광범위한 조직에서 발생할 수 있는 가장 심각한 웹 애플리케이션 보안 위험들을 식별하여 발표한 오픈프로젝 트[2021 Top10] 집약인 개정(안보)취식 무로위 / 4, 8, 10 A01 Broken Access Control : 접근 통제 취약점, MSA A02 Cryptographic Failures : 암호화 오류, 민감데이터 노출(AI) A03 Injection : 인젝션, 명령어와 쿼리 분리 A04 Insecure Design : 안전하지 않은 설계, 보안개발 방법론 A05 Security Misconfiguration : 보안설정 오류, 취약한 기본설정, 기본 값과 미설정 인한 취약점 A06 Vulnerable and Outdated Components : 취약하고 오래된 요소, SDLC 관리 A07 Identification And Authentication Failures : 식별 및 인증 오류, 멀티인증 A08 Software and Data Integrity Failures : 소프트웨어 및 데이터 무결성 오류, 데이터 HASH검증 A09 Security Logging and Monitoring Failures : 보안 로깅 및 모니터링 실패, 통합 모니터링 A10 Server Side Request Forgery : 서버 측 요청 위조, 요청 URL 유효성 검사	[정의] 광범위한 조직에서 발생할 수 있는 가장 심각한 웹 애플리케 이션 보안 위험들을 식별하여 발 표한 오픈프로젝트
101		중	OWASP Top 10 for LLM Application 2025	대규모 언어 모델(LLM) 기반 애플리케이션에서 발생할 수 있는 상위 10개의 보안 취약점 기술한 가이드라인 프롬프트 인젝션, 민감한 정보 공개, 공급망 취약점, 데이터 및 모델 중독, 부적절한 출력 처리, 과도한 대행, 시 스템 프롬프트 노출, 벡터와 임베딩 취약점, 잘못된 정보, 무제한 소비	모의 32회
102		하	OWASP Mobile Top 10	OWASP Top 10 2017 A1~A10까지 전체 암기	
103		하	LC/NC OWASP TOP 10	OWASP 에서 LC/NC 플랫폼에서 발생할 수 있는 보안 및 개인정보 보호관련 취약점을 발생빈도, 영향도 별로 정리한 보안 위험 목록 계정 가짜, 권한오용, 데이터 누출 및 예상하지 못한 결과, 인증 및 안전한 통신 실패, 보안 구성 오류, 인젝션 처리 실패, 취약하고 신뢰할 수 없는 구성 요소, 데이터 및 비밀 처리 실패, 자산 관리 실패, 보안 로깅 및 모니터링 실패	
104		하	OWASP LLM Top 10	프롬프트 인젝션, 민감정보 노출, 학습 데이터 조작 등 LLM 구조 특화된 취약점에 대응 위해 2023년 OWASP에서 제정한 LLM 보안 취약점 top 10 Prompt Injection, Output Handling, Training Data Poisoning, LLM Abuse, Sensitive Data Exposure, Supply Chain Vulnerability, Overreliance, Insecure Plugin, Vector Embedding Leakage, DoS, System Prompt Exposure, Monitoring Deficiencies, LLM Security, AI Risk Mitigation	
105		하	ISO/IEC 27000시리즈	[정의] 정보보안 관리시스템(ISMS, Information Security Management System)의 구축, 운영과 관련한 요구사항, 실행규범, 성과측정, 구축 가이드라인 및 ISMS 심사/인증기관 요구사항 등을 규정 [세부구성항목] ISO/IEC 27000(정보보안 관리체계 - 개관 및 어휘), ISO/IEC 27001(정보보안 관리체계 - 요구사항), ISO/IEC 27002(정보보안 관리를 위한 실무규약), ISO/IEC 27003(정보보안 관리체계 이행 가이드라인), ISO/IEC 27004(정보보안 관리-측정), ISO/IEC 27005(정보보안 위험관리), ISO/IEC 27006(정보보안 관리체계를 감사 및 인증하는 기관에 대한 요구사항), ISO/IEC 27011(통신분야에 특화된 ISM 적용 실무지침), SO/IEC 27033(네트워크 시스템의 보안관리와 운영에 대한 실무 지침), ISO/IEC 27799(의료 정보분야에 특화된 ISM 적용 실무 지침)	
106		상	ISO 27001	[정의] 기업이 각종 위험으로부터 주요 정보자산을 보호하기 위해 수립, 관리, 운영하는 종합적인 정보보호 관리체계의 적합성에 대해 인증을 부여하는 제도 [항목] 관리과정(12), 보호대책(92)	ISMS ISMS - P
107		하	ISO 27002	ISO 17799	
108		출제예상	ISO/IEC 27100	사이버 환경에서 네트워크를 통해 연결된 조직/사용자 자산을 보호하기 위해 ISO/IEC 27000 기반으로 제정중인 국제 표준, 0123 032-개구보관론 27100 : 보안에 관한 전반적인 개념 27101 : 개발하고 구축하기 위한 가이드 라인 27102 : 사이버 보안을 도입하기 위한 가이드 라인 27103 : 관리하기 위한 방법 27032 : 문제를 해결하기 위한 지침	IT 기술사회 자료 참고
109		상	ISMS, G-ISMS	정보보호관리체계(ISMS), 의무, KISA 인증 의무대상자 기준	각 인증제도 비교
110		상	ISMS-P	[정의] 기업이 개인정보보호 활동을 체계적, 지속적으로 수행하기 위해 필요한 보호조치 체계를 구축하였는지 점검하여 일정 수준 이상의 기업에 인증을 부여하는 제도 [인증기준] 관리체계 수립 및 운영(16), 보호대책 요구사항(64), 개인정보 처리단계별 요구사항(22) 관리체계 기반 마련, 위험관리, 관리체계 운영, 관리체계 점검 및 개선 정책/조직/자산관리, 인적보안, 외부자보안, 물리보안, 인증 및 권한 관리, 접근통제, 암호화 적용, 정보시스템 도입 및 개발보안, 시스템 및 서비스 운영관리, 시스템 및 서비스 보안관리, 사고 예방 및 대응, 재해복구 개인정보 수집 시 보호조치, 개인정보 보유 및 이용 시 보호조치, 개인정보 제공 시 보호조치, 개인정보 파기 시 보호 조치, 정보주체 권리보호 [주요개정사항] 유사항목 통합&재배치(관리 체계 통합, 패스워드 관리 통합, 개인정보 관리 통합) 최신 기술 및 이슈 반영(클라우드 보안추가, 이상감지시스템 보안 추가, 핀테크 보안 추가) 법개정 사항 반영(개인정보 국외이전, 개인 단말기 보안, 개인정보 폐기)	정보통신망법 제47조 2항
111		하	PIMS	PIMS(Personal Information Management System) PIMS와 PIPL을 PIMS로 일원화, 심사는 KISA와 인증기관이 수행함	
112		하	PIPL	PIMS로 통합, 행안부	

113	보안 표준 (정책) 및 관리적 보 안	중	CC (Common Criteria)	국가마다 서로 다른 정보보호시스템 평가 기준을 연동하고, 평가 결과를 상호 인증하기 위해 제정된 정보보안 평가기준(ISO/IEC 15408표준) 보안가능 요구사항 구조-패피 스이타 1) 패키지 : 기능보증사항의 집합, 재사용 가능, PP/ST의 기초 2) PP(Protection Profile) : 공통 심사기준 3) ST(Security Target) : 특정제품/시스템 의존기능 및 요구 4) EAL(Evaluation Assurance Level) : PP/ST의 등급(0~7 등급) 5) TOE(Target of Evaluation) : 심사 대상 객체 ISO/IEC 15408 특징 : 평등문지인 평가 (보안기능과 보호기능 평가) 보안등급체계 (EAL 부여 - 0~7등급, 0 = 부적절) 관련작성 문서 (PP, ST), 평가수행 지침 (CEM-Common Evaluation Methodology), 인증서 효력 (CCRA 가입 사- Common Criteria Recognition Arrangement)	CCRA 상호인증협정
114		하	CC - cPP	cPP(유형별 보호프로파일)는 국제CC인증을 받기 위해 참고가 되는 일종의 가이드 라인, Collaborative Protection Profile은 'Encrypted Storage', 'Network Device' 등을 추가하여 해의 수출할 때는 위 cPP로 검 사하는 것으로 변경됨	CC인증제도의 변화
115		하	계층적 방어 체계 (Defense-in-Depth)	다양한 공격으로부터 정보자산을 보호 하기 위해 방어 체계를 네트워크/시스템/어플리케이션 3단계 계층으로 구분하 여 단계적 대응 하는 보안 체계	
116		하	보안관제서비스 (Security Operation Service)	웹/바이러스, 해킹 시도 등 내부 정보기술(IT) 자원을 위협하는 침입시도에 대해 24시간 실시간 모니터링을 통해 안 정적인 운영을 확보하기 위한 보안서비스	
117		하	ISO/IEC 27014	[정의] 정보보호에 대한 최고경영층의 의사결정 권한과 책임, 비즈니스 와의 전략적 연계, 컴플라이언스 보장을 위해 지켜야 할 원칙과 수행해야 할 활동 및 과제를 정의한 표준 [조직] 최고 경영층(이사회)-기업 정보보안 위험 대응 주체, 소통 책임, 평가 실행조직 [프로세스] direct(전략, 정책 기반으로 지휘), evaluate(활동에 대한 피드백, 평가), monitor(정책의 준수, 계획 대비 성과 를 모니터링), 의사소통, 감사	ISO/IEC 27014 정보보호 거버넌 스
118	출제예상		ISO/IEC 27017	클라우드 서비스 보안을 위해 ISO/IEC 27002를 기본으로 클라우드 서비스 관련된 내용을 추가한 ISO/IEC국제 표준 정조인자 집합을 운통시 공사면법 정보보호 정책, 정보보호 조직, 인적보안, 자산관리, 접근통제, 암호화, 물리보안, 운영보안, 통신보안, 시스템 개발보안, 공급망관리, 사고관리, 연속성관리, 법적 준거성 1규 2실 9프 ISO 27001 -ISMS 심사 및 인증 규격 ISO 27002 -정보보안관리에 대한 실행 지침 ISO 29100 - 개인정보 프레임워크 국제 표준	
119		상	ISO/IEC 27018	클라우드 서비스 내 개인식별정보의 안전한 처리를 위한 통제와 가이드라인을 제공하는 국제표준 [구성요소] 개인식별정보(PII), 컨트롤러, 프로세서 [통제항목] 일동함수데사 정개책 책정규 0) 일반 1) 동의와 선택, 2) 합법성 및 사용목적, 3) 수집제한, 4) 데이터 최소화 5) 사용 및 공개 제한, 6) 정확성과 품질, 7) 개방성, 투명성, 8) 개인참여와 접근, 9) 책임, 10) 정보보호, 11) 개인정보 보호규정	
120			GDPR	GDPR(General Data Protection Regulation) 1995년 'EU 개인정보보호지침(directive)' 제정 20년 후 규정(regulation)된 개인정보 보호 법령 (2018년 5월 25일부터 시행되는 EU(유럽연합)의 개인정보보호 법령) 개인정보보호책임자(DPO, Data Protection Officer) 지정 1) 변동 : [영D과지정동침] 개인정보영향평가, DPO지정, 과징금 강화, 지리적 범위 확대, 정보주체권리강화, 동의조건강화, 침해사고발생시 통지의무 2) 원칙 : [개처동아민] 개인정보처리원칙, 처리의 적법성, 동의, 아동개인정보, 민감정보 3) 체계 : [일일권 권3독 협처특위체] 일반규정, 원칙, 정보주체의 권리 컨트롤러와 프로세스, 제3국 및 국제기구로의 개인정보 이전, 독립적인 감독기구 협력 및 일관성, 구체적/책임/처벌, 특정정보처리 상황에 관한 규정, 위임 법률 및 시행 법률, 최종규정 4) 주체권리 : [제열수 삭제이반프] 정보 제공권, 열람권, 수정(정정)권, 삭제권, 처리제한권, 이동권, 반대할 권리, 자동화 된 결정 및 프로파일링 관련 권리	데이터3법 개정과 연계해 생각 -> GDPR 적정성 평가 획득위해 서 데이터3법이 개정됨
121	SW개발보 안	하	ISO 28000	[정의] 공급사슬 전반에 걸쳐 보안(Security)을 보장하기 위한 핵심적인 측면을 포함하여 보안경영시스템을 수립, 이 행, 유지 및 발전하도록 하는 요구사항을 담은 표준 [시리즈] ISO 28000 : 공급사슬 보안경영시스템의 구축 및 실행, 유지, 개선을 위한 규격 ISO 28001 : 공급사슬보안, 평가 및 실행을 위한 모범사례 ISO 28003 : 공급사슬 보안경영시스템 심사 및 인증 ISO 28004 : ISO 28000 실행 지침 [표준구성] 범위, 인증규격, 용어정의, 보안경영시스템요구사항(일반요구사항, 보안경영방침, 보안리스크 평가 및 기획, 실행 및 운영, 점검 및 시정조치, 경영검토 및 지속적 개선) [평가기준] 물리적 보안, 출입 통제, 절차 보안, 인적 보안, 문서화 절차, 정보보안, 안전한 화물 흐름	물류보안 표준 ISO 28000
122		하	ISA/IEC 62443	자동차 및 제어 시스템의 운영 기술에 대한 사이버 보안을 다루는 국제 표준 시리즈	132회 기술문제
123		상	*SW개발보안 (시큐어 코딩, Secure Coding)	[입력데이터 검증 및 표현] 외부 입력에 의한 직접 파일 디렉토리 생성 필터링 [보안특성-취약한 암호화] RC2,MD5,SHA-1 대신 AES 사용 [시간 및 상태-경쟁조건] 공유자원 동기화 구분 [에러처리-오류 상황 처리부재] 예외,오류 포착시 적절한 처리 [코드 품질-널포인터 역참조] 레퍼런스 null값 여부 검사 [캡슐화-public 할당] public 대신 private 사용, 디버깅 코드 삭제 [API악용] DNS lookup의존, NULL피검사-Objectequals(), omlparable.compareTo()사용	
124	SW개발보 안	중	TOCTOU (Time Of Check, Time Of Use)	[개념] 멀티프로세스를 구현한 응용프로그램(병렬시스템)에서 자원(파일, 소켓 등)을 사용하기전 자원을 사용하는 시점과 사용하는 시 점의 시간 및 상태를 부적절하게 관리해서 발생하는 보안 취약점 [해결방법] 동기화(뮤트엑스, 세마포어)	시점 차이 동기화
125		중	소프트웨어 개발 보안 가이드	[설계단계] 입력값 데이터 검증 및 표현, 보안기능, 에러처리, 세션처리 [구현단계] 입력값 데이터 검증 및 표현, 보안기능, 시간 및 상태, 에러처리, 코드오류, 캡슐화, API 오용 [개정상항] XML삽입, 암호화 되지 않은 중요정보, 하드코드된 중요정보, 오류 메시지 정보노출 [신규보안악점] 코드삽입, 부적절한 XML 외부개체참조, 서버사이드 요청 위조, 부적절한 전자서명 확인, 부적절한인증서유효성검증, 신뢰할 수 없는 데이터의 역직렬화 인증, 권한부여, 무결성, 실행권한, 정보시스템 감리 대상 사업, 부적절한 입력값, 정수형 오버플로우, Null Pointer 역참조, 위험한 형식 파일 업로드	

126	PKI	상	PKI	공개키 기반 인프라 구조 [정의] 인증기관(CA)에서 공개키와 개인키 포함 인증서 발급받아, 네트워크 상 안전 비밀통신 가능케 하는 기반 인프라 구조 [특징] 인증, 기밀성,무결성,부인봉쇄,접근제어,키관리 [구성요소] 인증기관(CA), 디렉토리(LDAP,키관리), 등록대행기관(RA), 사용자 [검증방식] CRL, OCSP(Online Certificate Status Protocol,실시간 인증서 유효성 검증), SCVP(Simple Certificate Validation Protocol,인증서 체인제공)	전자봉투
127		하	인증서	Certificate, 인증서 생성 및 검증, CRL	
128		중	전자봉투 (Digital Envelope)	[정의] 송신자의 키로 전자 서명된 메시지를 암호화하여 기밀성을 보장하기 위한 기법 매커니즘: 전자서명과 메시지 암호화 비밀키를 전자봉투로 전달(송씨 개인암은 비밀 수공암에 있다.) 전자서명 : 송신자 개인키로 암호화 전자봉투 : 비밀키를 수신자 공개키로 암호화	위조불가, 인증, 부인방지, 변경불가, 재사용불가, HASH, MD생성, 개인키, 공개키, PKI, SSL, 임베디드 Secure Boot
129		중	공인인증서 문제 및 해결방안	공인인증패지에 따른 문제점, 대응방안 - 기존 공인인증서의 적용기술 및 문제점 1. Active-x사용 2. 1년마다 갱신, 국내만 규제 존재/해외 없음(갈라파고스 규제/독자 규제) - 대응 1. 블록체인 2. (인터넷 전문은행의) 사설 인증 방법 전체: 휴대폰, 타행 계좌 이체 등 3. FIDO	
130	VPN	중	VPN (Virtual Private Network)	[정의] 터널링 기법을 사용해 공중망에 접속해 있는 두 네트워크 사이의 연결을 마치 전용회선 이용에 연결한 것과 같은 효과를 내는 가상 네트워크 [필요기술] 터널링, 암호화, 인증, 키관리, 복수프로토콜처리 [구축] 준비단계(IKE 정책설정-VPN간 인증키 설정, SA생성, IKE 교환프로토콜설정) IPSec접속단계(AH,ESP방식 결정, 암호화/무결성확인) IPSec활성화(강제, 인터페이스 IPSec VPN적용,Host간 연동)	IPSec VPN : RFC 2401~2410 SSL VPN : X MPLS VPN : RFC 2547
131		상	SSL VPN	[개념] 전송 계층 보안 프로토콜 SSL/TLS을 이용해 데이터 송신자 인증과 암호화를 구현한 가상 네트워크 [구현 프로토콜] 핸드셰이크 프로토콜, 암호화상 변경 프로토콜, 경고 프로토콜, 레코드 프로토콜	
132		중	IPSec VPN	[개념] IPSec 프로토콜의 AH, ESP 헤더를 이용해 데이터 송신자 인증 및 암호화를 구현한 가상 네트워크 [구현기술] 인증, 암호화, 키관리, 터널링	터널링
133		하	MPLS VPN	패킷 스위칭 기술인 MPLS 환경을 통해 VPN 구현	
134		출제예상	MoVPN	모바일 환경+VPN	
135	디지털 포렌식	상	디지털/컴퓨터 포렌식	정보시스템 통한 범죄 행위에 대한 법적 증거 자료 확보를 위한 시스템, 네트워크 등 가상 공간의 자료를 법적 증거로 확보, 제출하는 일련의 방법 [특징] 매체독립성, 대용량, 디지털(무결성 검증 필요), 비가시성, 휘발성, 네트워크성 [원칙] 정(당)재신연구 정당성의 원칙(위법시 법적 효력 상실), 재현성의 원칙(동일 결과), 신속성의 원칙(휘발성 데이터), 연계 보관성 원칙(획득,이송,분석,보관,법정제출 책임자), 무결성 원칙(위조,변조 증명) [절차] 준(중)확보분보 준비(압수 수색영장, 관계자 협조, 현장 채증 장비, 증거분석 도구) 증거물 획득(메모리 덤프, 디스크 이미징, 네트워크 로그, 관리자 진술) 보관 및 이송(반출입 통제, 온도도 유지, 자성회피, 전자파 차단) 분석 및 조사(명확한 분석, 재현가능, 무결성 유지, 기록 유지) 보고서 작성(사실 근거, 명확한 기록, 증거 제출) [수집기술] 디메우 파삭비이 술암업 수집기술(디스크 이미징, 메모리 덤프, 무결성 입증) 분석기술(file time line, 삭제된 파일 복구, 비정상 파일, 이메일, 슬랙공간, 암호복구, 덤프 메모리 분석)	[유형] 디네E 소모암회 - Disk 포렌식(비휘발성, FAT,NTFS, EXT2), - NW 포렌식(트래픽, 라우터, FW, IDS), - E-mail 포렌식(수신, 발신 정보), - 소스코드 포렌식(원시코드 작성자, 상관관계), - 모바일 포렌식(휴대폰, USB), - 암호 포렌식(암호문서, 시스템), - 회계 포렌식(회계 시스템, Oracle ERP) - 클라우드 : 클라우드 시그니처
136		출제예상	스마트폰 포렌식	논리적 추출(Rooting, Jailbreak), 물리적 추출(JTAG) [가이드라인/NIST] 현장의 확인 및 보호 - 증거물의 획득 및 이송 - 증거물 데이터의 수집 및 분석 - 증거물 보관 - 보고서 작성 및 제출 (증거 추출 도구) QPST(퀵, 내장메모리, FS, 데이터 추출, 삽입/쓰기방지 없음/불안정) EasyCDMA(Pinksoft사 PC연결 툴, FS, 데이터 추출 삽입/쓰기방지 없음/불안정) Bitpim(GNU사, opensource, FS, 데이터 추출 삽입/쓰기방지 있음/매우 안정)	IMEI, IMSI, 충전, 네트워크차단
137		중	네트워크 포렌식	[정의] 네트워크를 통하여 전송되는 데이터나 패스워드 등 데이터 트래픽을 분석하거나 접근 예러로그, 네트워크 환경 등을 조사하여 수사 단서를 찾아내는 기법 [절차] 정보수집(시간-발견/날짜/시간/방법, 주변환경-8ig모델, 네트워크 토폴로지, 조직구조) 전략수립(조사 목표 기간, 증거 출처, 증거 우선순위 - 방화벽 로그/웹 프록시 캐시/ARP 테이블 - 중요도/수집난이도/휘발성/우선순위) 증거수집(문서화, 수집, 저장과 수송) 분석(연관성, 타임라인, 흥미로운 이벤트, 확증, 추가적 증거복구, 해석) 보고서(사실기반, 비전문가 이해 가능 내용)	정보수집, 전략수립, 증거수집, 분석, 보고서, 패시브 증거수집, 액티브 증거수집 트래픽 수집 소프트웨어, 케이블, 라디오 주파수, 허브, 스위치 감청 포트 스캐닝, 취약점 스캐닝
138		하	클라우드 포렌식 (Cloud Forensic)	[정의] 클라우드에 존재하는 전자적 증거물 등을 사법기관에 제출하기 위해 클라우드 시그니처(Signature) 데이터 수집, 분석 및 보고서를 작성하는 과학수사 기법	
139		중	증거물관리의 연속성 (Chain of Custody)	현재의 증거가 최초로 수집된 상태에서 지금까지 어떠한 변경도 되지 않았다는 것을 보증하기 위한 절차적 방법	증거물 획득, 보관 및 이송, 분석 및 조사, 수사기관, 인증기관, 사업기관, 증거물 관리대장
373	디지털 포렌식	하	디지털 포렌식 아티팩트(Artifact)	컴퓨터나 디지털 기기에서 사용자의 행위나 시스템 동작의 흔적을 보여주는 데이터나 파일 조각 시스템/응용 프로그램/파일 아티팩트(아티팩트) - 흔적, 증거물, 시스템/응용 프로그램/파일 아티팩트, 정적, 동적, 이미지	137 관리 1교시
140		중	디스크 이미징(Disk Imaging)	이미징 = 사본 생성 (1) 디스크 이미징 용도 (2) Disk to Disk와 Disk to File 방식 (3) 디스크 이미징을 활용한 증거수집 방법	

141		출제예상	안티포렌식	[데이터 영구삭제] Disk Wipe: 하드디스크 기존 데이터 완벽 제거, 모든 섹터 null Degausser: 하드디스크 등에 강력한 자기장 노출, 기록 파괴, 복구 불가능장비, Log data 삭제: OS 자동 생성 정보 즉시 자동 삭제 디스크 덮어쓰기: 삭제후 디스크에 남은 부분 복구 회피 [암호화] 압축파일 암호화(zip, rar), 문서파일 암호화(MS오피스, 한글등) 물리적 암호화(가상디스크, USB, OS 등), 스테가노그래피 [데이터 파손] 물리적 파손(소각, 파쇄, 전자파 등) [데이터 은닉] Slack space	
142		출제예상	데이터 카빙(Data Carving)	연속적 카빙(헤더/푸터/램슬랙/파일크기), 비연속적 카빙(시그니처/엔트로피/바이트분포)	
143		중	파일 카빙	메타데이터, 파일 복구, Header/Footer, Ram Slack, File Slack	
144		중	슬랙 공간	슬랙 공간 (Slack Space Area) / 기술 정리	
145		출제예상	AAA	[정의] 불법적 서비스 사용 방식을 위해 사용자 인증, 권한레벨 검증, 과금기능을 제공하는 서비스, 프레임워크와 기술의 총칭 [기술필요] 유무선통합, 디바이스 발달 [사업] 인증,권한,과금, 망/로밍서비스 [주요기술] 인증(PKI, PAP-PW Auth Protocol, CHAP-Challenge Handshake Auth Protocol/PPP인증규약/비밀번호 암호화), 관리(로그감사,접근제어), 암호화통신(SSL,IPSec) [역할] 인증(PW,개인식별번호),권한부여(접근기준,접근금지,Need to Know), 책임추궁(감사정보 재조사,키입력검사)	인증, 권한, 과금
146		하	패턴기반 인증(스마트폰)	Pattern Lock, Scribble-a-Secret, Drawing Geometric	
147		하	RADIUS	[정의] 보안을 위해 ID, 암호, 가능한 필요 보호 조치를 통해 사용자 인증하는 네트워크 접근제어 보안 프로토콜 [특징] UDP(비연결성,비신뢰성), Client-Server(단방향), 전송제어(packet loss,timeout감지 전송오류 보완), PW만 암호화(이름,권한,과금 평문전송-공격 취약) [절차] NAS <-> RADIUS서버 (Access-Req , Access-Rsp)	
148		출제예상	DIAMETER	[등장] mobile IP의 AAA지원 표준화, 로밍 지원 필요 [정의] 다양한 망 연동 유무선 이동 인터넷 환경에서, 인증/권한검증/과금 서비스를 제공하기 위한 AAA 표준 프로토콜 [특징] TCP(연결성,신뢰성,TLS,IPSec), P2P(양방향), 패킷전체 암호화, 보안성/확장성, Fail-over 지원, 로밍지원 [구조] Diameter서버-(AAA msg)-Diameter브로커-(AAA msg)-Diameter서버 (visited NW) (Home NW)	RFC 3588, HSS(Home Subscriber Server)와 연동
149		중	MAC (Mandatory Access Control)	분류-규칙기반(MLP(Multi-Level Policy),CBP(Component Based Policy)),관계기반 상위 레벨에서 하위레벨 읽기 가능, 하위레벨에서 상위레벨 쓰기 가능 [보안등급] TS,SCU	강제적 접근제어, 군사용
150		중	DAC (Discretionary Access Control)	객체의 소유자가 접근 여부를 결정 방법 - CL(Capability List,주체중심), ACL(Access Control List,객체중심) 분류 - Identity based(신원), User Based(사용자), Hybrid(혼합) 종류 - IBP(Industrial Based Policy,사용자별), GBP(Group Based Policy,조직별)	신원기반, 사용자 기반
151	접근 제어 (AC)	중	RBAC (Role Based Access Control)	개인 역할기반 DAC의 GBP변형	역할기반 접근제어
152		중	ABAC (Attribute-Based Access Control)	속성 기반 접근통제 [관리주체] 정책 관리자 및 시스템 [적용방식] 사용자, 리소스, 환경속성 기준	135회 관리 2교시
153		상	AC	[구성요소] 타입/정책: DAC, MAC, RBAC 메커니즘: ACL, CL, SL 모델: BLP, BIBA, Clark-wilson, Chinese Wall(관리장성 모델) [고려사항] 접근통제 고려사항 : 최소권리, 직무분리, 알필요성(최소정보)	
154		중	접근제어 Model(Bell-Lapadula, Biba, Clark & Wilson , Access Matrix)	Bell-lapadula (기밀성보장, No read up, no write down), 극비/비밀/미분류 구분 Biba(무결성보장, No read down, no write up), 벨+볼법 수정방식 내용 추가 Clark and wilson(무결성보장), 상업 환경 적합, 불법 수정 방지 access matrix(ACL,CL), 주체와 접근 허용 권한 테이블, 주체-행, 객체-열 관리장성 (주체와 객체 사이의 이해 충돌 통제하기 위한 모델)	
155		하	XML 보안(웹서비스 보안)	XML서명, XML암호화, XKMS, SAML, XACML	
156		출제예상	NAC(Network Access Control)	[정의] 사용자 Endpoint(PC, 노트북 등)의 NW 접근 시도 시 사전 승인여부 및 보안정책 준수 여부를 확인하고, NW 접속을 승인 또는 차단하는 네트워크 접근제어 시스템 [키워드] 네트워크 권한 통제, 위협 모니터링 및 탐지, 정책 관리	
157		중	TCP wrapper	[개념] 네트워크 서비스에 관련한 트래픽을 제어하고 모니터링 할 수 있는 UNIX 기반의 방화벽 툴 [특징] 네트워크 접근제어, TCP 서비스 제어 [구동과정] 클라이언트 접속 요구, 클라이언트 접근권한 확인, 네트워크 서비스 제공 [설정] /etc/shosts.allow, /etc/hosts.deny	
158		중	LDAP	[개념] LDAP(Lightweight Directory Access Protocol)는 사용자가 조직, 구성원 등에 대한 데이터를 찾는 데 도움이 되는 프로토콜 [키워드] 인증, Log4j, X500, 필터링 [활용] Kerberos, SSO(Single Sign-On), SASL(Simple Authentication Security Layer), SSL(Secure Sockets Layer) 지원, 액세스 관리(IAM) 솔루션 역할	
159		출제예상	Honey Pot(허니팟)	[정의] 보안 담당자가 공격자의 키로그(keylog)나 공격 방법, 유형에 대한 연구를 위해 설치해놓은 시스템 [요건] 노출, 취약, 모든 구성 갖춘 시스템, 패킷 감시, 관리자 인지 [구성요소] 허니팟(서버,윈도우), 로그서버(facility,level) [유형] 에뮬레이터(VMWare)-허니팟,로거서버 함께 운영,저렴,시스템고장시 전체중지 Gen-I 허니넷(Honeynet)-방화벽 안에 허니팟 설정, 스위칭 환경에서 로그 서버 운영, DoS공격 방어, 자동화 툴, 원격격에 좋은 성능	사이버 디셉션
160		출제예상	사이버디셉션(Cyber Deception)	허니팟의 진화형태, 내부보안 방어 및 실시간 탐지 모니터링 가능한 공격자 기만 기술	
161		중	Firewall(방화벽)	[정의] 외부로부터 불법침입과 내부의 불법정보 유출을 방지하고, 내,외부 네트워크의 상호간 영향을 차단하기 위한 보안시스템 [주요기능] 접근제어, 사용자 인증, 감사 및 로그, 프로시 기능, NAT [구축유형] 스크리닝 라우터(패킷 헤더 정보분석, 필터링, L3/L4동작) 베스전(Bastion) 호스트(인증기반, 접근통제, 로그기록, 모니터링, GW역할) 듀얼 홉드 GW(내/외부 네트워크 분리, 보안성, 내부 IP노출 안됨) 스크린드 호스트 GW(듀얼홉드+스크리닝, 2단계 보안점검, 가장 많이 사용) 스크린드 서브넷 GW(스크리닝+듀얼홉드+스크리닝, 완충지역, 강력보안 느낌)	port 80
162		상	NAT	주소 변환 기능, 유형 3가지 잘 정리할 것 IP Masquerading, Port Forwarding	네트워크
163		출제예상	IP Masquerading	다수의 private IP를 1개의 public IP로 변환	

164	중	Web Firewall(웹방화벽)	[정의] 웹서버로 들어오는 웹 트래픽을 트래픽을 검사 , 악의적인 코드나 공격유형이 포함된 웹 트래픽 차단 [주요기능] 사용자 요청검사(Web DoS, 응용 접근제어, 버퍼 오버플로우, SQL/스크립트 차단, 업로드 파일 검사) 컨텐트보호(신용카드 정보 유출 차단, 주민번호 유출 차단, 웹변조 방지, 응답형식 검사, 코드 노출 차단) 위장(URL 정보 위장, 서버 정보 위장) SSL 복호화 지원(암호화된 HTTPS 웹트래픽 복호화통한 웹 검사) [유형] 설계방식(네트워크 기반 웹 방화벽, 호스트 기반 웹 방화벽) 내부아키텍처(프록시 방식, 필터링 방식)	
165	중	IDS	[정의] 비인가된 사용자가 자원의 기밀성, 무결성, 가용성을 저해하는 일련의 행동들과 보안정책 위반 행위(침입)를 실시간 탐지하는 시스템 (주요기능) 경보기능(경보,이메일 발송, SNMP Trap발송) 세션차단기능(의심 행위 감지, 세션 차단) 실시간 탐지(실시간 침입 탐지 기능) reporting(통계적 분석 및 리포팅 기능) [구성] 정보수집기, 정보 분석기, 로그 저장소, 이벤트 보고기, 패턴생성기, 패턴 DB [유형] 데이터소스 기반(호스트기반-HIDS: 서버 직접설치, 감사자료 다양, 정확) 네트워크기반-NIDS: NW 세그먼트 당 하나의 탐지기만 설치, 운영서버 저하X) 침입탐지모델 기반(오용탐지: 특정 공격, 축적 지식바탕 패턴 설정) 이상탐지: 사용자 행동패턴 분석, 정상 사용패턴 비교, 인공지능 알고리즘)	오용탐지 이상탐지
166	중	IPS	[정의] 침입탐지시스템의 오판과 미탐의 문제 해결 위해 침입탐지와 사전 예방 기능을 제공하는 능동형 정보보호시스템 (주요기능) 실시간 자동 대응, 실시간 분석, 미확인 공격 탐지, 세션 기반 탐지 [구성] 시스템 구성(침입탐지 에이전트, 관리자콘솔), 운영방안(Passive monitoring, inline simulation, inline protection) [유형] HIPS(호스트기반)- 특정 서버기반, SW설치, 시큐어 OS 유사기능 서버기반 커널 조작, 서버 침입 방지 NIPS(네트워크기반)-방화벽처럼 네트워크 인라인모드 설치, 정책근거 패턴탐지 DDoS, 버퍼오버플로우 등 NW기반 공격에 빠른 대응, 사전 차단	
167	중	UTMS	[정의] 다양한 보안 솔루션 기능을 하나로 통합하여 보안 문제를 쉽고 편리하게 관리 및 해결하는 통합 보안관리 시스템 [주요기능] Firewall(보안정책 스케줄링(Port)) VPN(IPSec, 암호알고리즘(3DES,AES,SEED)) IDS/IPS(침입탐지 시그니처) Anti-Virus, Spyware(악성코드 탐지 시그니처) Anti-Spam(MIME 값, 컨텐츠필터링)	
168	상	ESM	[정의] 방화벽, 침입 탐지 시스템, 가상 사설망 등 여러 보안 시스템에서 발생한 각종 이벤트 관리,분석,통보,대응하는 보안관리 시스템 [필요성] 단순한계, 보안시스템 의무화, 인력한계, 비용 한계 [구성] Agent, Manager, Console [필요기술] 장비(NW-NMS,Router,Switch,보안-Firewall,IDS,IPS,VPN) 정보(대상-고객정보,서비스,데몬정보,공통-보안사용자,권한제어) 분석(위험분류,정규화/규칙기반) 탐지(이상탐지,Data mining,규칙기반) 대응(능동,수동)	기술적보안
169	하	ITS (Intrusion Tolerance System)	[정의] 보안침입에 대하여 예방, 탐지, 복구를 위하여 IDS, IPS, 가상화 기술, 실시간 분석 및 라이브 패치 기술을 적용 하여 지속적인 서비스를 제공 해주는 시스템 [특징] 면역기능, 라이브 패치 기술, FTS	
170	출제예상	DLP (Data Lose Protection)	[정의] 기업 내부의 민감한 데이터, 지적재산/사업 정보 및 고객개인정보 등의 데이터 유출을 사전에 방지하기 위한 데이터 유출 방지 솔루션 [필요성] 유출사고 예방, 유출사고 실시간 차단, 감사 및 모니터링 [DLP 프로세스] 분류, 태그, 정책, 통제 [구성요소] DLP관리자(정책관리-opt in,opt-out,XML기반 , 시스템관리, 상황 워크플로우, 보고 및 대시보드) DLP 데이터 센터(민감데이터 탐색, 민감데이터 통제) DLP 네트워크(모니터링, 데이터 전송통제) DLP 엔드포인트(사용자 활동 감시, 데이터 암호화)	네트워크 보안에 NAC 도 있음
171	중	FDS (Fraud Detection System)	안전한 전자 금융 거래 위해, 이용자 정보 및 이상금융거래 사례등 종합 분석하여 의심거래를 탐지하고 차단하는 시스템 [기능] 정분대오 정보수집(이용자 정보, 거래정보, 위치정보, 이상패턴) 분석 및 탐지(실/준실시간, 이상거래 탐지, 이상금융, 악성코드, 유관기관 정보) 대응(정상 판별, 이상거래 대응) 모니터링 [탐지모델] 오페상 이동마 오용탐지 : 패턴탐지, 상태 전이모델 이상탐지 : 통계모델, 데이터마이닝 모델	오용탐지 이상탐지 동기, 비동기
172	하	End Point 보안	[정의] End Point에 연결된 IT 장치를 보안위협에 보호를 위해 네트워크 환경에 맞는 정책 및 프로세스 기반의 통합 보안관리 체계 [주요기술] NAC, UTM, SBC, 망분리, Anti-Virus, Anti-Spyware, PMS, SSL, VPN, 문서보안, WAF	
173	기업 보안 시스템 (기술적 보안)	출제예상 SOAR (Security Orchestration, Automation and Response)	다양한 사이버위협에 대응수준을 자동으로 분류하고 표준화된 업무프로세스에 따라 보안담당자와 솔루션이 유기적 협력하도록 지원하는 보안 플랫폼 [아키텍처] 소시티 SOA(workflow 관리), SIRP(siem탐지), TIP(자동분석 환경최적대응솔루션제시) [주요기술] Orchestration(연가) : 보안솔루션 연동, 가시성 Automation(자플스) : 업무자동화, 동적 플레이북, 작업 및 스크립트 Response(사리) : 사고대응 및 협업, 리포팅 [쓸수 있는 기술] DevsecOps / IPS /Intelligence APT솔루션 / SIEM [도입 기대효과] 전사적(보안 스택 ROI 향상, 대응/관리 간소화), 실무적(정형화 사고 자동대응, 유사 공격 대응력 확보) 관리자적(보고 시스템 일원화, 사고 대응 현황 파악)	

174	출제예상	DNSSEC	DNS 데이터 위, 변조 차단을 위해 공개키 암호화 방식의 전자서명 기술을 DNS 체계에 도입한 확장 보안 프로토콜 [구성요소] 공서원 공개키 (DNSKEY), 서명데이터 (RRSIG), 원본데이터 (DNS레코드, DS, NSEC/NSEC3) [문제점 및 해결방안] 유설부업 - 유지관리 : 키생성, 키교체 관리 -> 독자적 KSK 생성/관리 툴 개발 - NW설정 : 패킷 사이즈 작게 설정 -> 설정 관리 툴 개발 - 트래픽부하 : 트래픽 증가 부하 발생 -> 하드웨어 업그레이드	
175	중	MTD(Moving Target Defense)	보호 대상의 주요 속성(네트워크, 플랫폼, 실행 환경, SW, 데이터 등)을 능동적으로 변화 시켜 각종 사이버 공격을 사전에 차단 하는 능동적 보안 기술 공격을 위한 비용/복잡도를 증가시키는 방법 [MTD의 구성요소] 써디리디 - 네메 O를 인쇄 분다 1)Shuffle 네트워크 주소 랜덤화 - SDN, NAT, Virtual Gateway 적용 네트워크 주소 변경 메모리 주소 재지정 - 주기적 메모리 주소 재할당 통한 공격 대응 2)Diversity OS별 환경 구성 - 플랫폼 내 OS별 환경 구성 통한 공격 비용 증가 플랫폼 분리 - 동일 기능을 다양한 플랫폼으로 구현 하여 공격 방어 3)Redundancy 동적 Instance 구성 - 동일 Instance를 중복 생성 하여 공격 시 Instance 종료 동일 서비스 운영 - 동일 서비스 운영 통한 공격 발생 시 피해 최소화 4)Distribution 분산 저장 - 데이터 탈취 및 훼손 발생 시 복구 위한 분산 저장 다중 분산 실행 - 다중 분산 환경 내 실행을 통한 공격 대상 다양화	
176	출제예상	EDR(EndPoint Detection and Response)	[정의] 엔드포인트 레벨에서 지속적인 모니터링과 대응을 제공하는 보안솔루션 [주요기능] 예방탐대- PPD(Predict, Prevent, Detection, Response) 예방기술(기본보안태세, 위협예측, 위협평가) 방어기술(시스템 강화, 시스템 격리, 공격방지) 탐지기술(사고탐지, 사건포함, 위험확인 및 우선순위 지정) 대응기술(보안 위협 억제 및 대응, 자동화 침해사고 대응) [성공적 적용 위한 참조 요소] 3단락용 이오데프 시복스 오픈아이오씨 IODEF(사건정보 교환용XML포맷) CybOX(상태속성, 이벤트 스키마) Open IOC(XML 기반 위협 정보 표현 프레임워크) [IOC(IndicatorOf Compromise)] OS 또는 N/W 침해 확인 가능한 포렌식 아티팩트 컴퓨터 포렌식, 사고대응에 주로 사용 IDS와 같은 보안장비/솔루션에서 침해확인 용도로 사용	
177	중	XDR(eXtended Detection & Response)	[정의] 엔드포인트뿐만 아니라 네트워크, 이메일, 클라우드 등 여러 레이어를 통합하여 위협을 탐지, 대응하는 확장형 통합 솔루션 데이터 수집 범위, 대응 자동화 수준, 주요 기능, 위협 학습 방식, Zero-day-Attack 대응	모의 32회
178	중	하이브리드 전쟁 (Hybrid War)	군사적 충돌과 함께 사이버 공격, 정보전, 경제 제재, 심리전 등 비군사적 수단을 복합적으로 활용하여 상대국을 약화시키는 새로운 전쟁 방식 하이브리드 전쟁 특징 (전선의 부재, 불특정 다수, 비대칭 전력) 위협 유형(인지전, 사이버전, 경제전, 복합적 하이브리드전)	모의 32회
179	출제예상	사이버 레질리언스 (Cyber Resilience)	조직 내/외부의 예측 불가능한 위협 및 부정적 영향에 대응하는 보안전략 수립 및 리스크 해소 역량 [핵심구성요소]비보중매복 비즈니스 영향 분석(위협요인 우선순위 도출), 보안 정책 통제(문서화), 종합적 테스트(보안정책 검증), 매니저 보안 를 설치(서비스 투자), 사이버 복구 계획 * RTO, BCO, RPO *우리 이미 피해를 받았을,어떻게 연속성을 가져갈 것인지 Focus에 두고 가져갈 것 [사이버 레질리언스 확보 6단계]위사리 외내문 1) 위협 평가 역량 확보(자산재평가) > 2) 사이버 보안 방법 도입(사람, 프로세스) > 3) RISK 기반 계획(정상) > 4) 외부 위협 보호 > 5) 내부 위협 최소화(이동 미디어 제한) > 6) 보안 문화 유지(보안 SLA 지속개선) 3. 사이버 보안 및 레질리언스 비교- 수록점법 수행 대상(알려진 위협으로부터 보호된 IT 시스템/ 비즈니스 결과물(outcome) 전달 보장) 목적(안전 장치(fail-safe) - 실패에도 안전(Safe-to-fail)) 접근 방식(외부 보안, 내부 보안 구축) 범위(단일 조직 / 조직 네트워크)	
180	출제예상	CARTA 접근법	지속적이고 적용할 수 있는 리스크 및 신뢰 평가(CARTA) 접근법 (Continuous Adaptive Risk and Trust) - 2018년 가트너 10대 기술	DevSecOps
181	출제예상	SASE(Secure Access Service Edge)	SD-WAN과 네트워크 보안을 클라우드 기반으로 융합한 보안기술	2020.3 모의고사 1교시
182	출제예상	CASB(Cloud Access Security Broker)	클라우드 서비스 접속보안 브로커 종류: 에이전트형/ 프라이빗/퍼블릭/API형	APPA/아파
183	상	제로 트러스트(Zero Trust) 보안모델	(정의) 신인증 후연결, 내·외부 사용자와 프로세스를 신뢰하지 않는 원칙하에 모든 사용자와 디바이스, 어플리케이션에 대해 확인을 요구하는 보안 모델. 선 인증 후 연결, 트러스트 보안 모델 한계, 무신뢰 기반, SDP, Micro-Segmentation, 강화된 인증 식별, 디바이스, 네트워크, 응용, 데이터, 성숙도 모델, [2.0] 지속적 검증, 최소 권한, 다중 요소 인증, 접근 제어, 정책 기반 접근, PDP, PEP, 통합 보안 관리 [아키텍처 모델 구성요소] 정책연진, 정책관리자, 정책결정지점, 정책시행지점, 정책정보지점 [성숙도 수준] 기존, 초기, 향상, 최적화	122회 기출/131회 기출/135회 관리 4교시, 컴시영 3교시
184	출제예상	제로트러스트 가이드 라인 2.0	기존 보안 체계의 한계를 극복하고, 네트워크 및 IT 인프라에서 절대 신뢰하지 말고 항상 검증하라(Never Trust, Always Verify)는 원칙에 기반한 보안 아키텍처의 개념을 한층 더 구체화하고 성숙한 한 모델 제로 트러스트, 성숙도 모델(기존, 초기, 향상, 최적화), 지속적 검증, 최소 권한, 다중 요소 인증, 접근 제어, 정책 기반 접근, PDP, PEP, 통합 보안 관리 성숙도 모델 4단계, 식별자, 엔드포인트, 데이터, 네트워크, 시스템, Application, 가시성, 통합	
185	상	책임공유모델(SRM)	과립형 경계 기행 방식	

186		상	런타임 애플리케이션 자가 보호(RASP, Runtime Application Self-Protection)	[정의]실행 중인 애플리케이션과 결합되거나 해당 런타임 환경과 통합되어 애플리케이션에 대한 호출을 지속적으로 감시하여 보안을 확인하는 자가진단 소프트웨어 [키워드] RASP, 자가보호, 클라우드, WAF	
187		출제예상	다중보안체계(Multi Level Security)	정보의 중요도에 따라 데이터의 보안 수준을 분류하여 등급별 보안통제를 자동 적용 하는 보안체계	기밀(Classified-C), 민감(Sensitive-S), 공개(Open-O) 등급
188	생체인식 기술 / FIDO	상	생체인식기술	보편성, 유일성, 영구성, 획득성 단점, 분기점, 코어, 얼굴인식 알고리즘, 홍채인식 알고리즘 지점맥인증: 손가락 정맥패턴을 추출, 정맥속의 헤모글로빈이 근적외선을 흡수하는 성질이음, 인증시에 신체표면이 닿지 않음 - FAR(False Acceptance Rate): 잘못 허용될 확률. 비인가자가 인가될 확률. 보안성 이슈 - FRR(False Rejection Rate): 잘못 거절될 확률, 인가자이지만 거부될 확률. 가용성 이슈 - CER(Crossover Error Rate), EER(Equal Error Rate): 교차 오류율 FAR과 FRR이 일치하는 지점으로, 생체인식 도구의 성능을 측정하는 표준 평가 지점이며 낮을수록 정확함 얼굴: 주성분분석(PCA), FDA, ICA	
189		하	모바일 바이오인식	[정의] 모바일 환경을 기반으로 사람의 고유한 바이오 정보를 이용하여 신원 확인시, 그 사람의 ID에 해당하는 저장된 특징과 입력된 특징을 1 : 1 비교하는 기술 [장치] [바이오 보안토큰] USB, 스마트카드(개인키 및 인증서 저장, 개인 식별정보 저장) MCU(바이오정보 저장) BIO 센서(바이오정보 취득) Mobile Phone용 연결핀 [표준] ITU-T X.1085/X.bhsm (ITU-T SG17 Q.9 X.1085/X.bhsm)에서 기존 공인인증서와 바이오 보안토큰과의 프로토콜 및 인증 프레임워크를 개발중이며, ISO/IEC 17922 (ISO/IEC JTC1 SC27 17922)와 공동으로 국제표준화 진행 중임 [참고] CA: Alice 의 바이오 보안 토큰을 발급하는 인증기관(Certificate Authority) - RA: Alice 가 자신의 바이오정보를 최초 한번 공개하여 BR을 등록해야만 하는 등록기관(Register Authority) - IR: ISO 24745 국제표준에 정의된 주민등록번호, 신용카드번호 같은 개인식별정보(Identity Reference). - BR: ISO 24745 국제 표준에 정의된 지문이나 얼굴인식을 위한 템플릿 등과 같은 바이오인식 정보(Biometric Reference)	바이오(Bio) 보안 토큰, (Mobile Biometrics)
190		중	FIDO 1.0	FIDO - Fast Identification Online Alliance, 생체인증표준, FIDO 1.0의 UAF /U2F 표준 프로토콜인 UAF와 U2F 유니버선 인증 프레임워크(UAF) 총 11개 기술표준 구성요소	
191		상	FIDO 2.0	웹브라우저 확장, 플러그인 제공, Javascript, 자체 프로토콜 제공	
192		하	생체인식 Database	이미지 처리, XML 처리	
193		하	생체인식 스푸핑 공격	공격자가 생체인증 정보의 가짜 특성을 제시하여 인증 시스템을 우회하려고 시도하는 공격	
194		중	생체정보 보호 가이드라인	위조, 실재성 감지, 다중인증 [생체인식정보의 정의] 생체정보 중 특정 개인을 인증식별할 목적으로 일정한 기술적 수단을 통해 처리되는 정보 [생체인식정보의 특성] 유일성, 불변성, 민감정보 추출 가능성, 위변조 가능성 [생체인식정보의 보호원칙] 비례성, 적법성, 목적제한, 투명성, 안전성, 통제권보장 [개인정보보호 중심설계] 사후조치가 아닌 사전 예방, 초기설정부터 프라이버시 보호 조치, 프라이버시 보호를 내재한 설계, 프라이버시 보호와 사업기능의 균형, 개인정보 생애주기 전체에 대한 보호, 개인정보 처리 과정에 대한 투명성 유지, 이용자 프라이버시 존중 [생체인식정보] 1. 기획,설계, 2. 수집단계, 3. 이용제공단계, 4.보관파기단계, 5.상시점검	
195		중	IP 터널링/터널링	IP 계층의 전용망 환경에서 Point to Point 로 연결한 것과 같은 효과를 위해 , 캡슐화를 통해 두 종단 사이를 가상의 Tunnel로 형성하는 기술 예) 캡슐화(IPSec AH 터널모드 사례), 중요 : IPv4 in IPv6 터널링 IP 터널링 방식 - 역할 설정 터널링 : 기존의 IPv4 라우팅 인프라를 활용하여 IPv6 트래픽을 전송 자동 터널링 : IPv4 호환 주소를 이용하여 자동으로 터널링 해주는 방법 [캡슐화 순서] 패킷 - Passenger(애플토크, IP, IPX), - Carrier(GRE, IPSec, MPLS, STUN), - Transport(IP) [터널링 기술 활용사례] 브이포 모피나 VPN, IPv4->IPv6, 무선 통신 모빌리티, P2P 오버레이 네트워크, NAT Traversal 위한 STUN	IPSec
196		상	SSL / TLS	[정의] Presentation과 Session의 중간 계층에 존재하며, TCP/IP상 Web 데이터 암호화 프로토콜 스택 구성요소 - 핸드셰이크(4가지 Protocol) Handshake : 서버와 클라이언트 간의 상호 인증 및 암호 키 교환, MAC 방식/압축방식, 협상, 세션키 생성 Change Cipher Spec : Handshake 에서 협상된 압축, MAC, 암호화 방식 작용 사항을 수신자에게 전달 Alert : 암호, 압축, 메시지 인증 오류, 인증 실패 등 에러발생 전달 Record : 응용 데이터, 제어 메시지를 레코드 단위로 TCP계층에 전달, 기밀성, 무결성 제공 SSL Offloading : 서버대신 SSL Handshake, 데이터 암호화를 수행 OpenSSL : 암호화 알고리즘과 SSL 프로토콜을 구현하고 있는 라이브러리 집합 OpenSSL 보안 취약점 : 하트 블러드 공격 OSI 4~7계층 [운영mode] 익서상 익명모드(AN,모두 공개키 인증서 없음,보안취약), 서버인증모드(SA서버만 공개키인증서), 상호인증모드(MA,모두 공개키인증서) [보안효과] 스피변 Sniffing방지, 피싱방지, 변조방지 [보안이슈] PDFH2 POODLE 공격(SSL 3.0 보안 취약), DROWN 공격(SSL 2.0 보안취약), FREAK 공격(RSA 사용 유도 통한 무작위 키 유출 공격 취약), HEIST 공격(자바스크립트 브라우저 취약점), TLS 1.2 보안 취약점 Heartbleed 공격(OpenSSL 라이브러리 오구현 취약점) [보안이슈대응] PDFH2 POODLE 공격(SSL 3.0 사용금지), DROWN 공격(SSL 2.0 사용금지), FREAK 공격(최신 보안패치), HEIST 공격(3루키 비허용), Heartbleed 공격(최신 보안패치, SSL 인증서 재발급)	RSA방식, X.509v3, port 443, VPN활용, TLS1.0으로 통합 TLS 1.3

197	터널링/네트워크 보안	중	SSL offloading	[정의] SSL 인증서를 로드 밸런서에 배치하여 백엔드 별 인증서 배포 및 암호화/복호화 수행을 최소화하여 서비스의 성능을 향상시키는 인프라 기술 [동작방식] SSL 인증서를 로드 밸런서에 배치하여 외부 NW와의 통신보안 수행, 내부 NW는 HTTP 로 통신 [메커니즘] Public NW Layer(인증서 배치, TLS Termination) Private NW Layer(HTTP통신, 백엔드 서비스 서버)	
198		상	IPSec	[정의] IP 계층에서 다양한 보호 [제공기능] Access Control, Connectionless integrity, Data Origin Authentication, Protection against Replays, Confidentiality, Limited Traffic Flow Confidentiality [구성] 프로토콜(인증프로토콜-AH, 암호화 프로토콜-ESP), 데이터베이스(보안연계DB-SAD,보안정책DB-SPD), 키 관리 (IKE), 보안연관(SA) [보안정책] (SPD(Security Policy Database)) 패킷에 대한 보안 정책, Drop(폐기), 통과(Bypass), 적용(Apply) (SAD(Security Authentication Database)) 양단간 비밀 데이터 교환 위해 미리 설정할 보안 요소 AH,ESP에 의해 서비스 [프로토콜] AH(터널모드, 트랜스포트모드) - 메시지 인증,무결성,재생방지,해시 Transport Mode - L2 IP ESP AH L4 Payload Tunnel Mode - L2 New IP ESP AH IP L4 Payload ESP - 발신지 인증,무결성,기밀성,프라이버시,대칭형 암호화,해시 IP Header ESP Header The Rest of Payload ESP Trailer Auth Data Authenticated Encrypted [작동모드] (트랜스포트 모드) P2P, Transport layer에만 보안 서비스 제공, host에 적용 (터널 모드) 전체 IP 패킷에 보안 서비스 제공, host와 secure gateway에 적용	IPv6(의무적), IPv4(선택적) SPD(보안연계DB) SAD(보안정책DB) 인증 프로토콜(AH) : RFC 2406 암호화 프로토콜(ESP) : RFC 2402
199		중	전송 계층 보안(TLS)	[정의] SSL을 IETF에서 표준화한 프로토콜 (TLS/SSL 기능) 압축(Huffman코딩), 변조방지(HMAC-MD5, HMAC-SHA-1), 인증서(공개키 암호화), 비밀키(RSA,Diffie-Helman) [암호화기법] 키교환, 인증, 대칭키, 해시형수	DTLS(Datagram Transport Layer Security)
200			DTLS(Datagram Transmission Layer Security)	[정의] 데이터그램 형식의 콘텐츠를 어플리케이션간에 통신시에 안전하게 전송할 수 있도록 고안된 통신 프로토콜 [특징] - TLS 기능을 UDP 계층 위에 그대로 구현한 암호화 프로토콜 - UDP의 장점인 성능을 암호화 핸드셰이크 과정에서도 극대화 가능 - 암호화 알고리즘과 헤더구조는 TLS와 동일, TCP 대신 UDP 사용, 빠른 암호화 보장 [표준] RFC 6347 [DTLS Handshake 절차] [1] Client Hello [2] Hello Verify Request [3] Client Hello [4] Server Hello [5] Certificate [6] Server Key Exchange [7] Certificate Request [8] Server Hello Done [9] Certificate [10] Client Key Exchange [11] Certificate Verify [12] Change Cipher Spec [13] Finished [14] Change Cipher Spec [15] Finished	
201	망분리	상	논리적 망분리	서버가상화, PC 가상화	
202		중	물리적 망분리	복수PC, 네트워크 전환장치	
203		중	망구성도	보안설비	
204	기업 접근 관리 보안	하	SSO	[정의] 한번의 시스템 인증으로 여러 정보시스템에 재인증 절차 없이 접근하는 통합 로그인 솔루션 [모델] Delegation(서버기반,인증대행), Propagation(사용자기반,인증정보전달)	
205		하	EAM	SSO(인증)+PMI(권한 관리)+자원/보안 정책관리	
206		중	IAM	[정의] 조직이 필요로하는 보안 정책 수립하고, 정책에 따라 자동으로 사용자 계정과 권한을 관리하는 솔루션 [주요기능] 연합서비스, 인증(SSO,생체), 접근제어, 프로비저닝, 디렉토리서비스, 감사 [FIM으로 발전] Federated Identity Mgmt = RBAC+SSO+디렉토리 저장소통합+포괄적 logging/audit	인증,권한,관리,프로비저닝 인권관프 EAM+Provisioning 거버넌스&감사
207		하	커버로스(Kerberos)	[정의] 비밀키 방식에 의한 인증 시스템으로 서비스 요구를 인증하기 위한 티켓 기반 네트워크 인증 프로토콜 [특징] 인증방식(3단계 인증절차), 암호화(DES, 기밀성, 무결성 보장) [구성요소] 커버로스 서버(인증서버), TGS(ticket granting server,인증값을 티켓 클라이언트에 게 발급), 사용자client, 접속하려는 서버, 티켓(접속허가 원하는 서버ID, 클라이언트ID/NW주소, 티켓 유효기간, 공유세션키)	
208		하	PMI (Privilege Management Infrastructure)	[정의] 기업/기관 단위로 사용자에게 특정 시스템 및 어플리케이션 접근 권한 자동 부여하는 관리 체계 [특징] 속성별 권한 인증, 확장성 [구성] AC(Attribute Cert.인증서), SOA(인증발급개체), AA(권한위임개체), Privilege Holder(권한 소유자), Privilege Verifier(권한입증자) [모델] ITU-T X.509표준 일반,제어,위임,역학	PKI(인증)이 사용자권한체계 보위 ITU-T X.509 v4 / IETF RFC 3281

209	인증 (Authentication)	중	Oauth / Oauth 2.0	[정의] 제 3의 앱이 자원의 소유자인 서비스 이용자 대신하여 서비스를 요청할 수 있도록 자원 접근 권한을 위임하는 OpenAPI 기반 보안 인증 기술 [특징] 비밀번호 불필요, 제한된 권한, 클라이언트 관리, 표준(RFC 6749,6750)/인증,권한부여 동시 수행 접근토큰, 재발급 토큰 이용 보안성 강화 [인증절차] 권한요청-권한승인-AccessToken요청-AccessToken발급(토큰유효기간 만료시 refresh token추가발급)-보호된자원요청-요청서비스 제공 [구성요소] Client(3rd App),Resource Owner(사용자),Authorization Server(인증서버,접근권한 위임관리), Resource Server(API서버), Access Token(자원접근제한,만료시간) [OAuth1.0 vs. OAuth2.0] 역할(이용자-자원소유자,소비자-클라이언트,서비스제공자-자원서버, 권한서버) API호출인증 및 보안(서명-Http기본,자원서버가 요청하는 경우 서명 사용), 클라이언트 지원 유형(웹 어플리케이션, 웹,이용자 에이전트,네이티브 어플리케이션) OAuth1.0의 알려진 보안문제 개선버전으로 하위호환성 미제공 [4가지 권한승인 유형] 권한코드승인, 암묵적승인,자원소유자 비밀번호 자격증명 승인, 클라이언트 자격증명 승인 [주요기술] Nonce,Timestamp, Replay Attack방지, Signing: HMAC-SHA1, RSA-SHA1데이터	RFC6749, RFC6750 Oauth 탈취 시 블록체인 기반으로 한다. (확인해보기)
		중	OTP (One Time Password)	1회용비밀번호 [비동기방식] Challenge-reponse [동기방식] 시간동기화(임의난수대신-시간값 입력), 이벤트동기화(서버-토큰의 동일카운터값), 시간-이벤트조합(시간,카운터모두이용) [비밀키 유출 대응방안] 2Factor인증(지식,소유,생체,특성+), 2Channel인증(서비스,인증채널분리), 스마트 OTP(IC칩 탑재 스마트카드를 NFC 탑재 휴대폰에 태깅)	
		하	OTC	One Time Card: 국내 규격으로 1분 30초마다 바뀌는 토큰보안방식으로 결제때마다 카드번호 바뀔 삼성페이는 고정토큰방식 도입	
		중	스마트 OTP	NFC 휴대폰 _ 모바일 앱 -> OTP 생성/입력	
		하	Challenge-response 방식	시도-응답(Challenge-response) 인증 기법 일회성 인증 추가	
214		하	i-PIN 1.0, 2.0	i-PIN(Internet Personal Identification Number)	
215		하	보안위협관리(SRM)	[정의] 조직의 자산을 보호하기 위하여 자산에 대한 보안 상의 위험 분석을 통하여 비용 효과적이고 적절한 보호 대책을 수립하여 이를 수행하는 관리 프로세스의 총칭 [보안위협 통제유형] 관리적 통제, 물리적 통제, 기술적 통제 [분석기법] 정성적 접근방법, 정량적 접근방법 [관리절차] 위험관리 계획수립, 위험식별, 위험분석(PI), 위험 대응계획수립, 위험 감시와 통제	
216		하	정성적 위험 분석	2019년 감리사 105번 풀이 델파이, 시나리오, 순위결정법	
217		하	정량적 위험 분석	2018년 감리사 109번 풀이 단일 예상손실액, 연간 예상 손실액 정리	
218		하	ISO/IEC 13335	2016년 감리사 107 문제 정리 models fundamental to a basic understanding of ICT security, and addresses the general management	
219		중	디지털ID	[정의] 각종 ID와 주민번호, 전자우편주소, 신용카드번호, 주소 등 사이버 스페이스 상에서 개인을 식별할 수 있는 속성들의 집합 [관리기술 유형] 개방형 모델, 중앙집중형 모델, 연계형 모델, 분산형 모델	
220		중	GADI (Global Architecture for Digital Identity)	[정의] Service Provider가 어떠한 Digital Address Provider(디지털 주소 공급자)를 이용하더라도 User의 신원을 신뢰할 수 있도록 보장하는 글로벌 신뢰 플랫폼 [특징] 신원 연속성, 신원 연결성, 신원 접근성 [구성요소] Digital Address, DAP, Issuers, Service Providers [주요기능] 사용자경험, 완성도, 예코시스템 [주요기술] 블록체인, DID, 영지식증명, 신뢰기반 프레임워크, 이기종 플랫폼 호환성, 확장가능한 포용성	
221		상	디바이스(Device) DNA	[개념] 디바이스의 하드웨어적/행동적 특징을 자동화된 장치로 추출·저장하여 정확하고 편리하게 디바이스 신원을 확인하는 기술 [고려요소] 보편성, 유일성, 영구성, 측정성, 성능성, 우회성	
222		출제예상	영지식 증명(Zero-Knowledge Proof)	영지식 증명(Zero-Knowledge Proof)의 정의 - 어떤 내용을 알고 있을 경우 그 내용을 직접적으로 보여 주지 않으면서 알고 있음을 증명하는 방법	
223		중	무자각 지속 인증	무자각 지속 인증(Implicit Continuous Authentication) - 사용자의 편의향상을 위해 바이오, 행동, 환경, 관계정보 등을 기반으로 사용자의 무자각 인증정보를 활용. 이기종 호환 통해 인증. 암시된, 내포된	120회 기술
224			SDP(Software Defined Perimeter)	선인증, 후연결, 신원중심, SDP Controller, SDP Agent, SDP Gateway	
225	컨텐츠 보안	상	컨텐츠 보안	[컨텐츠보호기술] 암호화, 접근제어(ACL), 수신제한(CAS), CDR, DRM, 전자지문, 워터마크, 핑거프린팅 [컨텐츠관리기술] DOI, INDECS, CCL(Creative Commons License), DPI(Deep Packet Inspection) [컨텐츠배포보안] PKI, CDN, SW Streaming	
226		중	데이터 마스킹	[정의] 기밀 데이터의 길이, 유형, 형식과 같은 속성을 유지한 채, 새롭고 읽기 쉬운 데이터를 익명으로 생성하는 기술 [정보통신망법 마스킹 가이드] 9조 (개인정보 표시 제한 보호조치) [유형] 정적인 데이터 마스킹(복사시 다른값으로 치환, ETL단계) 동적인 데이터 마스킹(조회시 변경 또는 치환) [기술] 치환 서플, 숫자와 낱파 변경, 암호화, 널처리나 삭제	치환, 서플, 숫자/낱파변경, 암호화, NULL, 삭제
227		하	스테가노그래피	[정의] Anti-Forensic 기법 중 하나로 디지털 매체(이미지 파일, MP3, WAV 등) 에 정보를 암호화 하여 메시지가 전송되고 있다는 사실을 숨겨 전송하는 심층 암호 기술 [기술유형] 이미지 삽입, 공간적 변환, 주파수 변환 ※ Slack Space 파일시스템 파일 저장 시 여러 클러스터들로 나누어 저장할 때 마지막 클러스터의 뒷부분에 남겨지는 공간이 공간에 데이터 은폐, 은닉	이미지 삽입, 공간적 변환, 주파수 변환
228		중	Water Marking	[정의] 디지털 콘텐츠에 저작권 관련 정보를 넣어 인증기능을 부여함으로써 불법 복제 및 배포를 방지하고 제작자의 저작권과 관련된 권리를 주장 할 수 있게 하는 기술 [필요기술]생성(워터마크 유무,저작권 소유자, 콘텐츠 내용, 키문자열,유사잡음) 삽입(같은 용량의 watermarked 데이터 제작, 공간/주파수 영역 방식) 추출(원본/watermark 분리, 블라인드/non블라인드)	[유형] 기술(디지털 워터마킹, 스테가노그래피) (메시지 은닉 전송), 핑거프린팅), 강도(강성-외부공격에 유지, 연성-외부공격에 깨져서 침입 여부 판단), 인지여부(가시적)
229		중	Finger Printing	[정의] 저작권이나 판매자의 정보가 아닌 디지털 콘텐츠의 사용자 정보를 삽입함으로써 사후에 발생할 수 있는 콘텐츠의 불법 복제를 추적 가능한 기술 (특징) 유일성, 역추적성, 공모위험 [기술] 대칭형(초기모델, 판매자 구매자 모두 접근가능, 책임소재 불분명) 비대칭형(구매자만 콘텐츠 접근)	
230		하	DOI	[정의] 디지털 저작물에 특정한 번호를 부여하여 저작권 보호 및 정확한 위치 추적이 가능한 시스템 (특징) 인식성(고유번호), 변화용이성(URL로 변화), 응용성(ISBN수용), 운용성(메타데이터 등과 상호 운용), 관리표기(식별, 분별, 소유권 이전), 영구식별 [구조] URL, Link, DOI 등록기관, DOI 등록자, ISBN번호, ISBN식별코드, 일련번호, 등록자ID - 10.1000 / issn.0028-0836	

231	하	INDECS	[정의] 저작권 관련 정보, 저작권 거래 내역관리 정보, 저작자의 권리 정보 기술을 위한 전자상거래 시스템에서 상호 운용 가능한 메타데이터 프레임워크 [원칙] 고유한 식별, 기능적 세분화, 지정된 권리, 적절한 접근 [구성요소] Entity(W3C, 일반적,상업적,지적재산권,특수 view) Parties(상거래 모델 정의, 정보처리운영 메타데이터) Creation(실현물, 아이템, 표현물, 추상물 구분) Relation(엔터티간 관계 표현, event, situation, attribute로 구성)	
232	상	DRM	[정의] 디지털 콘텐츠의 생성에서 이용까지 유통 전 과정에 걸쳐 디지털 콘텐츠를 안전하게 관리/보호하고, 부여된 권한정보에 따라 디지털 콘텐츠의 이용을 제어/통제하는 기술 [특징] 투명성, 사용성, 유통성 [기술요소] 패키징(패키징 구조, 파일 포맷 설계, 복합 패키징, 암호화) 권리 표현기술(권리 데이터 사전, XML기반, 다이나믹 사용규칙, 저작권 관계) 워터마킹/핑거프린팅 기술(공격, 평가 기술) 복제방지기술(디바이스 인증, 비밀키 교환, 디바이스 폐기/회복, 암호화) 식별 체계(식별자 구분구조, 변화, 메타데이터 관리) 도메인 간 상호연동(DRM간 상호 인증, DRM adaptation, 웨측DRM패키)	
233	하	CAS	Conditional Access System	IPTV, DRM
234	출제예상	전자지문	전자지문은 전자문서로부터 뿔아낸 고유한 Hash 코드로, Hash 코드를 이용하여 전자문서의 위변조 및 비밀원본증명을 위해 사용되는 기술. 위변조검사. 전자지문, Hash값, 위변조 확인, 비밀원본증명 서비스	제3기관에 보관
235	출제예상	CDR(Content Disarm & Reconstruction)	콘텐츠 분석하고 분해하여 위협요소 제거후 안전한 요소만으로 문서파일을 재구성	121회 기출
236	하	PIT (Privacy Invading Technology)	[불법 수집형] spyware, XSS/SQL injection [공격/파괴형] 스니핑/스무핑(NW 패킷 가로챌 변조), 해킹/바이러스 [사회공학] 스매/플래밍, 피싱/파밍	
237	상	개인정보 비식별 조치 가이드라인	[정의] 빅데이터 활용에 필요한 비식별 조치 기준·절차·방법 등을 구체적으로 안내하여 안전한 빅데이터 활용기반 마련과 개인정보 보호 강화를 도모 일반적 기법: 개인식별요소 삭제 방법, 가명,통계,삭제,범주,마스킹 프라이버시 보호 모델: 재식별 가능성 검토 기법: k-익명성,t-다양성,t-근접성 [단계별 조치사항] (1단계) 사전검토(개인정보-식별정보) -(2단계) 비식별조치 (개인식별 요소 제거)- (3단계) 비 식별 적정성 평가(k-익명성)-(4단계) 사후관리(비식별정보)	
238	상	개인정보 보호기술 PET (Privacy Enhancing Technology)	[정책 협상기술] P3P(W3C 제정 개인정보보호 정책 표준규격) [암호 기술] DES/RSA/ECC, SSL/VPN [필터링 기술] 방화벽/IDS/IPS/NAC, 안티바이러스/캡처방지, 피싱 모니터링 [익명화 기술] Mix-net(클라이언스 서버 익명성 제공), ISO25237, ISO20889 [인증 기술] PKI, i-PIN, SSO, Open ID	
239	상	개인정보 가명 익명화	가명처리 (성명, 출신학교, 근무처 등 고유 특징) 총계처리 (개인적 날짜 정보-생일,자격취득일, 수입지출, 신체정보, 진료기록) 데이터값 삭제 (이름,주민번호, 주소, 생년월일, 생체정보, 이용자 계정) 범주화 (주소, 생년월일, 고유식별정보, 계정) 데이터 마스킹 (개인식별 번호, 고유 식별번호, 이용자 계정) ----- 가명처리 (유리стик 익명화, 암호화, 교환방법) 총계처리 (총계처리, 부분집계, 라운딩, 재배열) 데이터값 삭제 (속성값 삭제, 속성값 부분 삭제, 레코드 삭제, 식별요소 제거) 범주화 (감추기, 랜덤 라운딩, 범위 방법, 제어 라운딩) 데이터 마스킹 (원의 값을 추가, 공백과 대체)	비식별화 ISO/IEC 20889
240	상	프라이버시 보호모델	[정의] 비식별화된 데이터로부터 개인을 재식별하는 공격이 성행하고 있으므로 이에 대한 대비가 필요 k-익명성 [정의] 주어진 데이터 집합에서 준식별자 속성값들이 동일한 레코드가 적어도 k개 존재하 도록 하는 연결공격(Linkage Attack) 방어형 프라이버시 보호모델 구현방법: 데이터 집합의 일부를 수정하여 모든 레코드가 자기 자신과 동일한(구별되지 않는) k-1개 이상의 레코드를 소유 ----- L-다양성(diversity) [정의] 주어진 데이터 집합에서 함께 익명화되는 레코드들(동질집합)은 적어도 l개의 서 로 다른 민감정보를 가져야 한다는 프라이버시 보호모델 구현방법: 데이터 집합의 일부를 수정하여 모든 레코드가 자기 자신과 동일한(구별되지 않는) l개 이상의 레코드를 소유 ----- T-근접성 [정의] 동질집합에서 민감정보의 분포와 전체 데이터 집합에서 민감정보의 분포가 유사한 차이를 보이게 하는 프라이버시 보호모델 l-다양성이 쓸림공격 및 유사성 공격에 취약한 부분을 보완 구현방법:전체 데이터 분포와 유사하도록 동질집합 데이터 분포를 구성	M유일성
241	하	PPDM	[정의] 데이터 마이닝이 분석분야에 주로 활용되면서, 개인프라이버시 침해 이외에도 수집한 정보의 누출이 문제시됨. 이를 해결하고자 프라이버시 보존형 데이터 마이닝(PPDM)에 대한 기법이 등장 [기법] 보존형 데이터 마이닝(원본 데이터에 노이즈나 랜덤화 적용해 은닉화 분석) Secure Multi-parity Computation(SMC)(입력과 계산 결과 이외엔 어떠한 정보도 얻을수 없는 기법) [상세기법] 시계열데이터 교란기법(PCA 베이스 추정, 노이즈 평준화, 영역기반 교란기법) 압축기반 교란기법(DFT(이산푸리에 변환) 기법, DWT(이산웨이블릿변환) 기법, SVD(특이값 분해) 기법) 기하학적 교란기법(회전교란기법, 다중회전기법, 융속교란기법) K-익명화 분산프라이버시보호기법(안전한 스칼라 곱과 안전한 유클리디안 거리, 프라이버시 보호 질의, 프라이버시 보호 집계)	
242	하	PPDP	[정의] 데이터를 공개하지 않고 사용자가 요청한 질의를 처리해서, 질의 결과에 개인 프라이버시가 누출되지 않도록 감시 및 관리 방법(기법) [주요기술] 관계형 데이터 프라이버시 모델(K-익명성) 속성 노출을 막기위한 프라이버시 모델(L-다양성) 귀속 노출을 막기위한 프라이버시 모델(존재성 모델) 확률 공격을 막기위한 프라이버시 모델(유주 확률을 증가시키려는 공격)	관속귀화 KL준유

243	개인정보 보호 기술 (PET)	이	PIA	[정의] 개인정보를 활용하는 새로운 정보시스템의 도입이나 개인정보 취급이 수반되는 기존 정보 시스템의 중대한 변경 시 등 시스템의 구축, 운영, 변경 등이 개인 프라이버시에 미치는 영향에 대하여 사전에 조사, 예측, 검토하여 개선 방안을 도출하는 체계적인 절차 [근거] 개인정보보호법 제 33조, 개인정보보호법 시행령 제 35호 [조건] 5만명이상(민감정보, 고유식별정보) 50만명이상(연계 결과 정보 주체의 수) 100만명이상(정보주체 수) 변경 시 [절차] 사전준비단계(사업계획 작성, 사업자 선정) 수행단계(평가수행계획수립, 평가자료수집, 개인정보흐름분석, 개인정보침해요인분석, 개선계획수립, 영향평가서 작성) 이행단계(개선계획 반영/점검, 개선사항 이행확인) [수행체계] [결과제출] 공공기관 -> 행정안전부 [기관지정] 행정안전부 -> 영향평가 수행(평가기관) [평가의뢰] 공공기관 -> 영향평가 수행(평가기관) [3단락] 개인정보보호법 제 33조 -> 개인정보 영향평가 -> ISO/IEC 29134 표준화	
244		이	PbD(Privacy by Design)	(정의) - 프라이버시에 대한 위협을 예측/예방하기 위해 서비스 설계, 기획 단계에 보안요소를 적용하여 이용자 프라이버시 통제권이 보호되면서 서비스/시스템의 편리성을 해치지 않도록 설계하는 기법 기본원칙 1. 사후조치가 아닌 사전예방 2. 초기설정부터 프라이버시 보호 조치 3. 프라이버시 보호를 내재한 설계 4. 프라이버시보호와 사업기능의 균형 5. 개인정보 생애주기 전체에 대한 보호 6. 개인정보 처리과정에 대한 가시성 및 투명성 유지 7. 이용자 프라이버시 존중	
245		출제예상	CCTV 개인정보보호	[정의] 불특정 다수를 자동으로 촬영하는 CCTV의 특성으로 인해 개인정보 오남용, 불법 유통, 사생활 침해등의 피해 증가로 개인영상정보 보호 기술 CCTV (개인정보) 활용 증가 지능적확대 개인정보보호 필요성	
246		하	P3P, 추적금지 기타	[정의] 특정한 웹사이트의 개인정보 보호 정책을 접속 사용자에게 알려줌으로써 자신에 관한 정보를 제공할 지 여부를 서비스하는 개인정보 보호 기술 - 릴레이선 R에 대해 X, Y, Z라는 속성(Attribute)의 집합이 주어졌을 경우 여러 가지 함수종속의 성질을 유도해 낼 수 있는 추론 규칙	(Do Not Track, DNT) 기능
247		하	개인정보의 기술적, 관리적 보호조치 기준	2019년 김라사 109번 문제를 참조하여, 자료 정리와 풀이 해 오기	
248		출제예상	가명정보 결합 및 반출방법	사전준비 및 결합신청 -> 결합 수행 (모의결합, 결합을 확인, 가명정보 추출)-> 추가처리 및 반출 -> 활용 및 사후처리	121회 기출
249		출제예상	가명처리 가이드라인	[정의] 개인정보 일부를 삭제하거나 일부 또는 전부를 대체하는 등의 방법으로 추가 정보가 없는 특정 개인을 알아볼 수 없도록 처리하는 것 [법령] 개인정보 보호법 제 28조의 2, 개인정보 보호법 제28조의 3 [가명처리 절차] 사전준비, 가명처리, 적정성 검토 및 추가처리, 사후관리 [가명정보 결합 및 반출 절차] 사전준비 및 결합신청, 결합 수행, 추가처리 및 반출, 활용 및 사후관리 [가명정보 관리 보호조치] - 관리적 (내부 관리계획 수립, 수탁자 관리/감독 의무, 개인정보 처리방침 수립 및 공개) - 기술적 (추가정보의 분리 보관, 접근권한의 분리, 가명정보 처리 기록 작성/보관) - 물리적 (출입 통제, 보조저장매체에 대한 반출입 통제 대책) - 정보주체 권리보장 (주체가 가명처리 정지 요구시 이를 보장)	
250		출제예상	ISO/IEC 29100 프라이버시 11원칙	[정의] ICT 시스템에서 처리되는 개인 식별 정보를 안전하게 보호하기 위한 High Level Privacy Framework에 대한 국제 표준 [프라이버시 원칙] 동의와 선택, 합법성 및 사용목적, 수진 제한, 데이터 최소화, 사용 및 공개 제한, 정확성과 품질, 개방성/투명성, 개인 참여와 접근, 책임, 정보 보호, 개인정보 보호규정	
251		출제예상	ISO/IEC 27701 개인정보 보호 시스템	[정의] 개인정보 보호를 위한 ISO/IEC 27001 및 ISO/IEC 27002의 확장판으로, 조직이 개인정보보호를 위해 갖추어야 하는 요구사항과 가이드라인을 동시에 제공하는 표준 [인증절차] 표준의 적합성 판단, 문서 및 소프트웨어 등에 대한 검토, 주관팀의 구성 및 전략 수립, 필요한 교육의 결정, 문서 개발, 프로세스의 결정, 관리 및 문서화, 실행, 사전 예비 심사의 검토, 인증획득	
252		출제예상	개인정보의 안전성 확보조치 기준' 고시	개인정보의 안전성 확보조치 기준' 고시 가. 내부관리계획 수립 이행 나. 암호화 적용방안	
253		중	개인정보 안심구역	[정의] 유연한 개인-가명정보 활용, 개인정보 보호-활용기술 실증 등을 위해 개인정보위가 전문심의를 지원하고, 개인정보 처리에 필요한 안전한 이용환경을 지원하는 제도 [주요기능] 안전한 환경 제공, 개인정보 유연한 활용, PET 실증 지원, [절차] 이용 신청, 심의 요청, 이용 심의, 개인정보 안심구역 이용, 반출 심사, 이용결과 관리	135회 관리 1교시 / 데이터 안심 구역(136회 정리)
254			데이터 안심구역	[정의] 공공 및 민간 데이터를 안전하게 분석·활용할 수 있도록 고성능 분석 인프라와 보안 환경을 갖춘 공간. 데이터 산업 활성화와 AI 기반 서비스 개발 등을 지원하며, 데이터기본법에 따라 운영하는 제도	
255		하	ISO 25237	[정의] 개인 의료정보 개인정보보호를 위한 비식별화(pseudonymization) 서비스의 원칙과 요구사항을 포함하는 ISO국제표준 [데이터 익명화 기법] 가명처리 (휴리스틱 익명화, 암호화, 교환방법) 총계처리 (총계처리, 부분집계, 라운딩, 재배열) 데이터값 삭제 (속성값 삭제, 속성값 부분 삭제, 레코드 삭제, 식별요소 제거) 범주화 (감추기, 랜덤 라운딩, 범위 방법, 제어 라운딩) 데이터 마스킹 (임의 값을 추가, 공백과 대체) [익명성을 위한 통계적 보호기술] K-익명성, L-다양성, T-근접성, 자분 프라이버시	의료정보 데이터 익명화 기법. 가명처리. 총계처리, 평균값대체 범주화, 데이터 마스킹
256	의료정보	상	Pseudonymization	[정의] 정보주체를 식별할 수 있는 식별자 대신에 새로운 인식기호를 붙이는 기법 [알고리즘] 시계열 데이터 마이닝 (k-익명화), 부분그래프 익명화, 차수 익명화, 부분 그래프+ 차수 익명화, 매크로 기법- 셀 값 감추기 방법 (suppression), 휴리스틱 익명화 (heuristic anonymization) [해의관점] 유럽연합(GDPR), 미국(HIPAA), 영국(개인 식별할 수 없도록 익명화 완전하게 하는가에 초점)	가명처리
257		출제예상	범주화	[정의] 데이터 값을 범주의 값으로 변환하여 명확한 값을 감추는 기법 (개념)특정 정보를 해당 그룹의 대표값으로 변환(범주화)하거나 구간 값으로 변환(범주화)하여 개인 식별을 방지 (대상)개인을 식별할 수 있는 저보(주소, 생일, 고유식별정보 등) 기관, 단체등의 이용자 계정(계좌번호 등) (장점)통계형 데이터 형식이므로 다양한 분석 및 가공 가능 (단점)정확한 분석결과 도출이 어려우며, 데이터 범위 구간이 좁혀질 경우 추론 가능성 있음. [세부기술] 범주화, 랜덤 율리 방식, 범위 방법, 제어 율리	예) 홍길동, 35세 → 홍씨, 30-40세

258	보안 역할/직업	중	정보보안 부서의 신설 과 정보보안 체계	보안팀 만드는 과정 및 체계 수립 기술 가. 정보보호 정책의 개념 나. 정보보호 시정별 보안 활동(Security Action Cycle) 다. 정보보안 전문가의 역할과 역량	132회 기술문제
259		하	CPO (Chief Privacy Officer)	[정의] 조직에서 수집 및 이용되는 개인정보보호를 위하여 개인정보보호 계획, 실행, 감독 및 유출사고 방지를 수행하는 총괄 책임자 [역할] 개인정보보호 계획 수립 및 시행, 개인정보 처리실태 관리감독, 개인정보 유출 예방 및 침해사고 대응 [역할] 관리적 보안(내부관리 체계 수립, 보안감사, 보안교육) 기술적 보안(보호 시스템 구축, 개인정보파일 관리, 개인정보 파기) 사고 대응(거버넌스 활동) [권한과 의무사항] 권한(관리, 감독, 업무 수행-불이익 받지 않음) 의무(개선조치-법령 위반시 즉시 개선 시정 조치, 보고 - 필요시 기관장에 보고)	
260		하	CSO (Chief Security Officer)	[정의] 기업에서 내부 정보 보안을 위한 대책을 책임지고 기술적 대책과 법률적 대응까지 총괄 책임을 지는 최고 임원 [체계] 데이터보안 책임자(DSO: Data Security Officer) 정보시스템 보안책임자(ISSO: Information System Security Officer) 보안 책임자(SECOFF: Security Officer) 시스템 보안 책임자(SSO: System Security Officer) [역할] 대사, 협상자, 변화대리인, 문제해결자, 집행자	
261		하	CISO 지정신고 의무화	CISO의 직무, CISO의 지정·신고 의무대상자, CISO의 겸직 제한 대상, CISO의 일반 자격요건	121회 기술
262	사이버 공격 및 대응	중	사이버 킬 체인 (Cyber Kill Chain)	[정의] 사이버 공격을 프로세스 기반으로 분석하여 각 단계에서 가해지는 위협 요소를 파악하고 공격활동 완화를 위한 방법을 7단계로 정의한 사이버 공격 분석 모델 [사상] 공격이 최선의 방어, ATP 공격 설명시 주로 사용 [사이버킬 체인 수행절차-7단계] 정찰-무기화-전달-익스플로잇-설치-C&C-행동개시 [정보보호대책] 탐지-자단-방해-완화-속임-파괴 [한계점] 방화벽을 핵심 방어 수단으로 가정 [대안] 끊임없는 방화벽 내부 강화, TTP 대응	
263		출제예상	위협헌팅(Threat Hunt)	[정의] 사이버 공격의 흔적(아티팩트)를 발견하고 공격주체를 추적하여 조직 내에 식별 및 비식별 된 보안위협을 탐지 하고 대응하는 기술 및 기능을 의미 [특징] 잠재적 보안위협 식별, 적극적인 방어활동 [구성요소] 보안조직(분석전문인력), 헌팅도구(맞춤형 솔루션), 프로세스(위협헌팅 방법론) *위협헌팅방법론 : Cyber kill chain, ATT&CK Lyfecycle, Threat Intelligence기반 분석	
264		중	ATT&CK(Adversarial Tactics, Techniques & Common Knowledge) Matrix	[개념] MITRE에서 제공하는 보안 프레임워크로서 실제 사이버공격에 대한 데이터를 기반으로 적대적인 전술 및 기술에 대한 정보를 쉽게 알아볼 수 있도록 만든 보안 매트릭스 [구성요소] Tactics, Techniques, Matrix [버전] ATT&CK Matrix for Enterprise, ATT&CK Matrix for Mobile, ATT&CK Matrix for ICS	
265		출제예상	사이버전(Cyber Warfa	[정의] 컴퓨터 네트워크를 통해 디지털화된 정보가 유통되는 가상적인 공간에서 다양한 사이버 공격 수단을 사용하여 적의 정보 체계를 교란, 거부, 통제, 파괴하는 등의 공격과 이를 방어하는 활동 [주요 사상] 국외(에스토니아 vs 러시아, 그루지야 vs 러시아) 국내(DDoS 청와대공격, DDoS 한국 주요 웹사이트, 북한에 의한 GPS 교란) [사이버전 대비 중요성] 과거(재래전)-대량살상전, 공중전, 해전 변화방향(정보우위, 물리->전쟁전략, 물리영역->사이버 공간) 현재(현재전)-보이지 않는 전쟁, 사이버 정보,테러,심리,물리적 연계전 [개념] 시스템/통신망 교란,마비, 지휘체계 C4I 교란,마비 아군 사이버체계 보호, 첩보/정보 획득	
266		출제예상	사이버보안 조직	사이버보안 조직의 역할 및 책임사항	
267		중	취약점(Vulnerability)	취약점(Vulnerability) 빈틈, 대상을 보호하는 것이 가장 흠	
268		중	위협(Threat)	위협(Threat) 보호 해야 할 대상을 훼손하거나 흠쳐갈 잠재적인 요인	
269		중	DB 보안 취약점 및 대 응기술	[정의] 데이터베이스 내에 저장된 조직의 주요기밀 정보를 비인가된 변경, 파괴, 노출 및 비밀관성 등을 발생시키는 사건이나 위협들로부터의 보호 [보안특성] 인증(Authentication), 기밀성(Confidentiality), 무결성(Integrity), 가용성(Availability) [보안위협요소] 불법 접근, 데이터 노출(Disclosure), 부적절한 변경(Modification), 서비스 거부(DoS) [보안요구사항] [보안요구사항] 정당한 사용자의 데이터 접근 보장, 추론 방지, 데이터 무결성, 데이터 의미 무결성 (Semantic Integrity) 유지, 시스템 감사 지원, 사용자 인증, 기밀 데이터 관리와 보호, 다단계 보호(Multilevel Protection) [보안구현방안] 접근제어(Access Control), 허가 규칙(Authorization Rules), 가상 테이블(Views), 암호화 [DB보안 프로세스] 취약점 평가(모의해킹, 보안진단), 우선순위 선정(위험점수 평가법), 취약점 교정(패치, DB보안 기 법), 위협 모니터링(DAM, Audit, Forensic) [암호화기술] API 방식, Plug-In 방식, 하이브리드 방식	접근제어, 허가규칙, 가상테이블 (View), 암호화
270		상	클라우드컴퓨팅 취약 점, 대응기술	[정의] 클라우드 컴퓨팅 서비스 각 영역에 존재하는 보안 취약점 및 대응 기술 [보안위협] 가상화 문제, 중복된 신뢰관계, 네트워크 침입, 서비스 공격, 권한 탈취, 과부하 공격, 구현오류 [서비스별 보안위협] SaaS(정보 훼손 및 유출, Web 공격, 버전 통제 문제) PaaS(Buffer Overflow, 표준화 부재, 인증 문제) IaaS(가상화 취약점, 서버관리 문제, 데이터손실 문제) [보안 취약점, 대응기술] 기술적 :기존 보안 위협 상속, 가상화를 통한 위협 기술 외적 :관리속면문제, 법제도 문제 ---- 클라우드 보안서비스 제공, SECaaS(Security-as-a-Service) 정의 - 클라우드 형태로 보안서비스를 제공하는 것으로 클라우드 인프라를 통해 전문화된 보안서비스 제공 - 고가의 장비를 구축하기 어려운 경우 전문 보안서비스를 제공하는 클라우드 서비스 (CSP SECaaS) 식별/접근관리(IAM), 데이터 손실방지(DLP), 침입관리(IM), 암호화, 네트워크보안, 업무연속성/재난복구(BCDR) [SSP SECaaS] 취약성 탐지, 웹보안, 이메일보안, 보안 및 정보 이벤트 관리, 지속적 감시, 보안접근	SECaaS CASB SASE ISO 27017 ISO 27018 검색가능 암호화 PPDM

271		상	가상화,하이퍼바이저 (Hypervisor) 취약점 및 대응기술	[가상화 환경에서 주요 보안 이슈 유형] 기존장비한계(보안 사각지대), 멀티테넌시(VM간 상호 공격 취약), VM관리(감염된 VM 이동복사) [기존보안기술 한계점] N/W보안기술 한계-보안사각지대 존재, 내부패킷 탐지불가 엔티바이러스 한계-AV스톱, VM상능저하, 파일 스캔, 시그니처 업데이트 보안사각지대 한계-Privileged level 차이, 권한부족, 악성코드 탐지불가 [대응기술] 가상머신 내부정보분석(VMI)-가상스위치 패킷캡처, VM스토리지접근, VMI기반 IDS/IPS Agentless 가상보안 Appliance - A/V스톱문제해결, 중복시그니처 복잡성 감소, out of the box 탐지 특별결한 SecaaS - tenant 별 보안기술 적용, 컴플라이언스 준수/감시, 서비스 형태보안	
272		중	모바일 취약점, 대응기술	[정의] 단말기 자체에 내재된 취약점 또는 단말기 사용 부주의로 발생하는 보안 위협 [기술적 위협] 무선 공격, 바이러스, 침투 공격, DoS 공격 (관리적 위협) 분실/도난, 다양한 접속 경로, 취약한 업데이트, 설치 시 보안점검, 사회공학위협 [관점 위협] 1)단말기: 개인정보 침해, 도청, 파싱 및 파밍,서비스 거부(Dos/DDos),권한탈취,악성코드해킹,정보유출, 2)에플리케이션: 권한탈취, 악성코드,정보유출 3)네트워크:도청, 권한탈취 4)내부시스템:서비스 거부, 정보유출 [대응방안] Contents(MDM, 모바일 엔티바이러스, Remote/local Wipe, encryption), Platform(WIDS,WIPS,Secure OS), Network(SSL-VPN,IPSec-VPN, 망분리), Terminal(E-mail Archiving, Access Control, Device Lock) [고려사항] 망분리, 상호인증, IT compliance, 내부통제강화	위협요소: 개방성, 휴대성, 저성능 보안기술: 코드난독화, 암호화, 디바이스인증, 엔티바이러스 기술, 전자서명(코드서명)
273		중	스마트그리드 취약점, 대응기술	[정의] ICT 기존 전력망 정보기술(IT)을 접목하여, 전력공급자와 소비자가 양방향으로 실시간 정보를 교환, 에너지효율을 최적화하는 차세대 전력망 [보안 위협] 제어시스템 위협(DDoS), 네트워크 위협(인터넷 취약성), 소비자 보안 위협(개인정보 노출) [보안 위협] 제어 시스템 위협-미타기 복잡, 정교한 공격, 퓌팅 등 악성코드 DDoS 공격시 대규모 정전 사태 네트워크 위협-인터넷 취약, 제어시스템으로 침투 가능 소비자보안 위협-에너지 사용 정보 노출 펌웨어 공격(펌웨어해독,암호키,정보유출), 램공격(메모리 칩 전기신호 가로챌,사용정보,요금정보), 네트워크 공격(원,악성코드 노출,위변조), 서비스 중지 공격(제한된 메모리, HAN/MDMS상위공격노출) [대응대책] 정책(법/제도-정보통신기반 보호법, 정보통신망 이용촉진 및 정보보호 사각지대 개정, 조직적-안보와 관련 전문 담당 조직 필요) 기술적(제어시스템-암호화키,SCADA보안,임베디드/송전시스템 보안,분산통합 보안,DB보안, 네트워크-유무선 통신 보안, 단말기 인증관리, 네트워크 포렌식, 통신망 보안 소비자 보안-기기, 인증, 접근제어, 프라이버시 보안관제-교육/정보 공유, 사전진단, 사물레이선) 사용자 및 기기 암호기술(DES, AES, SEED) 위변조 방지기술(해쉬, MD5, SHA 1~512) 인증 및 접근통제기술(기기인증 서비스, RBAC) 침입 탐지 대응기술(멀티패턴 매칭 알고리즘)	위협(제어시스템, 네트워크, 소비자 보안), 대응(암호화, 해쉬, 기기인증, 침입탐지)
274		중	사이버범죄의 유형 및 대응방안	[정의] 넓은 의미로는 컴퓨터 네트워크 시스템에 장애를 초래하는 물리적 또는 소프트웨어적인 일체의 불법적 행위 원/바이러스 전파속도 고속화/ 보안패치	
275		상	Big Data 보안 취약점 및 대응	[정의] 대규모 다양한 형태의 데이터 및 민감도(중요사업정보, 개인정보, 프라이버시 등)가 높은 정보를 외부 위협으로부터 보호하는 활동 [빅데이터 보안이슈] [분석목적 처리에 따른 보안이슈] 수집단계: 동의 없이 또는 정확하지 않은 개인정보수집가능 문제 전 처리단계: 사전 개인정보의 수집-이용을 한정하고 동의하는 과정의 어려움 정보처리 및 분석단계: 분석목적을 한정하고 동의 획득하는 것이 불가능 분석 결과의 활용단계: 분석과정의 공익적 활용가능성 따른 사회적 차별 발생가능 - 관리목적 처리에 따른 보안이슈 안전성확보: 복잡한 처리과정 서 잘못된 판단 및 개인정보 침해가능 데이터보관: 사생활 기록을 장기간 보관함 따른 사생활 감시 가능성 발생 열람: 어떤 경로로 프라이버시가 침해되었는지 파악하기 곤란 정정, 처리정리: 잘못된 행동-관계 등 관한 정보수정 절차 미 보장 파기: 프라이버시 보장과 관련된 정보의 파기곤란 [대응기준] ISO 27001, NIST Big Data: 데이터에 대한 접근제어 기술 적용, PCI/DSS, ISO 25237: 가명화 기술적용 [대응] 빅데이터 생명주기별 개인정보보호 기술, 개인정보, 프라이버시 침해 대한 정책적 보호	
276		상	IoT 보안 위협	[IoT 보안 정의] 사람-사람,사람-사람 간의 연결뿐만 아니라 사물-사물 간의 동적 연결을 가능하게 하는 진정한 유비쿼터스 환경 실현 기술을 위한 보안 [사물인터넷 보안 위협 요인] 가용성 침해 서버와 단말에 대한 불법 접근을 통해 침해 기밀성/무결성 공격 정보의 조작 및 탈취 프라이버시 침해 [주요기술] [센서측면] 인체센서(혈류, 뇌전도, 피부전기반사, 음성인식), 활동센서(아이트래킹, 족저압, 가속도, 자이로), 환경센서(온도/습도, 가스압력, 먼지, 자외선, 수질), 공간센서(실시간 환경 감시, 침입탐지, 재난복구) [플랫폼 측면] 플랫폼기술(M2M, USN, WOT), 단말 인터랙션 기술(USB, 블루투스, RFID, 6LowPAN), 프로토콜 기술(CoAP, MQTT, LwM2M), 네트워크 기술(WirelessHART, ISA-100.11a) [보안취약성] IoT접속(인증체계 부족, 약한 강도 비밀번호), IoT데이터(데이터 암호화 부재, 비신뢰 펌웨어 데이터), IoT통신(불완전한 네트워크, 접근통제 부재) [방어기술 - 7대 원칙] 설계운 설계초점포괄추진 설계/개발(Security by Design, 시큐어 코딩-개발기술 검증), 배포/설치/구성(Secure by default, 검증된 보안프로토콜), 운영/관리/패치(보안취약점 패치-업데이트, 관리체계 마련, Log/시그니처분석-추적)	IoT 공통 보안
277		하	사물인터넷(IoT) 보안 등급	사물 인터넷(IoT) 장치가 보안을 위해 채택한 기술적, 관리적 측면의 평가로서 단말 자체와 시스템의 보안 수준을 평가하고 이를 인증하는 국제적인 기준 ISO27001, NIST Cybersecurity Framework, Common Criteria EAL, FIPS 140-2, UL IoT Security Certification, Cyber Essentials	

278	보안 취약점 및 대응	중	무선 랜 보안	[정의] 무선 접속장치(AP)를 중심으로 일정거리 내에서 단말(PDA, 노트북)을 통해 무선으로 초고속 인터넷 등을 이용할 수 있는 통신환경 [무선랜 보안 기술] 1) 사용자 인증 - PSK: Pre-Shared Key, 사전 공유한 패스워드 입력을 통해 사용자 인증 - 인증서버: 별도의 인증서버를 통해 인증 2) 암호화 방법 - RC4: 로널드 라이베스트가 만든 스트림 암호로, 전송계층보안(TLS)이나 WEP 등의 여러 프로토콜에 사용 - TKIP: Temporal Key Integrity Protocol - CCMP - WAP3 (WPA2의 KRACK 취약점 개선 -> SAE 방식 인증 사용)	
279		중	오픈소스 취약점	[오픈소스정의] 일반적으로 자유롭게 사용, 복제, 배포, 수정할 수 있으며, 소스코드가 공개되어 있는 소프트웨어 [오픈소스 취약점/보안] 오픈소스의 접근성 이점대비 공개적 소스코드로서 취약점 빈번하게 발생 [오픈소스 중요성]경제(구매비용감소, 로열티 절감), 기술(기술격자해소,이기종간 시스템 호환성), 사회(백도어 기술유출 방지,원천기술 접근) [오픈소스 취약성 탐지방법] Fuzzing 무작위 대입, Code Auditing [대응] 취약점모니터링: - Network 망 관리 및 모니터링/- 주기에 따른 Source 전수검사 순쉬운패치 적용:- 패치 방법 상세히 기록/- 매뉴얼 작성 및 숙지 검증된 오픈 소스 도입:- 다수 사람들의 적용 여부확인/- 최신 버전의 오픈 소스 탑재/- Prototyping 및 Base Framework 필요한 솔루션에 대한 검토/선택 Secure Coding -취약점수 금지 -보안컨설팅 검수 -기존 방식 코딩 금지(새롭게 설계 및 개발) 관리적 방안 - 오픈소스SW 거버넌스 체계 도입 - SW 개발 정책수립부터 개발, 배포, 유지보수에 이르는 SDLC 전 단계에 걸쳐 OSS 사용 계획및 관리 - 단기 도입 어려움(중장기 방안) - OSS 보안 관리 방안 - OSS 사용 명세서 및 보안 취약점 관리 사용 - (단계) OSS 사용 명세서 작성 -> 자동화된 OSS 사용 확인 -> 취약점 모니터링 및 보안패치 - 단기 및 기 제작된 OSS에 적용 가능	오픈소스 취약점 사례 하트블리드, 쉘쇼크, 고스트
280		하	포스(POS) 시스템 취약점	[정의] 사업장소에서 사용하는 대금결제 시스템 [공격기법] 도청/탐핑(Tapping):케이블로 카드정보 유출 스니핑:스키밍(Skimming), 키로깅, 메모리 해킹 변조: 애플리케이션 위변조 [대응방안] 관리적/ 물리적:통신회선보호, 기기보호/ 기술적 대응 : 보안 모듈, POS 기 임베디드 OS 버전 XP임베디드사용	포스 시스템 보안 문제 대두 (Emerging security issue in the POS system), Point of sale (POS), 공격기법 3가지, 해킹방지 요구사항
281		하	인터넷 뱅킹 보안	[정의] 인터넷을 통해 은행의 각종 업무를 처리하는 기술 [필요성] 인터넷 뱅킹 보안 서비스는 현재 다양한 원인으로 인해 문제점을 가지고 있으며 구체적인 서비스 취약점 분석을 통한 보안대책 수립이 필요 [위협] 인터넷 뱅킹 해킹 금전 탈취 / 공인인증서 ActiveX 보안 및 이용불편으로 공인인증서 패치 전자서명법 개정 다양한 인증방식 도입 [취약점] 클라이언트측면 취약점: 입력오류, 정보유출, 파일 중요정보 획득,보안모듈 암호화 함수 노출 서버측면 취약점: 파라미터 변조, 민감한 데이터 노출 취약점, 세션 관리 [대응방안] 입력오류 : 키로깅, 웹스니퍼 => 보안솔루션 적용 데이터 캐싱 제거 파일 무결성 검증 루틴 추가	인터넷 뱅킹 서비스 취약점 및 대응방안
282	출제예상	중	스마트팩토리 취약점 및 대응방안	[정의] 제조업과 IoT를 중심으로 ICT 융합으로 효율화/ 자동화된 공장체계 [스마트공장 특성에 따른 융합보안 필요성] - 센서와 IoT기기, 제품정보관리시스템(PLM), 제조운영시스템(MES) 등이 공장 내외부 생태 계 연결되는 스마트공장의 특성 따라 기존 보안 피해가 물리공간으로 확대되는 융합 보안의 특성을 지님 [스마트공장 보안 대응 체계 구축 방안] 구분/ 대응 체계 / 구축 방안 / 대응 기술 관리적 정책수립, 지침, 절차, 조직, 감사, 보안교육 물리적 건물, 펜스, CCTV, 출입통제, 장비보안, 재해해택 기술적 암호화, 사용자인증 식별, 비상전원강화, 필수장비 이중화, 원격 접근통제 [보안취약점] 중요정보 유출(이동 저장장치 유출, 악성코드 감염, 데이터 훼손-유출) 디바이스 데이터(ID중복, 데이터훼손/유실, 무결성 훼손, 펌웨어 바이러스) IoT 통신환경의 네트워크 공격(ID Snooping, 데이터 Sniffing, DoS Attack) 기기와 사용자 인증 우회(NW Sniffing/ Spoofing, ID Snooping, 데이터 Tampering) Application 영역(데이터 Tampering, Repudiation, Buffer overflow) [보안기술] 기술측면(안전한 키관리, Secure 저장소, Trusted 펌웨어, Secure 채널, NW 필터링, BITW(Bump in the wire), Radius 서버, PKI 인증서, KMS(키관리), 인증서버, 데이터 검증, SCADA망과 OA망 분리, EDR, DLP, DRM) 정책측면(중요정보 생명주기별 대응(식별/생성/유출/접근/활용/보관/외부유출/파기), 전담 보안 조직 운영, 인적 보안 관리, 점검 및 감사 실시)	취약점: 디바이스 데이터 무결성 훼손, IoT 통신환경 NW 공격, 기기와 사용자 인증 우회 융합보안 OT IoT
283			NTP (Network Time Protocol)	[정의] 인터넷 상의 시간을 정확하게 유지시켜 주기 위한 통신망 규칙 [NTP Refelction attack] NTP 서버에 최근 접속한 시스템 목록을 전송하는 정상적인 'monlist' 명령어를 악용한 것으로, 트래픽 증폭시켜 공격 대상 서버의 DDoS 공격(CVE-2013-5211) [절차] 변조(IP변조,포트-s80,d:123) - 전송(monlist 요청) - 증폭(monlist응답) - 장애(victim target DDoS 공격 과부하) [NTP Stack overflow] 스택 포인터가 스택의 경계를 넘어서 프로그램 충돌이 발생하는 취약점 (CVE-2014-9295) [취약점] crypto-recv(): autokney 인증 활성화 시, cti_putdat():실패되지 않은 호스트 허용 시, configuration(): 익스플로잇 위한 추가적 인증 필요 [대응] 관리(NTP 서비스 서버 대상파악,검토) 물리(망분리, NTP서버 접속차단), 기술(NTL 버전 업데이트 트, ntp.conf 내 disable monitor 추가로 monlist 기능 비활성화)	CVE-2013-5211

284		출제예상	드론 취약점 및 대응	선 전파의 유도에 의해서 비행하는 무인항공기의 총칭 (UAV) [목적] 군항 감정물 군사활동, 항공정보 수집, 감시, 대상 정보 수집, 정찰, 물류, 촬영, 취미 도시 암살, 환경 관리, 산물감시, 재난상황감시, 노후인프라점검 [드론 서비스 구성요소] 구성지드제요 제구통페 구역관리장치(RA), 정보 제공 장치(IP), 지상제어장치(GCS), 드론, 서비스 제공기관(SP), 서비스요청자(SC) 제어부(각종 센서), 구동부, 통신부, 페이로드(탑재장비) 12Kg 이상은 허가 받아야 함. 도로교통부 CNPC(Control Non-payload Communication), GCS(지상통제장치) [3단락] 드론원스탑민원포탈서비스(비행장치 신고서 등록, 비행승인 신청서 등록, 특별비행 승인) [문제점] 정국추 [정보보호문제] 개인정보, 사생활 침해문제, 범죄 [국방위협] 국가 주요시설 정보탈취, 폭탄 투하 [추락 가능성] 원격조정 실패 인한, 재산피해, 인명피해 [위협요소] 속스재 도키 악감탐 통신신호 속이기(GPS Spoofing, GPS Jamming) 통신도청(정보유출, 불법탈취 후 키, MITM) 악성코드감염(악성코드 감염, , 불법 장치 탑재) [대응방안] 관리적보안(개인정보/개인 위치정보 전송 보호 법률 개정, 가이드라인 작성, 드론 등록제, 인증제도, 책임 보험) 기술적보안(GPS 송/수신기 상호인증, 통신데이터 암호화, GPS 개량(암호기술개발), 드론 트래커, 드론 디펜더, GPS 대체기술(이미지 탐지기술, 양방향전송)) 물리적보안(카메라 기반 인지기술(딥러닝 활용))	
285		하	IPv6 취약점 및 대응	[정의] 현재 인터넷의 한계 극복을 위한 충분한 주소공간 제공과 향상된 보안기술이 적용된 차세대 인터넷 주소체계 표기 : 128비트, 8개의 16비트 구성(ex:21DA:00D3:0000:2F3B:02AA:00FF:FE28:9C5A) [IPv6 자체 보안원형] 주소확장(스팸방지 어려움), 다량주소처리(방화벽이해 어려움), 확장헤더(재조합공격), 자동설정(설정오류), 애니/멀티캐스팅(패킷범람), ICMPv6(IDS, IPS CPU오버헤드, DDoS), IPSec(방화벽 인식불), 보안기술(포스트스캐닝한계) [IPv4 연동] 복잡터널링(정보파악 어려움), 주소체계포함문제(IPv4 오용주소) [대응방안] ① 방화벽, 라우팅 장비보완 ② IPv6 환경 전략/정책수립 ③ SEND프로토콜사용(공개키서명방식, CGA) ④ 확장헤더 필터링 ⑤ 주소인증, 포트인증 ⑥ ACL, 패킷필터링 ⑦ IPSec AH 사용 ⑧ Proxy 서버 > 확장된 주소 범위로 인해 포트 스캐닝이 어려움 > 확장된 주소 범위로 인해 공격자 추적어려움 > IDS, IPS 의 CPU 오버헤드로 인한 DoS 공격 위험 > 자동 주소설정기능 악용하여 정상적인 주소 할당 방해하거나 정상 선 종료	
286		상	스마트카	[정의] 자율주행차, 커넥티드 카를 포함하여 ICT 기술이 접목된 진화된 자동차 [주요기술] HAD(Hughway Driving Assist) [주요위협] 차량외부(VANET), 차량내부(CAN), 인포테인먼트 [공격루트] 회사NW, 생산NW, 자동차자체, 애프터마켓 NW [보안원형] 스마트카 자체(V2X 통신(DoS, 제임), GPS 신호 수신 방해, 악성코드 감염, ECU해킹, OBD 해킹) 스마트카 <-> 스마트카(V2V 도청/추적, 차량간 통신 방해, Fake 교통정보 전송) 스마트카 <-> 기반인프라(V2I 통신 도청/추적, V2I 통신방해, Fake 인프라(비인가 정보전송)) 기반인프라(원격 비정상 접근/해킹, 물리적 인프라 조작) 인프라 <-> 교통센터(I2C 통신 도청/추적, Fake 정보) 교통센터(원격해킹, 원격 비정상 접근) [대응방안] 스마트카 자체(스마트카 방화벽, GPS 안티 제임, 전용 백신, 키 침입방지 시스템, OBD 방화벽, HACMS, CANOpen, Secure Boot/Secure Update, KMS) 스마트카 <-> 스마트카(V2V 통신 암호화, 상호인증, 차량간 VPN) 스마트카 <-> 기반인프라(V2I 통신 암호화, 상호인증) 기반인프라(운행정보 보호기술, Anti DDoS) 인프라 <-> 교통센터(I2C 통신 암호화) 교통센터(운행정보 암호화, C-ITS Core 접근제어)	ISO11898(메시지 전송구간 비암호 화) TPM(Trusted Platform Module) 적대적공격
287		하	가상화폐 거래소 취약점 및 대응	[정의] [가상화폐 거래소] 비트코인 등 블록체인 기반으로 구현된 가상 화폐를 실시간으로 거래 양, 거래 정보 등을 확인 할 수 있는 사이트 [가상화폐 거래소 보안] 가상화폐 거래소 보안 취약점 대한 대비 미흡. 제도화된 금융권 편입 이전이라 금융감독원 규제를 벗어나 있어 문제의 심각성 대두 [가상화폐 거래소 시스템 관점 해킹 사고 유형] (부 해킹과정/설명/해킹 기술) (1) 직원 PC 장악 / 직원 PC 악성코드 설치로 공격거점 악용 / DBD, 피싱, 워터링 홀 (2) 지갑 서버 접근 / 거래 서명키 보관된 지갑 서버 접근 / 권한상승 (3) 지갑탈취, 가상화폐 이체 / 지갑(거래서명키) 탈취불법 가상통화 이체, 획득/ 백도어 [가상화폐 거래소 고객정보 관점 해킹 사고 유형] (부 해킹과정/설명/해킹 기술) (1) 고객 개인정보 탈취 / 거래소 서버, 직원PC 해킹 / 사회공학, 포스트스캐닝 (2) 고객 인증정보 탈취/보이스 피싱 등 고객 대상 추가공격 수행/Brute Force, 피싱, 스미싱 (3) 가상통화 이체 / 탈취 인증정보 통해 정상고객 위장, 불법 가상통화 이체, 획득 / MITM [가상화폐 보안 점검에 따른 대응] (법적 보안)-- 금융권으로 인식 전환 필요 - 이 따르는 금융감독원 감독 권한 강화 및 보안 정책 의무화 (정책 보안)-- 금융권 준하는 보안 정책 구축 및 관리 - 시스템 접근 통제 정책 강화 (기술적 보안)-- 네트워크 망분리 통한 접근 통제, 네트워크 방화벽 강화 - 주요 데이터 백업 관리 강화 [기술적 측면 가상화폐 거래서 상세 대응방안] User & Application(사용자보안적용(최신 패치, 백신), Application 보안 적용(시큐어코딩, 난독화)) User & 거래소(Network 보안 적용(암호화, 보안장비)) 거래소보안(접근제어 적용(RBAC), 인증기술 적용(OAuth2.0, 생체인증), 관제체계 적용(대시보드, 머신러닝)) 거래서 & 키관리(독립된 망운영 기술 적용(망분리), 사용자 자산 관리(Cold Wallet))	

288		상	블록체인(Block Chain) 플랫폼	[정의] 블록체인 플랫폼 안전하게 사용하기 위한 각종 위협과 취약성에 대한 대응 기법 [보안위협] 키위블 분상스 합사개 가비권내 공통보안위협(키도난 및 분실, 취약한 키 생성, 블록체인 S/W 취약점, 분산(Distribution) DoS 공격, 상호운영성 미제공, 스마트 컨트랙트 취약점) public(합의가로채기(51%공격), 사이드 체인 내 비정상 거래, 개인정보 침해, 가용성 저하, 비정상거래 탐지 불가) private(권한 오남용, 내부 담합) [대응방안] 공통(신뢰성 확보, 다중서명, 키 분리, 재생공격 방지) 거래 검증 및 합의(모니터링, 거래 수수료) 참여자 권한 관리(3자 접근통제, 거버넌스 확립) 블록체인S/W 보안(최신상태 유지, 스마트 계약 취약점 탐지) public(개인정보 보호, 유효성 검증, 가용성 확보, 신뢰성 확보, 스캠거래 차단) private(접근제어, 참여자 검증, 사이드체인 활용, 앵커링 검증)	적대적 공격(Adversarial Attack)
289		중	3D 프린팅	[취약점] 일반/ 네트워크/비휘발성 저장매체: 메모리에 저장된 정보 탈취 [대응방안] SDLC를 통한 3D 프린터 보안취약점 대응방안 : 설계 도입/개발/운영/폐기: NIST SP 800-53 가이드 따라 처분 ----- [정의] 3차원 설계 기반 복합물질 이용 실물모형, 프로토타입 등 인쇄하는 첨삭가공 기술 [3DP 특징] - 품종 소량생산, 다양한 모양, 프로토타입 [3DP 과정] 3D 모델링 → 복합물질 프린팅 → 마무리 작업 [3DP 방식] - 액체기반 : SLA(광합성 액상 수지, 레이저 빔) - 고체기반 . 분사 : Polyjet (광경화와 잉크젯 혼합), 3DP (노즐적층, 경화물질>분말원료) . 분말 : SLS(금속 파우더, 레이저), SLM(금속 파우더, 고출력) . 압출 : FDM(열 녹는 모델, 필라멘트 사출) [보안위협 및 취약점] 일반적 위협(스팸, default 설정, 데이터 캡처, 데이터 침해 변조, 취약한 운영체제) 네트워크 연결 위험(비인가 접근, 데이터 유출, 포트 오픈, DoS 공격, 봇넷, 접근권한 탈취) 매체 위험(USB 통한 정보 유출, 암호화 되지 않은 데이터 유출) [대응방안] 정기업데이트, 보안설정, DLP, DRM, NAC, ACL	
290		중	CPU 보안 취약점/스펙터(Spectre)	CPU 보안 취약점에서의 스펙터(Spectre) 멜트다운과 달리 x86과 ARM 아키텍처에 전부 적용되며, (공통) 멜트다운과 동일하게 마이크로프로세서가 컴퓨터의 메모리의 전체를 볼 수 있도록 프로그램의 접속을 허용하며, 이로 인해서 전체 컴퓨터의 내용에 접근할 수 있다.	
291		중	멜트다운(Meltdown) 버그	CPU 보안 결함 중에서 멜트다운(Meltdown) 멜트다운 버그는 마이크로프로세서가 컴퓨터의 메모리의 전체를 볼수있도록 프로그램의 접속을 허용하며, 이로 인해서 전체 컴퓨터의 내용에 접근할 수 있다. 멜트다운은 CVE-2017-5754로 등재되어 있다. -> 아마존 웹 서비스(AWS)[9], 구글 클라우드 플랫폼 같은 주요 클라우드 서비스 제공자들에게 큰 영향/ 클라우드 플랫폼의 경우 동일한 물리적 서버에서 돌리고, 가상화로 보호되지만, 멜트다운은 이런 보안을 부수고 다른 프로그램을 볼수 있기 때문에 큰 문제임.	파이프라인
292		중	DNS 취약점 공격	[정의] 보안 미고려 프로토콜 사용 설계상 취약점, 이용상 취약점으로 DNS에 의한 도메인 변조 공격 1) 의도치 않은 사이트 접속 : 도메인 위변조 시에 사용자가 의도하지 않은 사이트로 접속될 우려 발생 2) 장애 시 파급효과 치명적 : 도메인에 대한 기술적/보안적인 관리 허술, 가동 서비스 중단 등 우려 3) 추가 피해 : 민감한 데이터 유출과 기업의 평판 하락으로 인해 추가적인 피해 발생 [취약점공격] DNS Cache Poisoning Attack, DNS 중독 DDoS 공격 [기술적 대응방안] 서버설정(Recursion Query 제한, BIND 업데이트, Zone Transfer 제한) 시스템활용(DNSSEC 적용, KISA DDoS 대피소 활용) [관리적 대응방안] DNS 물리적 분리 DNS 방화벽 정책 수립 DNS 내부 운영 지속적인 DNS 보안 교육	은닉채널공격
293		상	딥러닝 취약점	[정의] 딥러닝 취약점, 적대적 공격의 개념 분류 성능이 우수한 DNN 을 이용한 Classifier 들에 적대적 교란을 적용하여 분류 알고리즘이 Misclassification 을 발생하도록 만드는 인공지능의 인식 오류를 이용한 공격 [원인] 네트워크/자원이용 제약, 차량/장치 내부실행, IoT와 엣지 환경 [기법] 포이즌 - 중회추모 Poisoning attack(중독 공격) - 악의적 학습 데이터 주입, MS 챗봇 테이, 스캐터럼 이루다 Evasion Attack(회피 공격) - 입력 데이터 최소 변조 => 머신러닝 속이는 기법, 표지판 이미지 변조 Inversion Attack(학습 데이터 추출 공격) - 수많은 질의 던져 산출된 결과로 데이터 추출 유도 공격 Model Extraction Attack(모델 추출) - MLaaS 탈취, Evasion, Inversion Attack 등 2차 공격에 활용 [방어 기법] 디지컬탐취 Defense-GAN, 적대적 훈련(Adversarial training), 결과값분석 차단, 적대적 공격 여부 탐지, 쿼리 횟수 제한(Brute Force 못하게 함)	적대적 공격(Adversarial Attack)
294		출제예상	실감콘텐츠 보안	[보안취약점] Brute Force 공격, Buffer Overflow 공격, Cyber kill Chain, Sniffing, DOS, 악성코드, 펌웨어공격, 기기 루팅 [대응방안] 통합계정관리(IAM), Secure Coding, 포렌식 워터마킹, 암호화, ESM, SIEM, Anti-DDoS, 백신, 난독화	
295		출제예상	MEC 취약점 및 대응방안	엣지 컴퓨팅(Edge Computing)의 보안취약점 및 대응방안	

296		출제예상	메타버스의 보안 위협 및 대응방안	[보안위협] Real World (개인정보 유출, 프라이버시 위협, 불법 권한상승, 자산 탈취, 바이오정보 노출, 지리정보 노출) Interface (송출 데이터 스니핑위협, 메타버스 로그 삭제, 5G RAN DDoS) Metaverse World (신원 변조·도용, 개인정보 불법 거래, 불법행위와 사법권, AI 창작물 저작권 침해) 관리적 측면 (내부자 설계/관리 문제, 데이터센터 관리, 해커들의 타겟, 피해 규모의 확산, 키 도난 및 분실, 취약한 키 생성) 기술적 측면 (트래픽 도청 및 위·변조, 시스템 설계상의 오류, 침입탐지 어려움, 가상머신의 이동성) 서비스 측면 (비정상 거래탐지 불가, 가용성 저하, 상호 운용성 미제공) [대응방안] Real World (디바이스 보호, 엔드포인트 보호, 소스코드 난독화, 개인정보 처리 통제, 개인정보 가명·익명처리, 바이오 정보 보호) Interface (메타버스 전구간 암호화, 보안 로그 복합 연동, 5G Anti-DDoS, NXG IPS / Firewall, 안전한 알고리즘, 설계부터 보호정책 수립) Metaverse World (디지털 자산의 안전관리, 디지털 포렌식, 콘텐츠 보호기술, 권한 접근 제어, 프라이버시 익명성 강화) 관리적 측면 (보안 인증체계, 정보처리책임자 지정, 보호 프레임워크 수립, 보상 및 보험, 지리적 분산, 정보보호 거버넌스) 기술적 측면 (전송데이터의 보호, 데이터의 저장, 접근 및 인증, VM간 독립성, 어플리케이션 보안) 서비스 측면 (정상·스팸거래 부류기술, 머신러닝기반 탐지, 참여자 제한 및 검증, 자산 이전 표준 기술)	
297		출제예상	생성형 AI 위협 및 대응방안	2. 국가사이버안보센터는 생성형AI의 보안위협과 안전한 활용을 위한 가이드라인(챗GPT 등 생성형 AI 활용 보안 가이드라인, 2023.6)을 발간하였다. 이와 관련하여 다음을 설명하시오. 가. 생성형AI의 개념 및 활용 서비스 사례 나. 생성형AI의 보안 위협 종류별 주요 원인과 발생 가능한 보안위협 다. 생성형AI 모델/서비스 개발 시 보안 고려사항과 보안위협 대응방안	
298		출제예상	생성형 인공지능 저작권	(저작권 이슈) - 텍스트, 이미지 제작 시 생성형 AI를 활용하여 빠르고 편리하게 제작할 수 있지만, 저작권 측면의 이슈로 인한 사회적, 문화적 이슈 발생 가능 데이터 수집 문제, 법적 기준 부재, 저작물 유사성, 저작권 침해 예방기술, 워터마크	
299		출제예상	UAM 취약점 및 대응방안	UAM(Urban Air Mobility) 보안사고(의도한 사고)와 안전사고(의도하지 않은 사고)로 분류 정리	
300		하	잊혀질 권리	[정의] 정보주체가 온라인상 자신과 관련된 모든 정보에 대한 삭제 및 확산 방지를 요구할 수 있는 권리(EU, 2012) 인터넷상에서 잠재적으로 나타나 있는 자신과 관련된 정보를 포함하는 각종 자료의 삭제를 요구하여 해당 자료로부터 자유로워질 수 있는 권리 (Norbert Nolte, 2011)	이용자본인 <-> 사업자 <-> 제3자
301	보안 교양 토픽	상	신지식재산권	[정의] 지식 재산권의 하위 개념으로 경제적, 기술적 가치를 인정받아 새로 규정한 재산권, 사회/기술의 변화에 따른 새로운 형태의 지식재산권 신지식재산권 : 산업저작권, 반도체집적회로 배치설계, 생명공학과 같은 "첨단산업재산권" 및 영업비밀, 멀티미디어와 같은 "정보재산권", 기타 (프랜차이즈, 캐릭터 등) [재산권] 산업재산권(특허권, 실용신안권, 디자인권, 상표권) 저작권(저작권, 저작인접권) 신지식재산권(첨단산업재산권, 산업저작권, 정보재산권, 기타)	
302		하	사이버 명예	토르전용접속, 패블릭 지원, 로그삭제	
303		하	E-Discovery	[정의] 소송 과정을 공정하고 합리적으로 진행하기 위해 공판 시작 전 원고와 피고가 서로 합의한 범위 내에서 사건과 관련된 이메일 등 각종 디지털 자료를 공개하는 제도 [특징] 전자문서 대상, 특허 괴물(Patent troll) 대응·전자기록 통합/모니터링 통한 특허 소송 합리적 대비 [필수기능 요소/업무절차] 정보관리(정책설정,모니터링) - 소송준비(소장검토, 연관성 정보 식별) - 정보수집(정보검색, ESI) 백업 - 보관(보관 정책 설정, 정책 적용) - 정보처리(유사성 기반 분석, 필터링) - 검토 및 분석(검토 전략 수립, 검토 대상 시각화) - 증거 생산(협의된 증거 파일포맷 가공) - 제출/파기(ESI 시각화, 미사용, 사용완료 정보 파기 등)	디지털 증거제시제도
304		하	탈린매뉴얼 (Tallinn Manual)	[정의] 북대서양조약기구 NATO가 발표한 사이버테러에 관한 조항 및 대처에 대해 최초로 성문화 한 사이버교전 수칙 [구성] Part 1(국제 사이버 보안법), Part 2(사이버 무력 충돌법) 2개 도메인 95개 교전 수칙	국제법 매뉴얼, 주권, 관할권 및 통제권, 무력의 사용
305		하	정보보호산업진흥법	[정의] 정보보호산업의 진흥에 필요한 사항을 정함으로써 정보보호산업의 기반을 조성하고 그 경쟁력을 강화하여 안전한 정보통신 이용환경 조성과 국민경제의 건전한 발전에 이바지함을 목적으로 제정된 법률 [정보보호 준비도 평가] 정보보호산업진흥법 제 12조 [평가등급 모델] AAA(100~90점 : 최적의 보안관리 활동 수행) AA(89~80점 : 체계적인 보안관리 활동 수행) A(79~60점 : (기업 상황에) 요구되는 보안관리 활동 수행) BB(59~40점 : (기업 상황에) 적절한 보안관리 활동 수행) B(39~23점 : 기본적인 보안관리 활동 수행)	ISMS, PIMS 정보보호산업의 진흥에 관한 법률 제12조에 따라 시행 근거 마련(2015.12.23)
306		상	개인정보보호법	[제 24조의 2항] 2018.1.1 100만명 이상 주민번호 반드시 암호화 미조치시 3천만원 이하 과태료, 유출시 2년이하 징역 또는 2천만원이하 벌금 [22조 2항] 수집 동의 획득 시 알아보기 쉽게 표시 [34조 3항/39조 1항] 2017.10.9 1천명 이상 개인정보 유출 시 KISA에 지체없이 신고 (매년 체크) 개인정보보호법 개정안 주요 내용 - 개인정보 관련 개별 주제들과 개인 정보 처리 흐름 - 개인정보 전송요구권과 AI 활용을 위한 자동화 의사결정 대응권 - 개인정보보호법 제 3 조 개인정보 보호 원칙(133회 기술)	
307		중	개인정보보호법 제30조	처리 목적, 처리 및 보유 기간, 제3자 제공 사항, 처리의 위탁 항목, 정보주체의 권리, 의무	
308		상	정보통신망법	[정의] 정보통신망의 이용을 촉진하고 정보통신서비스를 이용하는 자의 개인정보를 보호함과 아울러 정보통신망을 건전하고 안전하게 이용할 수 있는 환경을 조성하여 국민생활의 향상과 공공복리의 증진에 이바지함을 목적으로 한 법률 [내용] (3은 삭제됨) 제1장 총칙 제2장 정보통신망의 이용촉진 제4장 개인정보의 보호 제5장 정보통신망에서의 이용자 보호 제6장 정보통신망의 안전성 확보 등 제7장 통신과금서비스 제8장 국제협력 제9장 보칙 제10장 벌칙	
309		중	정보통신기반 보호법	이 법은 정보통신망의 이용을 촉진하고 정보통신서비스를 이용하는 자의 개인정보를 보호함과 아울러 정보통신망을 건전하고 안전하게 이용할 수 있는 환경을 조성하여 국민생활의 향상과 공공복리의 증진에 이바지함을 목적	

310		상	데이터 3법	[개인정보보호법] 가명정보 개념 도입 및 이용통제, 감독기관 일원화 [정보통신망법] 법체계 일원화, 감독기관 일원화 [신용정보법] 빅데이터 분석 이용 활성화, 감독기관 일원화, 신용정보의 전송요구권	122회 기출
311	법적 대응 법 필수 4 개 정리	출제예상	마이데이터/ 마이데이 터 전송 보안 안내서	개인정보 안전한 처리를 보장하기 위한 가이드라인, 마이데이터 전송 보안 안내서 어느정도 독자적인 의사결정 접근 통제 제공.	
312		출제예상	데이터 전송요구권	데이터3법중 신용정보법 개정으로 개인의 금융정보를 다른 금융기관이나 기관에게 전송하는 것을 요구할 수 있는 권리 [1-나.근거] 신용정보법 제 33조의 2 : 개인신용정보의 전송요구, 신용정보법 시행령 18조의 6, 28조의 3 : 개인신용정보의 제공·활용에 대한 동의 신용정보법 감독규정 39조 2 : 개인신용정보를 제공받는 자의 확인 [2-가.절차] 본고전통 1) 본인정보 이동요청서 제출 (정보주체 -> 금융회사, 신용조회사/본인신용정보관리회사) 2) 고객정보 제공 요청(금융회사/신용정보관리회사 -> 신용정보 제공자) 3) 전자적 전송 4) 본인정보 통합조회 및 금융상품 추천 [2-나.데이터 전송요구권 의무 수용기관] 신전공본 - 신용정보제공이용자 (금융지주사, 은행, 신용협동조합, 카드사, 보험사), - 전자금융업자 (한국거래소, 예탁결제원, 신용정보회사, 한국전력공사, 수자원공사), - 공공기관, 본인신용정보 관리회사 (행정안전부, 고용노동부, 국세청) [2-나.데이터 전송요구권 의무 수용기관] 신전공본 - 신용정보제공이용자 (금융지주사, 은행, 신용협동조합, 카드사, 보험사), - 전자금융업자 (한국거래소, 예탁결제원, 신용정보회사, 한국전력공사, 수자원공사), - 공공기관, 본인신용정보 관리회사 (행정안전부, 고용노동부, 국세청) [3단락 - 기술요소] OpenAPI, TLS, JWS(Java Web Signature 규격) , 플랫폼(오픈뱅킹)	데이터3법 마이데이터
313		출제예상	특정금융정보법	[개념] 금융거래를 이용한 자금세탁행위와 테러자금 조달행위를 규제하기 위해 금융회사 등에게 의심스러운 거래나 고객 현금거래 보고, 고객 확인, 자금세탁방지 관련 내부 업무절차 정비 등의 의무를 부과하고 있는 법률 [개정배경] 근래 암호화폐 등 가상자산 거래가 활발해지면서 가상자산을 이용한 금융거래의 불투명성, 가상자산을 이 용한 불법거래나 자금세탁행위에 대한 우려가 제기되고 있는데도 가상자산 거래에 대한 감시나 추적이 이루어질 수 있는 명확한 법률상 근거 [주요내용] 가상자산사업자의 범위(법 제2조 제2호 하목6), 가상자산사업자의 신고(법 제7조 및 시행령 제10조의 11~19) [가상자산사업자의 의무] - 자금세탁방지(고객확인, 의심거래보고), 가상자산 이전시 정보제공 의무(법 시행령로부터 1년 유예) [실명개정 발급요건] 1. 고객 예치금을 고유재산과 구분하여 관리할 것 2. 정보보호 관리체계(ISMS) 인증을 획득할 것 3. 고객별 거래내역을 분리하여 관리할 것 4. 금융회사는 가상자산사업자가 자금세탁행위 방지를 위한 가상자산사업자의 절차 및 업무지침을 확인하여 가상자산 사업자와의 금융거래에 내재된 자금세탁행위와 공중합박자금조달행위의 위험을 식별/분석/평가할 것	
314		출제예상	프라이버시 8원칙	1) 수집 제한의 원칙 2) 정보 정확성의 원칙 3) 목적의 명확화 원칙 4) 이용제한의 원칙 5) 안전성 확보의 원칙 6) 공개의 원칙 7) 개인 참가의 원칙 8) 책임의 원칙	
315		출제예상	CBPR(Cross Border Privacy Rules)	APEC(Asia-Pacific Economic Cooperation) CBPR(Cross Border Privacy Rules) - APEC 프라이버시 9원칙 9원칙: 고지, 수집 제한, 목적 내 이용, 선택권, 무결성, 보호대책, 열람·정정권, 책임성, 피해 구제 등 9가지 프라이버시 원칙CBPR 인증은 APEC(아시아 + 태평양경제협력체) 프라이버시 보호 원칙을 기반으로 기업의 개인정보 보호 체계를 평가하여 인증하는 글로벌 인증제도 - 6개 인증기준(나. CBPR의 주요 인증기준) 1) 개인정보관리체계수립 2) 개인정보보수집, 6) 보호대책까지	
316		하	FIPS	FIPS(Federal Information Processing Standard) 140-2 (정의)연방 정보 처리 표준 출판물 140-2(FIPS PUB 140-2) 암호화 모듈을 승인하는 데 사용되는 미국 정부 컴퓨터 보 안 표준	
317		하	정보보호 제품 신속 확인 제도	신기술, 융·복합 제품에 대해 최소한의 절차와 인증 기준으로 보안 제품을 평가한 뒤 평가 기준이 마련될 때 까지 공공 부문에 제품을 적용할 수 있도록 하는 제도 신속확인 대상 검토, 신속확인, 사후관리	
318		하	SIM	SIM: Subscriber Identification Module 통신 회선 가입자들의 식별 정보만 구별하는 용도	
319	가입자 식 별 모듈	하	USIM	Universal Subscriber Identity Module 카드 통신사와 제조사에 따라 변경 필요 주소록 저장, 교통카드, 신용카드 등의 부가 기능을 제공 - USIM에 식별자 값을 할당하고, 이 값을 IMSI 라고 부름. - 스마트폰 포렌식때, 위 용어 쓸 것	
320		하	e-SIM	전자식 가입자인증모듈(e-SIM), 이통사 선택 아키텍처 포함 기능 내장되어 있음, 세계이동통신사업자협회(GSMA), 폰에 서 이통사 선택기능이 있음.	
321	HW 보안 모듈	출제예상	TPM	TPM(Trusted Platform Module) 신뢰할 수 있는 플랫폼 모듈, 하드웨어적 보안 기능 제공하기 위한 모듈 컴퓨터의 보안을 유지하는 기능을 가진 하드웨어 부품	
322		하	PCI DSS (Payment Card Industry Data Security Standard)	[정의] 가맹점 결제 대행 사업자가 취급하는 카드회원의 개인정보를 안전하게 보호하기 위해, 국제적 대표 결제 브랜드 5개사가 공동으로 책정한 신용업계 글로벌 보안기준 [필요성] 기업측면(준거성, 분쟁방지), 고객측면(정보보호, 안전거래)	핀테크의 글로벌 보안기준
323		하	이탈리아 해킹팀 개발	[정의] 각 국 정보기관 등으로 도감청 용도로 판매된 이탈리아 해킹팀에서 개발된 원격제어시스템(갈릴레오 버전) [특징] 도감청범위(대부분 OS-안드로이드, 윈도우, iOS, MacOS, 블랙베리, 리눅스, 우분투 도감청항목(주소록, 일정표, 통화목록, 사진파일, 채팅기록, 클립보드, 키로그) [동작방식] 피해자선정 -> 피싱메일/스미싱 MMS 발송 -> 링크클릭 -> RCS설치 메시지 도감청	RCS(Remote Control System) 멀티미디어 메시징 서비스 (Multimedia Messaging Service)

324	하	전자기파 이용 공격	[정의] HW에 강력한 전기장과 자기장을 지닌 순간적인 전자기적 충격파를 통해 정보시스템을 파괴하는 공격 [그림] 전자파보안-물리적보안-사이버보안-정보보안 [유형] TEMPEST(반에크 프리킹 공격, 방사선 공격), EMP공격 [유형상세] TEMPEST: 전자파에서 정보를 흡수내는 기술, 스니핑 공격 EMP공격: 강력한 전기장과 자기장을 지닌 순간적인 전자기적 충격파,	Tempest, Emp공격
325	출제예상	Signature 기반	예) 시그니처 기반 멀웨어 진단 방법은 바이러스의 샘플을 수집하여 진단하는 방법. 컴퓨터 바이러스가 새로 출현하면, 안티 바이러스 제작사들은 이러한 샘플을 수집하여 진단하고 치료하는 방법을 알아내어 이를 안티 바이러스 데이터베이스에 추가하는 방식을 사용. 이러한 방식을 리액티브(reactive) 방식이라고도 하며, 바이러스의 흔적을 '시그니처'라고 부름. 대비용어: 이상징후(Anomaly) 기반	
326	하	Security Intelligence	[정의] 사용자, 애플리케이션 및 인프라에 의해 생성되어 기업의 IT 보안 및 위험 상황에 영향을 미치는 데이터를 실시간으로 수집, 정규화 및 분석하는 지능화된 보안 기술(솔루션) [특징] Context Aware Security, 새로운 공격 탐지, 통합 보안관리 기술, 빅데이터 활용 [필요성] 악성코드 증가, 연결 디바이스 증가, 한정된 자원, 선택적 대응 [기술요소] 수집&분석(SIEM 로그관리, 프로파일링, 실시간 분석) 예방&감지(네트워크와 호스트 침입방지, 네트워크 비정상패턴 탐지, 데이터베이스 행위 모니터링) 대응&조치(패킷 포렌식, 데이터 유출 방지)	
327	하	Federal RAMP	미국 클라우드 인증 평가프로세스: 3 PAO(Third Party Audit Organization) 인가>보안평가>운영권한등검>지속적인 평가 및 인증	
328	상	난독화(Obfuscation)	SW 참조 요망	
329	하	사이버 게놈(Cyber Genome)	[정의] 시그니처 기반이 통하지 않을때 인간의 유전체를 분석하듯이 인터넷 악성코드 및 해커를 분석, DNA화하여 APT 공격 등 사이버 공격을 예방하는 지능형 보안 기술 [주요기술] (1)악성코드 API 시퀀스 추출: 악성코드 확인, connect(), createfile() (2)API기반 악성코드 특성 인자 추출: whitelist 제거 남은 결과로 악성코드 유추 (3)서열 정렬: 2개 이상 유사도 측정, 구간 관계성 추출, 국소정렬 (4) 악성코드 유사도 분석: LCS 알고리즘 활용, 악성코드 식별	LCS(Longest Common Sequence) 데이터 마이닝, Classification, Clustering 기반 Outlier detection, Opcode
330	하	화이트 해커	인터넷 시스템과 개인 컴퓨터시스템을 파괴하는 해커(크래커)를 블랙 해커라고 하고 화이트 해커는 이에 대비하여 쓰는 개념으로 선의의 해커다.	
331	하	PIN 비밀번호	개인 정보 번호인 PIN(Personal Information Number, PIN)도 본인 확인 수단으로 사용되며 타인의 데이터 접근을 막는다. 자이는 PIN은 0에서 9까지의 숫자로 한정되며, 일반적인 비밀번호는 숫자, 대소문자, 문장 부호를 포함할 수 있다는 것이다. 편리/로컬에서만 사용하므로.	
332	하	Linux PAM	Linux PAM(Pluggable Authentication Modules) Linux용 착탈형 인증 모듈은 시스템 관리자가 응용프로그램들이 사용자를 인증하는 방법을 선택할수 있도록 해주는 공유 라이브러리 묶음 /etc/pam.d	
333	하	쉐도우 IT(Shadow IT)	[정의] 기업에서 개인 혹은 조직 단위로 회사에서 허용하지 않은 IT 디바이스, 소프트웨어, 서비스를 구매하여 IT자산관리에서 파악하지 못하는 미인증 IT환경 [등장배경] 1) SaaS기반의 다양한 협업도구 등장 2) BYOD에 따른 개인 디바이스의 업무 활용 [문제점] 비용관리(IT 비용관리 난해함, 불필요 애플리케이션 사용-BYOD) 보안관리-기업데이터 유출(관리어려움 수백가지 앱), 규정준수(이벤트 통제 어려움), 개인정보 유출(SNS 회수불가), 퇴사자 관리(개인 SNS 회수 불가) 통합관리(클라우드, 서비스 관리 어려움) [해결방안] 관리적(직원교육 강화, 정책우회 시 처벌 강화) 기술적(감시 시스템 리스크 방지, 데이터 암호화-가상화,NW보안, IaC) [주요기술] 기본기능(DLP, 포렌식) 모니터링(클라우드 계정 통합, 워크로드 이미지 제어) 관리(NW 포렌식, CASB, ATP보호, WAF, SSL)	
334	상	비대면 실명확인	비대면 실명인증을 위한 비대면 보안 인증기술	
335	하	SSLv2 DROWN	[정의] DROWN 공격 : Decrypting RSA with Obsolete and Weakened eNcryption (취약점) SSL 2.0 취약점 이용한 Bleichenbacher RSA 패딩 오라클 공격 (대응책) 모든 서버 및 클라이언트 SSL 2.0 지원 금지	SSLv2 MITM 공격, COA, KPA, CPA, CCA
336	중	코드서명(객체서명)	[정의] 개발회사에서 인터넷 상으로 소프트웨어를 배포하는 경우 사용자에게 신뢰할 만한 프로그램임을 알리기 위해 소프트웨어를 인증기관에서 디지털 도장을 받도록 하는 전자서명 방법 - 추가기능(ActiveX, Java Applet 등)을 사용자 컴퓨터에 설치하려고 할 때, 설치하려는 프로그램이 신뢰할 수 있고 안전하다는 사실을 공인된 인증기관으로부터 입증 받은 디지털 서명	

337	기타/시사	중	소단(shodan)	[정의] 세계최초 사물인터넷(IoT) 검색엔진으로, 웹캠, CCTV, 라우터, 스위치, FTP, 특정 웹 서버(IIS, Apache등) 에 대한 정보를 수집하고 그 결과를 보여주는 검색엔진 [동작알고리즘] 주소생성 -> 포트생성 -> 배너포착 (반복) [소단 검색 작업] 유저검색 -> 포트검색, 배너캡처 -> 인덱스 캡처 -> 소단 결과 표시 [구글 검색 작업] 유저검색-> 웹페이지 데이터 크롤링 -> 웹 콘텐츠 인덱스 캡처 -> 페이지 행킹에 따른 표시 [보안취약점] 포트, 배너, 인덱스(데이터베이스, 검색엔진, 포트, 운영체제등) 찾은 후 소단에 출력 IoT 기기정보 노출 [대응방안] IoT 공통 보안 7대 원칙 (1) Security By Design (2) 시큐어코딩 (3) Secure by Default (4) 보안프로토콜(암호/인증/인가 기술) (5) IoT S/W, H/W 보안 취약점 모니터링, 업데이트 (6) 프라이버시 관리체계 (7) 침입탐지와 사고 분석 및 책임 추적성 확보	IoT 검색 엔진
338		중	SNI	[정의] HTTPS로 운영중인 불법 해위 저작권 침해 사이트의 경우 기존의 URL 차단 방식으로는 차단이 불가해 SNI필드의 주소정보로 차단 [차단방식] handshake 과정 중 "HTTPS ClientHello" 메시지 중 SNI 필드에 있는 서버 주소 분석 -> 차단DB 조회 -> 차단 [DNS차단방식] DNS Query -> DNS 서버 IP 반환 -> 불법 침해 사이트 요청 시 차단 (IP도 차단)	
339		하	디지털 윤리(Digital Ethics)	디지털 윤리(Digital Ethics)	
340		출제예상	DevSecOps	Development 와 Operation의 융합과 협업을 통한 개발 주기에서 보안 측면의 주기를 포함하는 개발 방법론	
341		중	Pre-Crime 프리크라이미 시스템	범죄가 일어나기 전에 사건을 예측해 범죄자를 단죄하는 최첨단 치안 시스템	
342		중	ATA-4 / HPA	2019년 감리사 103번 문제를 참조하여, 자료 정리와 풀이 해 오기	
343		중	utmp, wtmp, history	2019년 감리사 107번 문제를 참조하여, 자료 정리와 풀이 해 오기 유닉스/리눅스 보안 문제 모두 정리하기	
344		중	AndroidManifest.xml	안드로이드 기반 보안 문제 총 정리 2018년 감리사 113번 문제를 참조하여, 자료 정리와 풀이 해 오기	
345		중	카나리 단어, ASLR	2019년 감리사 115번 문제를 참조하여, 자료 정리와 풀이 해 오기 카나리스(Canaries) 또는 카나리(canary)는 버퍼 오버플로를 감시하기 위해 스택의 버퍼와 제어 데이터 사이에 위치한 값들	
346		중	이메일 보안 프로토콜	S/MIME(Secure/Multipurpose Internet Mail Extension)	
347		출제예상	고객확인 절차(KYC: Know Your Customer)	자금세탁, 고객주의의무(CDD: Customer Due Diligence), 셸프 인증	122회 기출
348		상	IoC(Indicators of Compromise), IoA(Indicators of Attack)	[IoC] Signatures, Malware 등의 공격이 발생했음을 나타내는 방어자 대응 관점의 지표 [IoA] 코드 실행, Stealth, C&C 등 공격 의도를 파악할 수 있는 동적인 지표	
349		출제예상	공격표면관리-ASM(Attack Surface Management)	(기업이 해커의 입장에서) 민감한 데이터를 포함하여 전송 및 처리하는 외부 디지털 자산을 지속적으로 검색, 인벤토리, 분류, 우선순위를 지정하는 보안 모니터링 [공격표면으로 인한 보안이슈 발생원인분석] 인프라 측면 (정의되지 않은 취약한 네트워크 경계 증가, 섀도우IT(Shadow IT) 확산) 데이터측면 (데이터 활용 및 연계 증가, 다크웹(Dark web) 정보노출) 소프트웨어 측면 (취약한 소프트웨어 관리체계, 공급망 공격 증가) 사용자측면 (근무체계 유연화 및 지원기술 확산) [공격표면관리 프로세스] 디지털 자산 발견 > 자산식별 및 분류 > 지속적인 보안모니터링 > 악성자산 및 사고모니터링	
350		출제예상	지속적인 위협 노출 관리(CTEM)	기업의 정보자산들에 대해 외부에 노출되어 있는지 여부의 확인 및 외부에 노출된 자산들이 어떤 취약점들을 가지고 있고, 이로 인해 발생 가능한 위협 식별 및 지속적인 관리를 통해 경감시켜 나가는 프로세스	
351		중	팻 핑거(Fat Finger)	[개념] 담당자의 근무태만과 내부통제절차 불완전성으로 발생한 작은 실수가 회복 어려운 피해 결과 초래하는 Miss Use 행위 [발생 원인] SW설계 측면 - UX(User Experience) 간과한 UI(User Interface) 설계, 권한 검증 미흡한 전환 테스트 측면 - 입력 값 검증 테스트 부재, 테스트 커버리지(Test Coverage) 미흡 기술적 측면 - FDS(Fraud Detection System)등 이상 발생 징후 포착 부재, Kill switch 등 일괄 취소 기술 부재 거버넌스 측면 거버넌스 측면 - 승인 등 내부통제 절차 및 크로스 체크(cross check) 부족 - 응급장애복구, 자동제어시스템 체제 미비 - 조작 실수(operation mistake)	
352		중	CPTED (Crime Prevention Through Environmental Design)	[개념] "도시·건축환경의 적절한 설계와 효과적인 사용을 통해서 범죄 및 불안감을 감소시키고 삶의 질을 향상" 시키기 위한 다학제적(multi-disciplinary) 이론이자 실천전략 메인 컨셉 : 감시(기계적 감시, 조직적 감시, 자연적 감시) , 접근통제(기계적 접근통제, 조직적 접근통제, 자연적 접근통제) 서브 컨셉 : 공동체 강화(근린교류 및 비공식적 사회통제, 주민자지활동, 자발적인 환경관리)	
353		중	암호공격 기법/암호문 공격	키의 비밀성을 유지하기 위한, 커크호프(Kerchhoff)의 원리 : 암호 해독자는 현재 사용되는 암호 방식을 알고 있다는 것을 전제로 암호 해독을 시도 단기 - CO P, 평암 - PC 암호론 단독 공격(COA, Ciphertext Only Attack), 기지 평문 공격(KPA, Known Plaintext Attack) 선택 평문 공격(CPA, Chosen Plaintext Attkc), 선택 암호론 공격(CCA, Chosen Giphertext Attack)	

354		중	블록체인(Blockchain) 암호기술 가이드라인	[개념] 국가·공공기관에서 안전한 블록체인을 구축하기 위해 준수해야 할 17개의 가이드라인 암호 사용기준(암호모듈 검증제도 검증대상 암호 알고리즘 사용), 계정 관리(관리 시스템 제공, 생성 개체와 시스템 상호 인증 수행, 공개키 개인키 사용, 개인키와 공개키 쌍은 교체 가능, 계정 즉시 폐기 가능) 데이터 전송 보안(개체와 데이터 상호 인증 수행, 데이터 보호) 합의 프로토콜(안전성, 효율성 특성 만족 합의 프로토콜 사용, 참여 노드 수 서비스 환경과 합의 프로토콜을 고려) 원장(트랜잭션 생성 참여 모든 개체 재전송 공격 방지 데이터가 포함, 개체 권한과 전자서명 검증, 이전헤더 해쉬값 포함, 식별자/전자서명/생성 시각 포함) 스마트 컨트랙트(실행 결과 검증 가능, 알려진 보안 취약점 미존재) 데이터베이스(데이터 신뢰성 보장)	
355		중	소프트웨어 안전진단 가이드	국가, 공공기관 등에서 SW 안전 진단을 기획, 추진 및 수행하는데 참고할 수 있는 실무 지침서 주요 내용 - SW 안전 진단에 대한 기본 개념 및 체계 제시 - SW 안전 진단 분야, 진단 절차, 진단 방법, 진단 기법 등 제시 - 진단에 활용할 수 있는 템플릿, 예제, 실무적 고려사항 등 제시	126회 정보관리 3교시 3번 참조
356		출제예상	CSAP, CSAP(Cloud Security Assurance Program)	[정의] 클라우드 서비스 제공자가 제공하는 서비스에 대해 「클라우드 컴퓨팅 발전 및 이용자 보호에 관한 법률」 제 23조 제2항에 따라 정보보호 기준의 준수여부 확인을 인증기관이 평가·인증하여 이용자들이 안심하고 클라우드 서비스를 이용할 수 있도록 지원하는 제도	KISA 인증제도
357	물리적 보안	하	용어	(정의) 물리적 보안은 직원, 데이터, 시설, 설비, 시스템 등의 조직의 자산에 대한 물리적 보호를 의미 접근장치(시간장치 x), CCTV	
358			CWPP - (Cloud Workload Protection Platform)	하이브리드 및 멀티 클라우드 환경에서 서버 워크로드를 보호하기 위한 보안(가트너) [CWPP 8가지 주요기능] Iaas Stack(설기우 애워킴필) ▲보안 강화 및 설정/취약점 관리(Hardening, Configuration and Vulnerability Management) ▲네트워크 방화벽, 가시성 확보 및 마이크로세그멘테이션(Network Firewalling, Visibility and Microsegmentation) ▲시스템 무결성 보장(System Integrity Assurance) ▲애플리케이션 제어(Application Control/Whitelisting) ▲악스플로잇 예방 및 메모리 보호 (Exploit Prevention/Memory Protection) ▲서버 워크로드 EDR, 행위 모니터링 및 위협 탐지-대응 (Server Workload EDR, Behavioral Monitoring and Threat Detection/Response) ▲호스트 기반 침입 탐지 시스템 (Host-Based IPS With Vulnerability Shielding) ▲안티 멀웨어(Anti-malware Scanning) * 클라우드 책임공유모델(IaaS)의 일환으로 도입	
359		하	제로데이(Zero Day) 취약점	특정 소프트웨어의 아직까지 공표되지 않은, 혹은 공표되었지만 아직까지 패치 되지 않은 보안 취약점을 이용한 해킹의 통칭	
360		하	동적 WEP 키(Dynamic WEP Key)	무선 단말기와 AP 간의 WEP 키를 주기적으로 자동 변경함으로써 무선 랜(WLAN)의 보안성을 향상시킨 방식. 정적 WEP 키 방식은 공유된 해킹 툴로도 간단하게 해킹이 가능해서 이를 보완하기 위해 동적 WEP 키 방식	
361		하	MLS(Multi-Level Security)	국가 전산망 정보를 중요도에 기반한 세등급으로 분류, 자동적 보안통제 적용하여 보안성 유지하면서 원활한 데이터 공유를 실현하는 보안체계	제로트러스트 MFA, 기밀 (Classified), 민감 (Sensitive), 공개 (Open)
362		하	OT 사이버 보안 6 원칙	물, 에너지, 교통 인프라와 같은 사회 필수서비스의 운영 기술에 위협이 되는 사이버활동에 대해 국가적 시스템을 안전하게 보호하기 위한 원칙	안전 최우선, 비즈니스 지식, OT 데이터 인프라, 공급망, 사람
363		하	사전적정성 검토제	사업자가 AI 등 신기술 개발이나 신 서비스 제공을 기획하는 과정에서 개인정보 보호법 준수 여부가 불확실한 경우, 처리 환경에 적합한 개인정보 보호법 적용방안을 사업자와 개인정보보호위원회가 함께 협의하여 마련하는 제도 신청서제출, 신청요건 검토, 현황분석, 적용방안 마련, 적용방안 검토, 결과통보, 환류	모의 32회
364		하	BitB(Browser-in-the-Browser) 공격	피싱 공격의 한 형태로, 웹 브라우저 창을 가장한 가짜 로그인 창을 통해 사용자의 인증 정보를 탈취하는 고도화된 소셜 엔지니어링 기법 피싱공격, 가짜 로그인 창	
365		하	J2 공격(Jailbreak 2 Attack)	인공지능 언어모델 (의 내장된 윤리적 필터, 보안 정책, 콘텐츠 제한 시스템 가드레일 을 우회하기 위해, 역할 주입 (Role Injection), 허구 설정 (Fictional 사고 흐름 유도 (Chain of thought Prompting) 등의 고도화된 기법을 활용하여 AI 가 스스로 금지된 응답을 생성하도록 유도하는 2 세대 탈출 (Jailbreak) 공격 방식 Jailbreak, 프롬프트 단단계 구성 허구 설정 AI 의 자율적 판단왜곡, Chain of thought Prompting	
366		하	Shift Left Security	소프트웨어 개발 생명주기의 초기에 보안 활동을 통합해 결함을 조기에 발견하고 대응 시간과 비용을 절감하기 위해 테스트나 보안 검증을 앞당기는 보안 전략 Secure Coding 교육, 정적 코드 분석 (SAST), 오픈소스 종속성 점검 (SCA), IaC 보안 스캔, 보안 유닛 테스트, DevSecOps	
367		하	TARA(Threat Analysis and Risk Assessment)	사이버 보안 위협에 대한 체계적인 분석과 평가 과정을 통해, 차량 시스템이 직면할 수 있는 위험을 식별하고 대응 방안을 마련하는 방법론 제품 정의, 자산 식별, 시나리오 제작, 영향도 평가, 공격 경로 식별, 실현 가능성 평가, 위험도 결정, 위험관리 방법 결정	
368		출제예상	국가 망 보안체계 (National Network Security Framework)	주요 기반시설과 국가 공공기관이 직면한 복합적인 사이버 위협 으로부터 국가 핵심 기능과 업무의 연속성을 보호하기 위해 위협식별 위험 파악 보호대책 수립 및 적용 을 포함한 일련의 보안 원칙과 절차를 제공하는 체계적인 보안 프레임워크 국가정보보안기본지침 준비 → 등급분류 → 위험식별 → 보안대책 → 적절성평가조정 C/S/O 등급분류	
369		하	딥보이스(Deep Voice) 피싱	딥페이크(Deepfake) 와 보이스 피싱 Voice Phishing) 의 합성어로서 딥러닝 기반의 음성 합성 기술 (Voice Cloning) 을 활용해 실제 인물의 음성을 모방 하여 전화를 걸고, 금전이나 정보를 탈취하는 지능형 보이스피싱 수법 Deepfake, Voice Phishing, 딥러닝 음성합성 전화사기 금전 정보탈취 음성다중 검증 합성음성 탐지 사용자 보안교육	
370		출제예상	암호론 공격 기법	암호키 없이 암호화된 정보를 해독하거나 인증에 필요한 패스워드를 알아내기 위한 적극적인 공격 행위 COA, KPA, CPA, CCA	
371		하	위성체 보안 위협	미래 우주 경제 시대에 지속 가능한 우주 개발을 지원하기 위해 우주 분야 사이버보안 강화를 위한 모델 직접적인 공격, 통신구간 공격, 지상 시스템 공격, 공급망 공격, 내부자 위협, 위성자재 보안강화, 통신구간 보안, 지상 시스템 보안, 공급망 보안, 전반적인 보안 대책	
372		출제예상	프롬프트 인젝션 (Prompt Injection)	공격자가 악의적인 목적을 갖고 고안한 입력 프롬프트를 사용하여 LLM 모델 또는 LLM 기반 응용 프로그램으로 하여금 설계된 정상 범위를 벗어난 동작을 하게끔 유도하는 AI 모델 공격 악성입력, 취약한 모델 구조, 데이터 소스 조작, 직접 프롬프트 인젝션, 간접 프롬프트 인젝션	
373		하	디지털 포렌식 아티팩트(Artifact)	컴퓨터나 디지털 기기에서 사용자의 행위나 시스템 동작의 흔적을 보여주는 데이터나 파일 조각 시스템/응용 프로그램/파일 아티팩트	137 관리 1교시

374	하	BPFdoor(Berkeley Packet Filter door) 악성코드	BPF를 활용해 네트워크 패킷을 감시하며 외부 명령을 은밀히 수신하고 실행하는 리눅스 기반 보안시스템 우회 공격기법 스텔스 백도어, 메모리 상주, 보안시스템 우회, 매직 패킷, 리버스 쉘	137 관리 4교시
375	하	Open XDR(Open eXtended Detection & Response)	다양한 보안 벤더 제품과 연동 가능한 개방형 XDR 플랫폼. API와 표준 포맷 등으로 이기종 보안 기능들을 통합하는 보안 솔루션 다양한 보안 벤더 연동, 개방형 XDR플랫폼, 단일 보안벤더	
376	하	Native XDR(Native eXtended Detection & Response)	단일 벤더의 보안 솔루션 제품군을 중심으로 설계된 자체 생태계 중심의 통합 보안 솔루션	
377	하	다자간 연산(Secure Multi-Party Computation: SMPC)	조직 내 참여자들이 민감한 정보를 암호화하여 타인에게 공개하지 않는 범위 내에서 공동으로 각각의 데이터를 활용 및 처리할 수 있게 하는 PET 기술 중 하나로 자신이 가진 데이터 공개 없이 참여자 모두가 공동의 연산 결과를 가질 수 있도록 하는 분산 컴퓨팅 기술 비밀 공유(Secret Sharing), 왜곡 회로(Garbled Circuits)	
378	하	신뢰 실행 환경 (Trusted Execution Environment: TEE)	하드웨어 보안 메커니즘을 통해 민감 데이터에 안전하게 접근하고 이를 처리할 수 있도록 격리된 보호 환경을 제공하는 기술 하드웨어 보안 메커니즘, 격리된, 무결성 및 기밀성 보장, 신뢰성 보장, 물리적 공격 저항	
379	하	심 스와핑(SIM Swapping)	해커가 도용된 사용자 정보로 유심(USIM)을 복제하여, 복제된 유심을 통해 타인의 전화번호로 통신 및 인증을 탈취하는 공격 기법	
380	하	공간정보 안심구역	보안이 확보된 구역에서 공개가 제한된 고정밀 공간정보와 미공개 데이터를 누구나 융복합하여 분석 및 가공할 수 있는 공간 ArcGIS, AutoCAD, QGIS, R Studio, 공개제한 공간정보	
381	하	KCMVP(Korea Cryptographic Module Validation Program)	국가정보통신망에서 소통, 저장되는 비밀이 아닌 업무자료를 보호하기 위해 국가와 공공망에서 도입하는 암호모듈의 안전성과 구현 적합성을 검증하는 제도 사이버안보 업무규정, ISO/IEC 19790, ISO/IEC 24759, CMVP, FIPS 140	
382	하	로봇 보안모델	최신 IT 기술을 바탕으로 인간과 상호작용하여 다양한 형태의 서비스를 제공하는 것으로 상황판단 능력을 탑재하여 자율적으로 행동하는 것을 목표로 하는 서비스 로봇, 임베디드, 네트워크, 인프라, 인증 및 권한 관리, 데이터 보호, 네트워크 보호, 소프트웨어 보호	
383	하	MCP(Model Context Protocol)	대규모 언어 모델 (이 다양한 데이터 소스 및 도구와 안전하고 일관되게 상호작용할 수 있도록 지원하는 개방형 프로토콜 Tool Poisoning, Tool Pinning, Rug Pulls, Cross Server Attacks, 무분별한 설치, 취약한 보호체계	
384	하	RED(Radio Equipment Directive)	"Radio Equipment Directive"의 약자로, 유럽 시장에 출시되는 무선 장치의 안전성, 주파수 사용 효율, 전자기 간섭, 보안성 등을 관리하는 법적 지침(Directive) 무선 장치의 네트워크 보호 요건, 개인정보 보호 요건, 금융사기 방지 요건, EN 18031-1 Internet Connected Radio Equipment, EN 18031-2 Radio Equipment Processing Data, EN 18031-3 Equipment Handling Monetary Value	
385	하	EN 18031	EU RED 3.3(d/e/f) 조항에 명시된 사이버 보안 요건을 충족하기 위해 CEN(CEN: 유럽표준위원회)과 CENELEC(전기전자 표준위원회)이 공동으로 개발한 유럽 기술 표준(European Norm) 역으로 연결, Listener : 해커, 방화벽 우회 용이)	
386	하	KISA의 데이터백업 8대 보안 수칙	1. 오픈 사이트 운영, 2. 3-2-1 보관 전략, 3. 접근 통제 및 권한 관리, 4. 백업 서버 모니터링, 5. 정기적 복구 훈련, 6. 최신 보안패치 적용, 7. 백업 전 무결성 검증, 8. 자동 백업체계 운영	
387	하	Security Group	클라우드 인스턴스에 대한 가상 방화벽 역할로서 특정 인스턴스에 대한 트래픽 제어 장치 인스턴스, 서브넷(Subnet), Stateful(상태저장), Statefulless(상태 비저장), 허용(Allow), 허용 및 거부(Allow와 Deny)	
388	하	Network ACL	VPC(Virtual Private Cloud)내 서브넷의 전체 트래픽을 제어하는 가상 방화벽	
389	하	바인드 쉘(Bind Web Shell)	해커가 웹 브라우저를 통해 서버에 직접 명령을 내릴 수 있는 업로드 된 서버 스크립트 서버 스크립트, Listener : Host 서버)	
390	하	리버스 쉘(Reverse Web shell)	방화벽 우회가 가능한 웹서버가 공격자에게 역으로 연결하여 셸을 획득하는 침투 공격	
391	하	AI워터마크	AI가 생성한 인공지능 생성물에 사람이 인지할 수 있는 명시적 인지형 워터마크 또는 AI나 특수기술을 만들 이용하여 확인 가능 비인지형 워터마크 삽입 기술 LSB(Least Significant Bit), DCT (Discrete Cosine Transform), SynthID, Stable Signature, 추론과정	
392	하	CIA Triad	정보보안의 근간을 이루는 세 가지 핵심 가치로, 정보의 기밀성, 무결성, 가용성을 지속적으로 유지하고 보호하기 위한 보안의 기본 원칙 기밀성, 무결성, 가용성, 접근제어, 감사, 인증, 백업, 암호화 등	
393	하	제로클릭 공격(0-Click Attack)	사용자의 클릭이나 조작 없이 메시지 수신, 이미지 렌더링 등 단순 이벤트만으로 시스템의 취약점을 자동 실행하여 악성 행위를 유발하는 공격 기법 정수형 오버플로우, 버퍼 오버플로우, Use-After-Free, 타입 혼동(Type Confusion), 잘못된 최적화 패스, Side-Effect 오판, 스크립트 인젝션(Injection), 상태 전이 오류	
394	하	불변(Immutable) 백업	한 번 저장된 데이터가 지정된 기간 동안 누구도 수정, 삭제, 암호화할 수 없는 데이터 보호 기술. 읽기 전용, 객체 잠금, 불변 정책	
395	하	Ephemeral Diffie-Hellman (DHE) 와 Elliptic Curve DHE (ECDHE) 다. Perfect Forward Secrecy (PFS)	세션마다 임시 키 쌍을 생성하여 키 교환을 수행하는 방식의 디피-헬만 알고리즘으로, Perfect Forward Secrecy(PFS)를 제공하는 보안 프로토콜	
396	하	Elliptic Curve DHE (ECDHE)	타원 곡선 암호 기반으로 매 세션마다 임시 키를 생성하는 고성능 보안 키 교환 방식으로, DHE의 보안성과 효율성을 개선한 알고리즘	
397	하	Perfect Forward Secrecy (PFS)	세션 키가 유출되더라도 과거의 통신 내용을 복호화할 수 없도록 보장하며, DH 구조의 임시 키 방식(DHE, ECDHE)과 결합되어 구현되는 암호 통신 속성	